Sample Product

1.0.0

Sample Product SW-REPORT

metaeffekt GmbH
https://metaeffekt.com

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Imprint

Sample Product

Version: 1.0.0

SampleProduct

Version: 1.0.0

Sample Product SW-REPORT

Version: 01
Status: Final
Classification: PUBLIC
Date: 07.11.2025

Copyright 2025, metaeffekt GmbH

metaeffekt GmbH

https://metaeffekt.com

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Notice

Names and Trademarks

All company names, organization names, and product names mentioned in this documentation are used for identification purposes only. A trademark is explicitly identified as registered or unregistered trademark only if required by appropriate guidelines or license terms.

External Vulnerability Materials

Materials - including data, content, and references - covering vulnerability information from external sources are presented in this documentation 'AS IS'. metaeffekt GmbH does not claim any copyright on the included external materials nor is metaeffekt GmbH liable for the correctness and completeness of the presented external materials. Materials from external sources are included herein for informational purposes only. metaeffekt GmbH is not responsible for the availability and content provided by external links.

Third-Party Component Vulnerabilities

The vulnerabilities enlisted within this document are primarily vulnerabilities of third-party software or hardware components that are included within or integrated with assets of metaeffekt GmbH. The fact that such a component is affected by a known vulnerability must not necessarily imply that assets are affected. To determine the relevance and potential risks, vulnerabilities are categorized and assessed within the context of the assets using or integrating the components.

Vulnerability Assessment Categories

This report organizes vulnerabilities in three assessment categories:

- **Affected** - This category covers vulnerabilities that have been assessed were identified as vulnerabilities affecting one or more assets in scope.
- **Potentially Affected** - Vulnerabilities that have not yet been assessed are considered to potentially affect one or more assets in scope.
- **Not Affected** - In case a vulnerability does not have any impact on the assets in scope, the vulnerability is categorized to not affect the assets.

These categorizes are used specifically in statistics and summaries.

Vulnerability Assessment Status

On the individual level of a vulnerability in a specific usage, integration and deployment context the vulnerability assessment status can be determined:

- **Applicable** - A vulnerability is found to be included and to be potentially exploitable in the scope of an asset. In particular, no justification can be provided arguing that the vulnerability cannot be exploited.
- **Not Applicable** - A vulnerability is considered not applicable in case evidence can be provided, constituting the vulnerability either as not accessible or as not reachable in the context of an asset. Especially, vulnerabilities in functions or interfaces not in use or deactivated are considered not applicable.
- **Insignificant** - A vulnerability is regarded as insignificant in case the original severity does not exceed a predetermined score or a vulnerability has been assessed and is explicitly marked as insignificant in the given context. The status supports to prioritize assessments, while providing a comprehensive view.
- **Void** - Void vulnerabilities are vulnerabilities that have been reported and assessed for other versions of the assets considered in scope. Void vulnerabilities affect component versions that are not included in the current asset version. The affected components have either been patched or are not included in the currently provided assets. Void vulnerabilities are reported to provide continuity over a product's life cycle.
- **In Review** - A vulnerability is in review in case assessment details are insufficient or not available.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Vulnerability Remediation

Vulnerability assessment is performed to remediate vulnerabilities. During an assessment it is possible to capture a rationale to justify the assessment status and to further assessment details. In particular:

- Modification to the severity score (i.e. including context information) can be applied.
- Identified risks can be captured and disclosed.
- Measures can be concluded to mitigate risk.

Vulnerability Severity Metrics

Generally, vulnerability severity is measured using the *Common Vulnerability Scoring System (CVSS)* scoring system. Currently, two versions of the CVSS scoring system are commonly applied and supported by the NVD. This document uses both the CVSS version 2.0 and the CVSS versions 3.x.

In case a CVSS version 3.x vector is available all severity metrics are using this version. If no CVSS version 3.x vector is provided for a vulnerability, the severity metrics fall back to a CVSS version 2.0 vector, if available. The resulting metrics are used for computing scores, severity categorization, ordering and charting.

This approach is taken since CVSS version 3.x allows more fine-granular and therefore more differentiated assessments.

The report uses the default CVSS severity scheme as defined in the CVSS 3.1 specification:

Severity Rating	CVSS Score Range	Remarks
None	0.0	In the CVSS 2.0 specification 0.0 is included in severity rating Low.
Low	0.1 - 3.9	In the CVSS 2.0 specification 0.0 is included in severity rating Low.
Medium	4.0 - 6.9	
High	7.0 - 8.9	In the CVSS 2.0 specification the severity rating Critical does not exist. CVSS scores from 7.0 to 10.0 are all rated as High.
Critical	9.0 - 10.0	In the CVSS 2.0 specification the severity rating Critical does not exist. CVSS scores from 7.0 to 10.0 are all rated as High.

Table 1: CVSS Severity Scheme

Vulnerability Prioritization

The Vulnerability Priority Score automates the ranking of vulnerabilities based on their relevance within a specific context. The score is computed based on the contextualized CVSS score as a base score with additional metrics applied. These additional metrics are detailed in the priority sections of the vulnerability details chapters. A priority label is derived for each vulnerability indicating whether - due to an increased Priority Score - a timely treatment is due.

The Priority Score is a non-normalized, non-continuous metric. It is not capped in order to provide a relative measurement for ranking vulnerabilities applying a policy-driven prioritization.

External Vulnerability Sources

The *National Vulnerability Database (NVD)* is the primary data source for vulnerability information utilized. A vulnerable product is represented within NVD as *Common Product Enumeration (CPE)*; an individual vulnerability as *Common Vulnerability Exposure (CVE)*.

Advisory information is included from additional sources. These vary dependent on the product domain and target audience.

Copyright

This documentation is protected by copyright 2025, metaeffekt GmbH.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Table of Contents

Imprint **2**
Notice **3**

1 Overview **6**

2 SampleProduct Vulnerability Statistics **7**

3 SampleProduct Vulnerabilities **8**
3.1 Vulnerability List 8
3.2 Affected Assets 18
3.3 Affected Components 19
3.4 Vulnerability Details 31

Glossary **202**

Log of Template Changes **203**

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

1 Overview

The subsequent table provides details on the overall vulnerability assessment status.

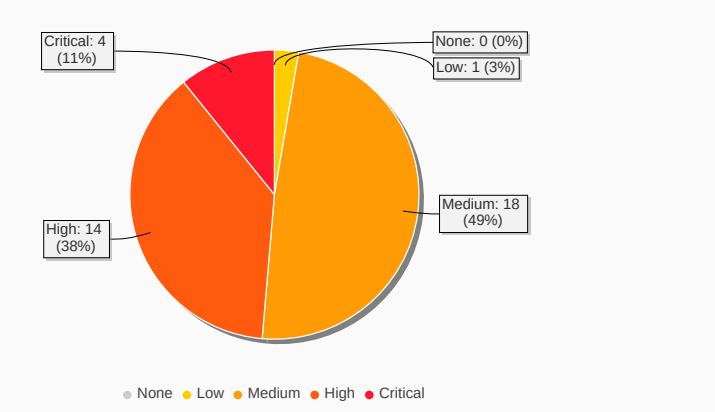
Severity	Affected	Potentially Affected	Not Affected	Total	Assessed
Critical	1	2	1	4	50,0 %
High	0	14	0	14	0,0 %
Medium	0	18	0	18	0,0 %
Low	0	1	0	1	0,0 %

Table 2: Vulnerability Statistics (SampleProduct)

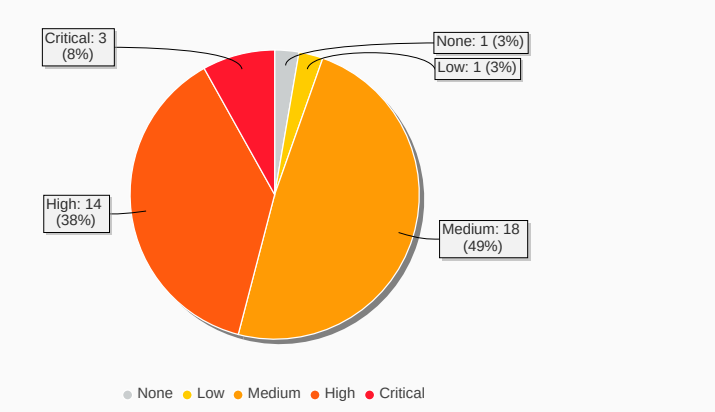
Applying the context-sensitive vulnerability assessment the following overall effective vulnerability status can be concluded at the point in time the report was generated.

Severity	Affected	Potentially Affected	Not Affected	Total	Assessed
Critical	1	2	0	3	33,3 %
High	0	14	0	14	0,0 %
Medium	0	18	0	18	0,0 %
Low	0	1	0	1	0,0 %
None	0	0	1	1	100,0 %

Table 3: Context Vulnerability Statistics (SampleProduct)



Initial Vulnerability Severity - Depicts the vulnerability severity distribution without assessment or context information.



Resulting Vulnerability Severity - Illustrates the vulnerability severity distribution after assessment in the given context.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

2 SampleProduct Vulnerability Statistics

The following table shows statistics for the identified vulnerabilities. The vulnerabilities are included in the statistics with their original unmodified severity.

Severity	Affected	Potentially Affected	Not Affected	Total	Assessed
Critical	1	2	1	4	50,0 %
High	0	14	0	14	0,0 %
Medium	0	18	0	18	0,0 %
Low	0	1	0	1	0,0 %

Table 4: Vulnerability Statistics (SampleProduct)

The following table shows statistics for the identified vulnerabilities. The vulnerabilities are included in the statistics with their modified severity if available or their unmodified severity otherwise.

Severity	Affected	Potentially Affected	Not Affected	Total	Assessed
Critical	1	2	0	3	33,3 %
High	0	14	0	14	0,0 %
Medium	0	18	0	18	0,0 %
Low	0	1	0	1	0,0 %
None	0	0	1	1	100,0 %

Table 5: Context Vulnerability Statistics (SampleProduct)

The following table shows statistics for the identified vulnerabilities from CISA KEV

Exploited in the Wild	Total	Percentage
KNOWN	3	8.0%
UNKNOWN	34	92.0%

Table 6: CISA KEV vulnerabilities statistics

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

3 SampleProduct Vulnerabilities

For the third-party components contained in SampleProduct 1.0.0 vulnerabilities have been queried from public vulnerability databases. The following sections cover the vulnerabilities for the different software parts.

3.1 Vulnerability List

The following vulnerabilities have been identified and categorized.

Affected

The following vulnerabilities are considered `Affected` within the given configuration:

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2021-44228	10.0	9.1	Critical	Critical	Escalate	Applicable
	CERT-EU-2021-074, CERT-EU-2021-073, CERT-EU-2021-076, CERT-EU-2021-075, CERT-EU-2021-067, CERT-EU-2022-005, CERT-EU-2021-070, CERT-EU-2021-072, CERT-EU-2021-071 CERTFR-2021-ALE-022 CERTFR-2021-AVI-953, CERTFR-2022-AVI-526, CERTFR-2021-AVI-951, CERTFR-2022-AVI-568, CERTFR-2022-AVI-016, CERTFR-2022-AVI-125, CERTFR-2022-AVI-124, CERTFR-2022-AVI-243, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-570, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-717, CERTFR-2024-AVI-0027 VU#930724 GHSA-jfh8-c2jp-5v3q WID-SEC-W-2023-0063_BSI, WID-SEC-W-2022-0351_BSI, WID-SEC-W-2024-0064_BSI ICSA-21-357-02_CISA, ICSA-22-034-01_CISA RHSA-2021:5130_Red Hat, RHSA-2021:5108_Red Hat, RHSA-2022:0296_Red Hat, RHSA-2021:5148_Red Hat, RHSA-2025:1746_Red Hat, RHSA-2021:5093_Red Hat, RHSA-2021:5126_Red Hat, RHSA-2022:0082_Red Hat, RHSA-2021:5141_Red Hat, RHSA-2021:5134_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2021:5127_Red Hat, RHSA-2021:5133_Red Hat, RHSA-2021:5094_Red Hat, RHSA-2021:5128_Red Hat, RHSA-2025:1747_Red Hat, RHSA-2021:5132_Red Hat, RHSA-2021:5106_Red Hat, RHSA-2021:5137_Red Hat, RHSA-2021:5107_Red Hat, RHSA-2021:5140_Red Hat, RHSA-2021:5138_Red Hat, RHSA-2021:5129_Red Hat CVE-2021-44228_Red Hat SCA-2021-0003_sick SSA-397453_Siemens, SSA-479842_Siemens, SSA-714170_Siemens SSA-661247_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.15.0), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.15.0), cpe:/a:apache:log4j:2.16.0,					

Table 7: Affected Category (SampleProduct)

Potentially Affected

The following vulnerabilities are considered `Potentially Affected` within the given configuration:

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2022-22965	9.8		Critical		Escalate	In Review
	CERT-EU-2022-023 CERTFR-2022-AVI-307, CERTFR-2022-AVI-626, CERTFR-2022-AVI-659, CERTFR-2022-AVI-326, CERTFR-2022-AVI-568, CERTFR-2022-AVI-523, CERTFR-2022-AVI-456, CERTFR-2022-AVI-345, CERTFR-2022-AVI-487, CERTFR-2022-AVI-376, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-297, CERTFR-2022-AVI-572, CERTFR-2022-AVI-472, CERTFR-2022-AVI-494, CERTFR-2022-AVI-360, CERTFR-2022-AVI-481, CERTFR-2022-AVI-371, CERTFR-2022-AVI-928, CERTFR-2022-AVI-716, CERTFR-2022-AVI-539 VU#970766 GHSA-36p3-wjmg-h94x WID-SEC-W-2023-0139_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2022-0033_BSI, WID-SEC-W-2023-1016_BSI, WID-SEC-W-2023-0016_BSI, WID-SEC-W-2022-0169_BSI, WID-SEC-W-2023-1012_BSI ICSA-22-286-05_CISA RHSA-2022:1306_Red Hat, RHSA-2022:1626_Red Hat, RHSA-2022:1360_Red Hat, RHSA-2022:1378_Red Hat, RHSA-2022:1333_Red Hat, RHSA-2022:1627_Red Hat, RHSA-2022:1379_Red Hat CVE-2022-22965_Red Hat SSA-254054_Siemens					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.18), OSV org.springframework:spring-beans (Maven) [5.3.0, 5.3.18), cpe:/a:vmware_tanzu:spring_framework:5.3.18,					
CVE-2016-1000027	9.8		Critical		Escalate	In Review
	CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-0113, CERTFR-2023-AVI-0908, CERTFR-2025-AVI-0590, CERTFR-2023-AVI-0839 GHSA-4wrc-f8pq-fpqp WID-SEC-W-2023-2625_BSI, WID-SEC-W-2023-1060_BSI CVE-2016-1000027_Red Hat					
	cpe:/a:vmware:spring_framework [, 6.0.0)					
CVE-2024-47554	8.7		High		Elevated	In Review
	CERTFR-2025-AVI-0671, CERTFR-2024-AVI-1081, CERTFR-2025-AVI-0058, CERTFR-2025-AVI-0003, CERTFR-2025-AVI-0337, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0170 GHSA-78wr-2p64-hpwj WID-SEC-W-2025-1563_BSI, WID-SEC-W-2025-0807_BSI, WID-SEC-W-2025-0826_BSI, WID-SEC-W-2025-0811_BSI, WID-SEC-W-2025-0001_BSI, WID-SEC-W-2025-0810_BSI, WID-SEC-W-2025-0135_BSI, WID-SEC-W-2025-0824_BSI, WID-SEC-W-2025-1572_BSI, WID-SEC-W-2025-0822_BSI, WID-SEC-W-2025-0805_BSI, WID-SEC-W-2025-0143_BSI, WID-SEC-W-2025-1565_BSI, WID-SEC-W-2025-0818_BSI, WID-SEC-W-2025-0147_BSI, WID-SEC-W-2025-1562_BSI, WID-SEC-W-2025-0814_BSI, WID-SEC-W-2025-1570_BSI, WID-SEC-W-2025-0823_BSI, WID-SEC-W-2025-1560_BSI, WID-SEC-W-2025-0808_BSI, WID-SEC-W-2025-0817_BSI, WID-SEC-W-2024-3082_BSI, WID-SEC-W-2025-0819_BSI RHSA-2025:2416_Red Hat, RHSA-2024:9571_Red Hat CVE-2024-47554_Red Hat STACKSA_2024_0113_0001_Stackable GmbH					
	cpe:/a:apache:commons_io [2.0, 2.14.0), OSV commons-io:commons-io (Maven) [2.0, 2.14.0)					
CVE-2024-22262	8.1		High		Elevated	In Review

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0298, CERTFR-2024-AVI-0595, CERTFR-2024-AVI-0498, CERTFR-2024-AVI-0599, CERTFR-2024-AVI-0886 GHSA-2wrp-6fg6-hmc5 WID-SEC-W-2024-3195_BSI, WID-SEC-W-2024-3218_BSI, WID-SEC-W-2024-1642_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1622_BSI, WID-SEC-W-2024-1637_BSI, WID-SEC-W-2024-1643_BSI, WID-SEC-W-2024-1654_BSI, WID-SEC-W-2024-1641_BSI, WID-SEC-W-2024-3191_BSI, WID-SEC-W-2024-1656_BSI, WID-SEC-W-2024-1659_BSI, WID-SEC-W-2024-1207_BSI, WID-SEC-W-2024-3192_BSI, WID-SEC-W-2024-0854_BSI, WID-SEC-W-2024-1638_BSI ICSA-25-261-04_CISA RHSA-2024:3708_Red Hat CVE-2024-22262_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.1.6, , cpe:/a:vmware_tanzu:spring_framework:6.0.19, cpe:/a:vmware_tanzu:spring_framework:5.3.34					
CVE-2024-22259	8.1		High		Due	In Review
	CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0223 GHSA-hgjh-9rj2-g67j WID-SEC-W-2024-0869_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1637_BSI, WID-SEC-W-2024-0639_BSI RHSA-2024:2945_Red Hat CVE-2024-22259_Red Hat					
	cpe:/a:vmware:spring_framework [, 5.3.33), cpe:/a:vmware_tanzu:spring_framework:6.1.5, , cpe:/a:vmware_tanzu:spring_framework:5.3.33, cpe:/a:vmware_tanzu:spring_framework:6.0.18					
CVE-2024-22243	8.1		High		Due	In Review
	CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0154 GHSA-ccgv-vj62-xf9h OXAS-ADV-2024-0005_Open-Exchange WID-SEC-W-2024-0457_BSI, WID-SEC-W-2024-0868_BSI, WID-SEC-W-2025-0810_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1637_BSI RHSA-2024:3354_Red Hat CVE-2024-22243_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.0.17, , cpe:/a:vmware_tanzu:spring_framework:5.3.32, cpe:/a:vmware_tanzu:spring_framework:6.1.4					
CVE-2025-41249	7.5		High		Elevated	In Review
	CERTFR-2025-AVI-0792 GHSA-jmp9-x22r-554x WID-SEC-W-2025-2060_BSI CVE-2025-41249_Red Hat					
	OSV org.springframework:spring-core (Maven) [5.3.0, 5.3.44], cpe:/a:vmware_tanzu:spring_framework:6.2.11,					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2024-38816	7.5		High		Due	In Review
	CERTFR-2025-AVI-0210, CERTFR-2025-AVI-0585, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-1015, CERTFR-2025-AVI-0481, CERTFR-2024-AVI-1006, CERTFR-2024-AVI-0776 GHSA-cx7f-g6mp-7hqm WID-SEC-W-2024-3681_BSI, WID-SEC-W-2024-3195_BSI, WID-SEC-W-2024-3180_BSI, WID-SEC-W-2024-3508_BSI, WID-SEC-W-2024-2135_BSI RHSA-2024:8064_Red Hat, RHSA-2024:11023_Red Hat CVE-2024-38816_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.40, , cpe:/a:vmware_tanzu:spring_framework:6.0.24					
CVE-2023-34053	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-0145, CERTFR-2023-AVI-0980 GHSA-v94h-hvhg-mf9h WID-SEC-W-2023-3009_BSI, WID-SEC-W-2024-0870_BSI, WID-SEC-W-2024-0869_BSI, WID-SEC-W-2024-0106_BSI CVE-2023-34053_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.0.14,					
CVE-2023-20860	7.5		High		Due	In Review
	CERTFR-2023-AVI-0567, CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0398, CERTFR-2023-AVI-0990, CERTFR-2023-AVI-0397 GHSA-7phw-cxx7-q9vq WID-SEC-W-2023-1755_BSI, WID-SEC-W-2023-0697_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2023-1142_BSI RHSA-2023:3185_Red Hat, RHSA-2023:4612_Red Hat, RHSA-2023:3771_Red Hat, RHSA-2023:4983_Red Hat, RHSA-2023:3610_Red Hat, RHSA-2023:2100_Red Hat, RHSA-2023:3622_Red Hat, RHSA-2023:3663_Red Hat, RHSA-2023:3954_Red Hat, RHSA-2023:3625_Red Hat CVE-2023-20860_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.26), cpe:/a:vmware_tanzu:spring_framework:5.3.26, , cpe:/a:vmware_tanzu:spring_framework:6.0.7					
CVE-2022-25844	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-1057, CERTFR-2023-AVI-0245 GHSA-m2h2-264f-f486 WID-SEC-W-2022-0507_BSI, WID-SEC-W-2024-0967_BSI CVE-2022-25844_Red Hat					
	cpe:/a:angularjs:angular:::~~~node.js~~ [1.7.0, ,]					
CVE-2021-36090	7.5		High		Elevated	In Review
	CERTFR-2023-AVI-0073, CERTFR-2022-AVI-239, CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2023-AVI-0325, CERTFR-2021-AVI-932, CERTFR-2021-AVI-943, CERTFR-2021-AVI-804, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-mc84-pj99-q6hh					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	WID-SEC-W-2023-0132_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2023-0426_BSI, WID-SEC-W-2024-2180_BSI, WID-SEC-W-2023-1016_BSI, WID-SEC-W-2023-1017_BSI, WID-SEC-W-2024-1627_BSI, WID-SEC-W-2024-0123_BSI, WID-SEC-W-2024-1653_BSI, WID-SEC-W-2023-1807_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-36090_Red Hat					
	cpe:/a:apache:commons_compress [1.0, 1.21), OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35517	7.5		High		Elevated	In Review
	CERTFR-2023-AVI-0073, CERTFR-2022-AVI-239, CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-932, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-xqfj-vm6h-2x34 WID-SEC-W-2022-0607_BSI, WID-SEC-W-2023-0426_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-35517_Red Hat					
	cpe:/a:apache:commons_compress [1.1, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35516	7.5		High		Elevated	In Review
	CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-crv7-7245-f45f WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-35516_Red Hat					
	cpe:/a:apache:commons_compress [1.6, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35515	7.5		High		Elevated	In Review
	CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-7hfm-57qf-j43q WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-35515_Red Hat					
	cpe:/a:apache:commons_compress [1.6, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2019-12402	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-0590 GHSA-53x6-4x5p-rrvv WID-SEC-W-2024-1627_BSI, WID-SEC-W-2022-0770_BSI, WID-SEC-W-2022-1375_BSI, WID-SEC-W-2024-1773_BSI RHSA-2021:3140_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CVE-2019-12402_Red Hat					
	cpe:/a:apache:commons_compress [1.15, 1.18], OSV org.apache.commons:commons-compress (Maven) [1.15, 1.19)					
CVE-2021-44832	6.6		Medium		Due	In Review
	CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-933, CERTFR-2022-AVI-205, CERTFR-2022-AVI-125, CERTFR-2022-AVI-345, CERTFR-2022-AVI-960, CERTFR-2022-AVI-366, CERTFR-2022-AVI-056, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-717, CERTFR-2024-AVI-0027 GHSA-8489-44mv-ggj8 WID-SEC-W-2023-1524_BSI, WID-SEC-W-2023-0122_BSI, WID-SEC-W-2022-0197_BSI, WID-SEC-W-2023-0123_BSI, WID-SEC-W-2024-2180_BSI, WID-SEC-W-2022-0169_BSI, WID-SEC-W-2024-0064_BSI, WID-SEC-W-2023-1031_BSI RHSA-2022:0083_Red Hat, RHSA-2022:0138_Red Hat, RHSA-2022:0236_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2022:0493_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2022:0467_Red Hat, RHSA-2022:0181_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0226_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2022:0485_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2022:0225_Red Hat, RHSA-2022:0230_Red Hat, RHSA-2022:1299_Red Hat, RHSA-2022:0227_Red Hat CVE-2021-44832_Red Hat SSA-784507_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.17.1), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.17.1)					
CVE-2025-48924	6.5		Medium		None	In Review
	CERTFR-2025-AVI-0754, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756 GHSA-j288-q9x7-2f5v WID-SEC-W-2025-1540_BSI RHSA-2025:12511_Red Hat, RHSA-2025:16407_Red Hat, RHSA-2025:15697_Red Hat CVE-2025-48924_Red Hat					
	cpe:/a:apache:commons_lang [3.0, 3.18.0), OSV commons-lang:commons-lang (Maven) [2.0, 2.6], OSV org.apache.commons:commons-lang3 (Maven) [3.0, 3.18.0)					
CVE-2025-41234	6.5		Medium		Elevated	In Review
	CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0506 GHSA-6r3c-xf4w-jxjm WID-SEC-W-2025-1319_BSI CVE-2025-41234_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.2.8, , cpe:/a:vmware_tanzu:spring_framework:6.1.21					
CVE-2023-20863	6.5		Medium		Elevated	In Review
	CERTFR-2023-AVI-0798, CERTFR-2023-AVI-0567, CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0863, CERTFR-2023-AVI-0990, CERTFR-2024-AVI-0324 GHSA-wxqc-pxw9-g2p8 WID-SEC-W-2023-1812_BSI, WID-SEC-W-2024-0871_BSI, WID-SEC-W-2023-2675_BSI, WID-SEC-W-2023-1847_BSI, WID-SEC-W-2023-2688_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-0966_BSI, WID-					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	SEC-W-2023-1808_BSI, WID-SEC-W-2023-2674_BSI, WID-SEC-W-2023-1804_BSI, WID-SEC-W-2023-1791_BSI, WID-SEC-W-2023-2681_BSI, WID-SEC-W-2023-1142_BSI, WID-SEC-W-2024-0888_BSI, WID-SEC-W-2023-1813_BSI, WID-SEC-W-2023-1782_BSI, WID-SEC-W-2023-2690_BSI, WID-SEC-W-2023-1811_BSI, WID-SEC-W-2023-2679_BSI, WID-SEC-W-2024-3197_BSI, WID-SEC-W-2023-1807_BSI RHSA-2023:2099_Red Hat, RHSA-2023:2100_Red Hat CVE-2023-20863_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.27), OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.27), cpe:/a:vmware_tanzu:spring_framework:6.0.8, , cpe:/a:vmware_tanzu:spring_framework:5.3.27					
CVE-2023-20861	6.5		Medium		Elevated	In Review
	CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0990 GHSA-564r-hj7v-mcr5 WID-SEC-W-2023-1812_BSI, WID-SEC-W-2023-1813_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-1755_BSI, WID-SEC-W-2024-0874_BSI, WID-SEC-W-2023-1808_BSI, WID-SEC-W-2023-0697_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2023-1142_BSI RHSA-2023:3185_Red Hat, RHSA-2023:4612_Red Hat, RHSA-2024:0778_Red Hat, RHSA-2023:3771_Red Hat, RHSA-2023:4983_Red Hat, RHSA-2023:3610_Red Hat, RHSA-2023:2100_Red Hat, RHSA-2023:3622_Red Hat, RHSA-2023:3954_Red Hat CVE-2023-20861_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.25], OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.26)					
CVE-2022-22971	6.5		Medium		Elevated	In Review
	CERTFR-2022-AVI-454, CERTFR-2024-AVI-0240, CERTFR-2023-AVI-0034, CERTFR-2023-AVI-0276, CERTFR-2022-AVI-935 GHSA-rqph-vqwm-22vc WID-SEC-W-2023-0138_BSI, WID-SEC-W-2023-0809_BSI, WID-SEC-W-2023-0864_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-1017_BSI, WID-SEC-W-2023-1809_BSI, WID-SEC-W-2023-0137_BSI, WID-SEC-W-2022-0361_BSI, WID-SEC-W-2023-1031_BSI, WID-SEC-W-2023-0126_BSI RHSA-2023:3185_Red Hat, RHSA-2023:1661_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22971_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.19]					
CVE-2022-22950	6.5		Medium		Elevated	In Review
	CERTFR-2022-AVI-626, CERTFR-2022-AVI-523, CERTFR-2022-AVI-279, CERTFR-2024-AVI-0240, CERTFR-2022-AVI-539 GHSA-558x-2xjg-6232 WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2022-1035_BSI, WID-SEC-W-2023-1809_BSI ICSA-22-286-05_CISA RHSA-2022:8761_Red Hat, RHSA-2022:5555_Red Hat, RHSA-2022:5903_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22950_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.17), OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.17), cpe:/a:vmware_tanzu:spring_framework:5.3.17,					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2022-25869	6.1		Medium		None	In Review
	CERTFR-2025-AVI-0021 GHSA-prc3-vjfx-vhm9 WID-SEC-W-2024-0967_BSI, WID-SEC-W-2022-0701_BSI CVE-2022-25869_Red Hat					
	cpe:/a:angularjs:angular:::~~~node.js~~					
CVE-2025-41242	5.9		Medium		None	In Review
	CERTFR-2025-AVI-0696, CERTFR-2025-AVI-0754, CERTFR-2025-AVI-0756 GHSA-r936-gwx5-v52f WID-SEC-W-2025-1832_BSI CVE-2025-41242_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.2.10,					
CVE-2021-45105	5.9		Medium		Elevated	In Review
	CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-568, CERTFR-2022-AVI-125, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-570, CERTFR-2022-AVI-717 GHSA-p6xc-xr62-6r2g WID-SEC-W-2022-0811_BSI, WID-SEC-W-2023-0119_BSI RHSA-2022:0083_Red Hat, RHSA-2022:1469_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2022:0047_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2022:0026_Red Hat, RHSA-2022:0043_Red Hat, RHSA-2022:1463_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0042_Red Hat, RHSA-2022:0219_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2022:0044_Red Hat, RHSA-2022:1462_Red Hat, RHSA-2022:1299_Red Hat CVE-2021-45105_Red Hat SSA-479842_Siemens, SSA-501673_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.16.0], OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.17.0)					
CVE-2024-25710	5.5		Medium		None	In Review
	CERTFR-2024-AVI-0305, CERTFR-2024-AVI-0903, CERTFR-2024-AVI-0958, CERTFR-2024-AVI-0939, CERTFR-2024-AVI-1081, CERTFR-2024-AVI-1061, CERTFR-2024-AVI-1051, CERTFR-2025-AVI-0512, CERTFR-2025-AVI-0622, CERTFR-2024-AVI-1067, CERTFR-2024-AVI-0330, CERTFR-2024-AVI-1103, CERTFR-2025-AVI-0590 GHSA-4g9r-vxhx-9pgx OXAS-ADV-2024-0003_Open-Exchange WID-SEC-W-2025-0225_BSI, WID-SEC-W-2024-3663_BSI, WID-SEC-W-2024-3674_BSI, WID-SEC-W-2024-1642_BSI, WID-SEC-W-2025-0814_BSI, WID-SEC-W-2024-0818_BSI, WID-SEC-W-2024-1360_BSI, WID-SEC-W-2024-0414_BSI, WID-SEC-W-2024-3678_BSI, WID-SEC-W-2025-0818_BSI RHSA-2024:1797_Red Hat, RHSA-2024:1706_Red Hat, RHSA-2025:7625_Red Hat, RHSA-2024:1662_Red Hat, RHSA-2024:1924_Red Hat, RHSA-2024:1509_Red Hat, RHSA-2024:3989_Red Hat, RHSA-2024:2833_Red Hat, RHSA-2024:4057_Red Hat, RHSA-2024:3527_Red Hat CVE-2024-25710_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	cpe:/a:apache:commons_compress [1.3, 1.26.0), OSV org.apache.commons:commons-compress (Maven) [1.3, 1.26.0)					
CVE-2024-38828	5.3		Medium		None	In Review
	CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0114, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-0991, CERTFR-2025-AVI-0481 GHSA-w3c8-7r8f-9jp8 WID-SEC-W-2025-0307_BSI, WID-SEC-W-2025-0821_BSI, WID-SEC-W-2024-3473_BSI, WID-SEC-W-2025-1572_BSI CVE-2024-38828_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.42,					
CVE-2024-38820	5.3		Medium		None	In Review
	CERTFR-2025-AVI-0210, CERTFR-2024-AVI-1081, CERTFR-2024-AVI-0900, CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0114, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0190, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0604, CERTFR-2025-AVI-0054 GHSA-4gc7-5j7h-4qph WID-SEC-W-2025-0307_BSI, WID-SEC-W-2025-0521_BSI, WID-SEC-W-2024-3237_BSI, WID-SEC-W-2025-0819_BSI CVE-2024-38820_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.41), OSV org.springframework:spring-context (Maven) [0, 5.3.40]					
CVE-2024-38809	5.3		Medium		None	In Review
	CERTFR-2024-AVI-0689, CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0481 GHSA-2rmj-mq67-h97g WID-SEC-W-2024-1853_BSI, WID-SEC-W-2024-3180_BSI RHSA-2024:8064_Red Hat CVE-2024-38809_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.38, , cpe:/a:vmware_tanzu:spring_framework:6.1.12, cpe:/a:vmware_tanzu:spring_framework:6.0.23					
CVE-2022-22970	5.3		Medium		None	In Review
	CERTFR-2022-AVI-626, CERTFR-2023-AVI-0418, CERTFR-2023-AVI-0116, CERTFR-2022-AVI-454, CERTFR-2024-AVI-0240, CERTFR-2023-AVI-0276 GHSA-hh26-6xwr-ggv7 WID-SEC-W-2023-0809_BSI, WID-SEC-W-2023-0864_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-0137_BSI, WID-SEC-W-2022-0361_BSI RHSA-2023:3185_Red Hat, RHSA-2023:1661_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22970_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.19], OSV org.springframework:spring-beans (Maven) [5.3.0, 5.3.20)					
CVE-2022-22968	5.3		Medium		Elevated	In Review

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CERTFR-2022-AVI-626, CERTFR-2022-AVI-952, CERTFR-2022-AVI-655, CERTFR-2022-AVI-344, CERTFR-2022-AVI-539, CERTFR-2022-AVI-935 GHSA-g5mm-vmx4-3rg7 WID-SEC-W-2022-0735_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI RHSA-2022:5532_Red Hat, RHSA-2022:5101_Red Hat CVE-2022-22968_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.18], OSV org.springframework:spring-context (Maven) [5.3.0, 5.3.19)					
CVE-2020-13956	5.3		Medium		None	In Review
	CERTFR-2021-AVI-556, CERTFR-2024-AVI-0459, CERTFR-2021-AVI-559, CERTFR-2021-AVI-943, CERTFR-2022-AVI-056, CERTFR-2023-AVI-0861, CERTFR-2021-AVI-804, CERTFR-2023-AVI-0110, CERTFR-2025-AVI-0590, CERTFR-2023-AVI-0839 GHSA-7r82-7xv7-xcpj WID-SEC-W-2024-1643_BSI, WID-SEC-W-2024-1872_BSI, WID-SEC-W-2023-0132_BSI, WID-SEC-W-2024-1659_BSI, WID-SEC-W-2023-2625_BSI, WID-SEC-W-2023-2691_BSI, WID-SEC-W-2024-3197_BSI, WID-SEC-W-2022-0044_BSI, WID-SEC-W-2023-2674_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2024-0794_BSI, WID-SEC-W-2024-1637_BSI RHSA-2021:0250_Red Hat, RHSA-2021:0603_Red Hat, RHSA-2021:0246_Red Hat, RHSA-2021:0327_Red Hat, RHSA-2021:1044_Red Hat, RHSA-2021:4100_Red Hat, RHSA-2022:1860_Red Hat, RHSA-2021:0248_Red Hat, RHSA-2022:1861_Red Hat, RHSA-2021:0247_Red Hat, RHSA-2021:3140_Red Hat, RHSA-2022:0722_Red Hat, RHSA-2023:3954_Red Hat, RHSA-2021:0084_Red Hat, RHSA-2021:3700_Red Hat, RHSA-2021:0811_Red Hat CVE-2020-13956_Red Hat					
	cpe:/a:apache:http_components:5.0.3, , cpe:/a:apache:http_components:4.5.13					
CVE-2024-38808	5.1		Medium		Elevated	In Review
	CERTFR-2024-AVI-0689, CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0756 GHSA-9cmq-m9j5-mvww WID-SEC-W-2024-1853_BSI, WID-SEC-W-2024-3221_BSI RHSA-2024:6508_Red Hat, RHSA-2024:8887_Red Hat, RHSA-2024:8884_Red Hat, RHSA-2024:8886_Red Hat, RHSA-2024:8885_Red Hat CVE-2024-38808_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.39), OSV org.springframework:spring-expression (Maven) [0, 5.3.39), cpe:/a:vmware_tanzu:spring_framework:5.3.38, , cpe:/a:vmware_tanzu:spring_framework:5.3.39					
CVE-2025-22233	3.1		Low		None	In Review
	CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0524, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0417, CERTFR-2025-AVI-0580 GHSA-4wp7-92pw-q264 WID-SEC-W-2025-1077_BSI CVE-2025-22233_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	OSV org.springframework:spring-context (Maven) [0, 5.3.39], cpe:/a:vmware_tanzu:spring_framework:5.3.43, , cpe:/a:vmware_tanzu:spring_framework:6.1.20, cpe:/a:vmware_tanzu:spring_framework:6.0.28, cpe:/a:vmware_tanzu:spring_framework:6.2.7					

Table 8: Potentially Affected Category (SampleProduct)

Not Affected

The following vulnerabilities are considered `Not Affected` within the given configuration:

Name	Score	Severity	Priority	Status
CVE-2021-45046	9.0	Critical	None	Not Applicable
	CERT-EU-2021-076, CERT-EU-2021-075, CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-1027, CERTFR-2021-AVI-951, CERTFR-2022-AVI-568, CERTFR-2022-AVI-125, CERTFR-2022-AVI-124, CERTFR-2022-AVI-570, CERTFR-2022-AVI-717 VU#930724 GHSA-7rjr-3q55-vv33 WID-SEC-W-2023-0063_BSI, WID-SEC-W-2022-0352_BSI RHSA-2022:0083_Red Hat, RHSA-2022:0138_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2021:5108_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2021:5148_Red Hat, RHSA-2025:1746_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2021:5141_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2021:5127_Red Hat, RHSA-2021:5094_Red Hat, RHSA-2021:5128_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2025:1747_Red Hat, RHSA-2021:5106_Red Hat, RHSA-2022:1299_Red Hat, RHSA-2021:5137_Red Hat, RHSA-2021:5107_Red Hat, RHSA-2021:5129_Red Hat CVE-2021-45046_Red Hat SSA-397453_Siemens, SSA-479842_Siemens, SSA-714170_Siemens SSA-661247_Siemens			
	cpe:/a:apache:log4j [2.13.0, 2.16.0), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.16.0), cpe:/a:apache:log4j:2.16.0,			

Table 9: Not Affected Category (SampleProduct)

3.2 Affected Assets

A

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Apache Log4j	`log4j-core-2.14.0.jar`	`2.14.0`
@angular/common	`@angular/common-10.0.14`	`10.0.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Table 10: A Affected Components

B

Component	Artifact Id	Version
Apache HTTP Components	`httpcore-4.4.13.jar`	`4.4.13`

Table 11: B Affected Components

C

Component	Artifact Id	Version
Apache Commons IO	`commons-io-2.7.jar`	`2.7`
Apache Commons Lang	`commons-lang3-3.6.jar`	`3.6`
Apache Commons Lang	`commons-lang-2.4.jar`	`2.4`

Table 12: C Affected Components

3.3 Affected Components

@angular/common

Artifacts

Component	Artifact Id	Version
@angular/common	`@angular/common-10.0.14`	`10.0.14`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2022-25844	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-1057, CERTFR-2023-AVI-0245 GHSA-m2h2-264f-f486 WID-SEC-W-2022-0507_BSI, WID-SEC-W-2024-0967_BSI CVE-2022-25844_Red Hat					
	cpe:/a:angularjs:angular:::~~~node.js~~ [1.7.0, ,]					
CVE-2022-25869	6.1		Medium		None	In Review
	CERTFR-2025-AVI-0021 GHSA-prc3-vjfx-vhm9 WID-SEC-W-2024-0967_BSI, WID-SEC-W-2022-0701_BSI CVE-2022-25869_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	cpe:/a:angularjs:angular:::~~~node.js~~					

Table 13: @angular/common Vulnerabilites

Apache Commons IO

Artifacts

Component	Artifact Id	Version
Apache Commons IO	`commons-io-2.7.jar`	`2.7`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2024-47554	8.7		High		Elevated	In Review
	CERTFR-2025-AVI-0671, CERTFR-2024-AVI-1081, CERTFR-2025-AVI-0058, CERTFR-2025-AVI-0003, CERTFR-2025-AVI-0337, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0170 GHSA-78wr-2p64-hpwj WID-SEC-W-2025-1563_BSI, WID-SEC-W-2025-0807_BSI, WID-SEC-W-2025-0826_BSI, WID-SEC-W-2025-0811_BSI, WID-SEC-W-2025-0001_BSI, WID-SEC-W-2025-0810_BSI, WID-SEC-W-2025-0135_BSI, WID-SEC-W-2025-0824_BSI, WID-SEC-W-2025-1572_BSI, WID-SEC-W-2025-0822_BSI, WID-SEC-W-2025-0805_BSI, WID-SEC-W-2025-0143_BSI, WID-SEC-W-2025-1565_BSI, WID-SEC-W-2025-0818_BSI, WID-SEC-W-2025-0147_BSI, WID-SEC-W-2025-1562_BSI, WID-SEC-W-2025-0814_BSI, WID-SEC-W-2025-1570_BSI, WID-SEC-W-2025-0823_BSI, WID-SEC-W-2025-1560_BSI, WID-SEC-W-2025-0808_BSI, WID-SEC-W-2025-0817_BSI, WID-SEC-W-2024-3082_BSI, WID-SEC-W-2025-0819_BSI RHSA-2025:2416_Red Hat, RHSA-2024:9571_Red Hat CVE-2024-47554_Red Hat STACKSA_2024_0113_0001_Stackable GmbH					
	cpe:/a:apache:commons_io [2.0, 2.14.0), OSV commons-io:commons-io (Maven) [2.0, 2.14.0)					

Table 14: Apache Commons IO Vulnerabilites

Apache Commons Lang

Artifacts

Component	Artifact Id	Version
Apache Commons Lang	`commons-lang-2.4.jar`	`2.4`
Apache Commons Lang	`commons-lang3-3.6.jar`	`3.6`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2025-48924	6.5		Medium		None	In Review
	CERTFR-2025-AVI-0754, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756 GHSA-j288-q9x7-2f5v WID-SEC-W-2025-1540_BSI					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	RHSA-2025:12511_Red Hat, RHSA-2025:16407_Red Hat, RHSA-2025:15697_Red Hat CVE-2025-48924_Red Hat					
	cpe:/a:apache:commons_lang [3.0, 3.18.0), OSV commons-lang:commons-lang (Maven) [2.0, 2.6], OSV org.apache.commons:commons-lang3 (Maven) [3.0, 3.18.0)					

Table 15: Apache Commons Lang Vulnerabilites

Apache Commons Compress

Artifacts

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2021-36090	7.5		High		Elevated	In Review
	CERTFR-2023-AVI-0073, CERTFR-2022-AVI-239, CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2023-AVI-0325, CERTFR-2021-AVI-932, CERTFR-2021-AVI-943, CERTFR-2021-AVI-804, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-mc84-pj99-q6hh WID-SEC-W-2023-0132_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2023-0426_BSI, WID-SEC-W-2024-2180_BSI, WID-SEC-W-2023-1016_BSI, WID-SEC-W-2023-1017_BSI, WID-SEC-W-2024-1627_BSI, WID-SEC-W-2024-0123_BSI, WID-SEC-W-2024-1653_BSI, WID-SEC-W-2023-1807_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-36090_Red Hat					
	cpe:/a:apache:commons_compress [1.0, 1.21), OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35517	7.5		High		Elevated	In Review
	CERTFR-2023-AVI-0073, CERTFR-2022-AVI-239, CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-932, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-xqfj-vm6h-2x34 WID-SEC-W-2022-0607_BSI, WID-SEC-W-2023-0426_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-35517_Red Hat					
	cpe:/a:apache:commons_compress [1.1, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35516	7.5		High		Elevated	In Review
	CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-crv7-7245-f45f WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CVE-2021-35516_Red Hat					
	cpe:/a:apache:commons_compress [1.6, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2021-35515	7.5		High		Elevated	In Review
	CERTFR-2022-AVI-523, CERTFR-2024-AVI-0590, CERTFR-2021-AVI-943, CERTFR-2025-AVI-0590, CERTFR-2021-AVI-671 GHSA-7hfm-57qf-j43q WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-1627_BSI RHSA-2022:5555_Red Hat, RHSA-2022:5532_Red Hat CVE-2021-35515_Red Hat					
	cpe:/a:apache:commons_compress [1.6, 1.20], OSV org.apache.commons:commons-compress (Maven) [0, 1.21)					
CVE-2019-12402	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-0590 GHSA-53x6-4x5p-rrvv WID-SEC-W-2024-1627_BSI, WID-SEC-W-2022-0770_BSI, WID-SEC-W-2022-1375_BSI, WID-SEC-W-2024-1773_BSI RHSA-2021:3140_Red Hat CVE-2019-12402_Red Hat					
	cpe:/a:apache:commons_compress [1.15, 1.18], OSV org.apache.commons:commons-compress (Maven) [1.15, 1.19)					
CVE-2024-25710	5.5		Medium		None	In Review
	CERTFR-2024-AVI-0305, CERTFR-2024-AVI-0903, CERTFR-2024-AVI-0958, CERTFR-2024-AVI-0939, CERTFR-2024-AVI-1081, CERTFR-2024-AVI-1061, CERTFR-2024-AVI-1051, CERTFR-2025-AVI-0512, CERTFR-2025-AVI-0622, CERTFR-2024-AVI-1067, CERTFR-2024-AVI-0330, CERTFR-2024-AVI-1103, CERTFR-2025-AVI-0590 GHSA-4g9r-vxhx-9pgx OXAS-ADV-2024-0003_Open-Exchange WID-SEC-W-2025-0225_BSI, WID-SEC-W-2024-3663_BSI, WID-SEC-W-2024-3674_BSI, WID-SEC-W-2024-1642_BSI, WID-SEC-W-2025-0814_BSI, WID-SEC-W-2024-0818_BSI, WID-SEC-W-2024-1360_BSI, WID-SEC-W-2024-0414_BSI, WID-SEC-W-2024-3678_BSI, WID-SEC-W-2025-0818_BSI RHSA-2024:1797_Red Hat, RHSA-2024:1706_Red Hat, RHSA-2025:7625_Red Hat, RHSA-2024:1662_Red Hat, RHSA-2024:1924_Red Hat, RHSA-2024:1509_Red Hat, RHSA-2024:3989_Red Hat, RHSA-2024:2833_Red Hat, RHSA-2024:4057_Red Hat, RHSA-2024:3527_Red Hat CVE-2024-25710_Red Hat					
	cpe:/a:apache:commons_compress [1.3, 1.26.0), OSV org.apache.commons:commons-compress (Maven) [1.3, 1.26.0)					

Table 16: Apache Commons Compress Vulnerabilites

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Apache HTTP Components

Artifacts

Component	Artifact Id	Version
Apache HTTP Components	`httpcore-4.4.13.jar`	`4.4.13`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2020-13956	5.3		Medium		None	In Review
	CERTFR-2021-AVI-556, CERTFR-2024-AVI-0459, CERTFR-2021-AVI-559, CERTFR-2021-AVI-943, CERTFR-2022-AVI-056, CERTFR-2023-AVI-0861, CERTFR-2021-AVI-804, CERTFR-2023-AVI-0110, CERTFR-2025-AVI-0590, CERTFR-2023-AVI-0839 GHSA-7r82-7xv7-xcpj WID-SEC-W-2024-1643_BSI, WID-SEC-W-2024-1872_BSI, WID-SEC-W-2023-0132_BSI, WID-SEC-W-2024-1659_BSI, WID-SEC-W-2023-2625_BSI, WID-SEC-W-2023-2691_BSI, WID-SEC-W-2024-3197_BSI, WID-SEC-W-2022-0044_BSI, WID-SEC-W-2023-2674_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2024-0794_BSI, WID-SEC-W-2024-1637_BSI RHSA-2021:0250_Red Hat, RHSA-2021:0603_Red Hat, RHSA-2021:0246_Red Hat, RHSA-2021:0327_Red Hat, RHSA-2021:1044_Red Hat, RHSA-2021:4100_Red Hat, RHSA-2022:1860_Red Hat, RHSA-2021:0248_Red Hat, RHSA-2022:1861_Red Hat, RHSA-2021:0247_Red Hat, RHSA-2021:3140_Red Hat, RHSA-2022:0722_Red Hat, RHSA-2023:3954_Red Hat, RHSA-2021:0084_Red Hat, RHSA-2021:3700_Red Hat, RHSA-2021:0811_Red Hat CVE-2020-13956_Red Hat					
	cpe:/a:apache:http_components:5.0.3, , cpe:/a:apache:http_components:4.5.13					

Table 17: Apache HTTP Components Vulnerabilites

Apache Log4j

Artifacts

Component	Artifact Id	Version
Apache Log4j	`log4j-api-2.14.0.jar`	`2.14.0`
Apache Log4j	`log4j-core-2.14.0.jar`	`2.14.0`

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2021-44228	10.0	9.1	Critical	Critical	Escalate	Applicable
	CERT-EU-2021-074, CERT-EU-2021-073, CERT-EU-2021-076, CERT-EU-2021-075, CERT-EU-2021-067, CERT-EU-2022-005, CERT-EU-2021-070, CERT-EU-2021-072, CERT-EU-2021-071 CERTFR-2021-ALE-022 CERTFR-2021-AVI-953, CERTFR-2022-AVI-526, CERTFR-2021-AVI-951, CERTFR-2022-AVI-568, CERTFR-2022-AVI-016, CERTFR-2022-AVI-125, CERTFR-2022-AVI-124, CERTFR-2022-AVI-243, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-570, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-717, CERTFR-2024-AVI-0027 VU#930724					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	GHSA-jfh8-c2jp-5v3q WID-SEC-W-2023-0063_BSI, WID-SEC-W-2022-0351_BSI, WID-SEC-W-2024-0064_BSI ICSA-21-357-02_CISA, ICSA-22-034-01_CISA RHSA-2021:5130_Red Hat, RHSA-2021:5108_Red Hat, RHSA-2022:0296_Red Hat, RHSA-2021:5148_Red Hat, RHSA-2025:1746_Red Hat, RHSA-2021:5093_Red Hat, RHSA-2021:5126_Red Hat, RHSA-2022:0082_Red Hat, RHSA-2021:5141_Red Hat, RHSA-2021:5134_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2021:5127_Red Hat, RHSA-2021:5133_Red Hat, RHSA-2021:5094_Red Hat, RHSA-2021:5128_Red Hat, RHSA-2025:1747_Red Hat, RHSA-2021:5132_Red Hat, RHSA-2021:5106_Red Hat, RHSA-2021:5137_Red Hat, RHSA-2021:5107_Red Hat, RHSA-2021:5140_Red Hat, RHSA-2021:5138_Red Hat, RHSA-2021:5129_Red Hat CVE-2021-44228_Red Hat SCA-2021-0003_sick SSA-397453_Siemens, SSA-479842_Siemens, SSA-714170_Siemens SSA-661247_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.15.0), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.15.0), cpe:/a:apache:log4j:2.16.0,					
CVE-2021-45046	9.0		Critical		None	Not Applicable
	CERT-EU-2021-076, CERT-EU-2021-075, CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-1027, CERTFR-2021-AVI-951, CERTFR-2022-AVI-568, CERTFR-2022-AVI-125, CERTFR-2022-AVI-124, CERTFR-2022-AVI-570, CERTFR-2022-AVI-717 VU#930724 GHSA-7rjr-3q55-vv33 WID-SEC-W-2023-0063_BSI, WID-SEC-W-2022-0352_BSI RHSA-2022:0083_Red Hat, RHSA-2022:0138_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2021:5108_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2021:5148_Red Hat, RHSA-2025:1746_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2021:5141_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2021:5127_Red Hat, RHSA-2021:5094_Red Hat, RHSA-2021:5128_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2025:1747_Red Hat, RHSA-2021:5106_Red Hat, RHSA-2022:1299_Red Hat, RHSA-2021:5137_Red Hat, RHSA-2021:5107_Red Hat, RHSA-2021:5129_Red Hat CVE-2021-45046_Red Hat SSA-397453_Siemens, SSA-479842_Siemens, SSA-714170_Siemens SSA-661247_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.16.0), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.16.0), cpe:/a:apache:log4j:2.16.0,					
CVE-2021-44832	6.6		Medium		Due	In Review
	CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-933, CERTFR-2022-AVI-205, CERTFR-2022-AVI-125, CERTFR-2022-AVI-345, CERTFR-2022-AVI-960, CERTFR-2022-AVI-366, CERTFR-2022-AVI-056, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-717, CERTFR-2024-AVI-0027 GHSA-8489-44mv-ggj8 WID-SEC-W-2023-1524_BSI, WID-SEC-W-2023-0122_BSI, WID-SEC-W-2022-0197_BSI, WID-SEC-W-2023-0123_BSI, WID-SEC-W-2024-2180_BSI, WID-SEC-W-2022-0169_BSI, WID-SEC-W-2024-0064_BSI, WID-SEC-W-2023-1031_BSI					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	RHSA-2022:0083_Red Hat, RHSA-2022:0138_Red Hat, RHSA-2022:0236_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2022:0493_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2022:0467_Red Hat, RHSA-2022:0181_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0226_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2022:0485_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2022:0225_Red Hat, RHSA-2022:0230_Red Hat, RHSA-2022:1299_Red Hat, RHSA-2022:0227_Red Hat CVE-2021-44832_Red Hat SSA-784507_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.17.1), OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.17.1)					
CVE-2021-45105	5.9		Medium		Elevated	In Review
	CERT-EU-2021-067 CERTFR-2021-ALE-022 CERTFR-2022-AVI-526, CERTFR-2022-AVI-1027, CERTFR-2022-AVI-568, CERTFR-2022-AVI-125, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-570, CERTFR-2022-AVI-717 GHSA-p6xc-xr62-6r2g WID-SEC-W-2022-0811_BSI, WID-SEC-W-2023-0119_BSI RHSA-2022:0083_Red Hat, RHSA-2022:1469_Red Hat, RHSA-2022:0222_Red Hat, RHSA-2022:0047_Red Hat, RHSA-2022:0205_Red Hat, RHSA-2022:0216_Red Hat, RHSA-2022:0223_Red Hat, RHSA-2022:0026_Red Hat, RHSA-2022:0043_Red Hat, RHSA-2022:1463_Red Hat, RHSA-2022:1297_Red Hat, RHSA-2022:0042_Red Hat, RHSA-2022:0219_Red Hat, RHSA-2022:0203_Red Hat, RHSA-2022:1296_Red Hat, RHSA-2022:0044_Red Hat, RHSA-2022:1462_Red Hat, RHSA-2022:1299_Red Hat CVE-2021-45105_Red Hat SSA-479842_Siemens, SSA-501673_Siemens					
	cpe:/a:apache:log4j [2.13.0, 2.16.0], OSV org.apache.logging.log4j:log4j-core (Maven) [2.13.0, 2.17.0)					

Table 18: Apache Log4j Vulnerabilites

Spring Framework

Artifacts

Component	Artifact Id	Version
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14

Vulnerabilites

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2022-22965	9.8		Critical		Escalate	In Review
	CERT-EU-2022-023 CERTFR-2022-AVI-307, CERTFR-2022-AVI-626, CERTFR-2022-AVI-659, CERTFR-2022-AVI-326, CERTFR-2022-AVI-568, CERTFR-2022-AVI-523, CERTFR-2022-AVI-456, CERTFR-2022-AVI-345, CERTFR-2022-					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	AVI-487, CERTFR-2022-AVI-376, CERTFR-2025-AVI-0756, CERTFR-2022-AVI-297, CERTFR-2022-AVI-572, CERTFR-2022-AVI-472, CERTFR-2022-AVI-494, CERTFR-2022-AVI-360, CERTFR-2022-AVI-481, CERTFR-2022-AVI-371, CERTFR-2022-AVI-928, CERTFR-2022-AVI-716, CERTFR-2022-AVI-539 VU#970766 GHSA-36p3-wjmg-h94x WID-SEC-W-2023-0139_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2022-0033_BSI, WID-SEC-W-2023-1016_BSI, WID-SEC-W-2023-0016_BSI, WID-SEC-W-2022-0169_BSI, WID-SEC-W-2023-1012_BSI ICSA-22-286-05_CISA RHSA-2022:1306_Red Hat, RHSA-2022:1626_Red Hat, RHSA-2022:1360_Red Hat, RHSA-2022:1378_Red Hat, RHSA-2022:1333_Red Hat, RHSA-2022:1627_Red Hat, RHSA-2022:1379_Red Hat CVE-2022-22965_Red Hat SSA-254054_Siemens					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.18), OSV org.springframework:spring-beans (Maven) [5.3.0, 5.3.18), cpe:/a:vmware_tanzu:spring_framework:5.3.18,					
CVE-2016-1000027	9.8		Critical		Escalate	In Review
	CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-0113, CERTFR-2023-AVI-0908, CERTFR-2025-AVI-0590, CERTFR-2023-AVI-0839 GHSA-4wrc-f8pq-fpqp WID-SEC-W-2023-2625_BSI, WID-SEC-W-2023-1060_BSI CVE-2016-1000027_Red Hat					
	cpe:/a:vmware:spring_framework [, 6.0.0)					
CVE-2024-22262	8.1		High		Elevated	In Review
	CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0298, CERTFR-2024-AVI-0595, CERTFR-2024-AVI-0498, CERTFR-2024-AVI-0599, CERTFR-2024-AVI-0886 GHSA-2wrp-6fg6-hmc5 WID-SEC-W-2024-3195_BSI, WID-SEC-W-2024-3218_BSI, WID-SEC-W-2024-1642_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1622_BSI, WID-SEC-W-2024-1637_BSI, WID-SEC-W-2024-1643_BSI, WID-SEC-W-2024-1654_BSI, WID-SEC-W-2024-1641_BSI, WID-SEC-W-2024-3191_BSI, WID-SEC-W-2024-1656_BSI, WID-SEC-W-2024-1659_BSI, WID-SEC-W-2024-1207_BSI, WID-SEC-W-2024-3192_BSI, WID-SEC-W-2024-0854_BSI, WID-SEC-W-2024-1638_BSI ICSA-25-261-04_CISA RHSA-2024:3708_Red Hat CVE-2024-22262_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.1.6, , cpe:/a:vmware_tanzu:spring_framework:6.0.19, cpe:/a:vmware_tanzu:spring_framework:5.3.34					
CVE-2024-22259	8.1		High		Due	In Review
	CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0223 GHSA-hgjh-9rj2-g67j WID-SEC-W-2024-0869_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1637_BSI, WID-SEC-W-2024-0639_BSI RHSA-2024:2945_Red Hat					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CVE-2024-22259_Red Hat					
	cpe:/a:vmware:spring_framework [, 5.3.33), cpe:/a:vmware_tanzu:spring_framework:6.1.5, , cpe:/a:vmware_tanzu:spring_framework:5.3.33, cpe:/a:vmware_tanzu:spring_framework:6.0.18					
CVE-2024-22243	8.1		High		Due	In Review
	CERTFR-2024-AVI-0514, CERTFR-2024-AVI-0504, CERTFR-2024-AVI-0506, CERTFR-2024-AVI-0470, CERTFR-2025-AVI-0215, CERTFR-2024-AVI-0154					
	GHSA-ccgv-vj62-xf9h					
	OXAS-ADV-2024-0005_Open-Exchange					
	WID-SEC-W-2024-0457_BSI, WID-SEC-W-2024-0868_BSI, WID-SEC-W-2025-0810_BSI, WID-SEC-W-2024-1313_BSI, WID-SEC-W-2024-1637_BSI					
	RHSA-2024:3354_Red Hat					
	CVE-2024-22243_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.0.17, , cpe:/a:vmware_tanzu:spring_framework:5.3.32, cpe:/a:vmware_tanzu:spring_framework:6.1.4					
CVE-2025-41249	7.5		High		Elevated	In Review
	CERTFR-2025-AVI-0792					
	GHSA-jmp9-x22r-554x					
	WID-SEC-W-2025-2060_BSI					
	CVE-2025-41249_Red Hat					
	OSV org.springframework:spring-core (Maven) [5.3.0, 5.3.44], cpe:/a:vmware_tanzu:spring_framework:6.2.11,					
CVE-2024-38816	7.5		High		Due	In Review
	CERTFR-2025-AVI-0210, CERTFR-2025-AVI-0585, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-1015, CERTFR-2025-AVI-0481, CERTFR-2024-AVI-1006, CERTFR-2024-AVI-0776					
	GHSA-cx7f-g6mp-7hqm					
	WID-SEC-W-2024-3681_BSI, WID-SEC-W-2024-3195_BSI, WID-SEC-W-2024-3180_BSI, WID-SEC-W-2024-3508_BSI, WID-SEC-W-2024-2135_BSI					
	RHSA-2024:8064_Red Hat, RHSA-2024:11023_Red Hat					
	CVE-2024-38816_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.40, , cpe:/a:vmware_tanzu:spring_framework:6.0.24					
CVE-2023-34053	7.5		High		Elevated	In Review
	CERTFR-2024-AVI-0145, CERTFR-2023-AVI-0980					
	GHSA-v94h-hvhg-mf9h					
	WID-SEC-W-2023-3009_BSI, WID-SEC-W-2024-0870_BSI, WID-SEC-W-2024-0869_BSI, WID-SEC-W-2024-0106_BSI					
	CVE-2023-34053_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.0.14,					
CVE-2023-20860	7.5		High		Due	In Review

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CERTFR-2023-AVI-0567, CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0398, CERTFR-2023-AVI-0990, CERTFR-2023-AVI-0397 GHSA-7phw-cxx7-q9vq WID-SEC-W-2023-1755_BSI, WID-SEC-W-2023-0697_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2023-1142_BSI RHSA-2023:3185_Red Hat, RHSA-2023:4612_Red Hat, RHSA-2023:3771_Red Hat, RHSA-2023:4983_Red Hat, RHSA-2023:3610_Red Hat, RHSA-2023:2100_Red Hat, RHSA-2023:3622_Red Hat, RHSA-2023:3663_Red Hat, RHSA-2023:3954_Red Hat, RHSA-2023:3625_Red Hat CVE-2023-20860_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.26), cpe:/a:vmware_tanzu:spring_framework:5.3.26, , cpe:/a:vmware_tanzu:spring_framework:6.0.7					
CVE-2025-41234	6.5		Medium		Elevated	In Review
	CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0506 GHSA-6r3c-xf4w-jxjm WID-SEC-W-2025-1319_BSI CVE-2025-41234_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.2.8, , cpe:/a:vmware_tanzu:spring_framework:6.1.21					
CVE-2023-20863	6.5		Medium		Elevated	In Review
	CERTFR-2023-AVI-0798, CERTFR-2023-AVI-0567, CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0863, CERTFR-2023-AVI-0990, CERTFR-2024-AVI-0324 GHSA-wxqc-pxw9-g2p8 WID-SEC-W-2023-1812_BSI, WID-SEC-W-2024-0871_BSI, WID-SEC-W-2023-2675_BSI, WID-SEC-W-2023-1847_BSI, WID-SEC-W-2023-2688_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-0966_BSI, WID-SEC-W-2023-1808_BSI, WID-SEC-W-2023-2674_BSI, WID-SEC-W-2023-1804_BSI, WID-SEC-W-2023-1791_BSI, WID-SEC-W-2023-2681_BSI, WID-SEC-W-2023-1142_BSI, WID-SEC-W-2024-0888_BSI, WID-SEC-W-2023-1813_BSI, WID-SEC-W-2023-1782_BSI, WID-SEC-W-2023-2690_BSI, WID-SEC-W-2023-1811_BSI, WID-SEC-W-2023-2679_BSI, WID-SEC-W-2024-3197_BSI, WID-SEC-W-2023-1807_BSI RHSA-2023:2099_Red Hat, RHSA-2023:2100_Red Hat CVE-2023-20863_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.27), OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.27), cpe:/a:vmware_tanzu:spring_framework:6.0.8, , cpe:/a:vmware_tanzu:spring_framework:5.3.27					
CVE-2023-20861	6.5		Medium		Elevated	In Review
	CERTFR-2023-AVI-0513, CERTFR-2024-AVI-0010, CERTFR-2023-AVI-0990 GHSA-564r-hj7v-mcr5 WID-SEC-W-2023-1812_BSI, WID-SEC-W-2023-1813_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-1755_BSI, WID-SEC-W-2024-0874_BSI, WID-SEC-W-2023-1808_BSI, WID-SEC-W-2023-0697_BSI, WID-SEC-W-2023-1807_BSI, WID-SEC-W-2023-1142_BSI RHSA-2023:3185_Red Hat, RHSA-2023:4612_Red Hat, RHSA-2024:0778_Red Hat, RHSA-2023:3771_Red Hat, RHSA-2023:4983_Red Hat, RHSA-2023:3610_Red Hat, RHSA-2023:2100_Red Hat, RHSA-2023:3622_Red Hat, RHSA-2023:3954_Red Hat CVE-2023-20861_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.25], OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.26)					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
CVE-2022-22971	6.5		Medium		Elevated	In Review
	CERTFR-2022-AVI-454, CERTFR-2024-AVI-0240, CERTFR-2023-AVI-0034, CERTFR-2023-AVI-0276, CERTFR-2022-AVI-935 GHSA-rqph-vqwm-22vc WID-SEC-W-2023-0138_BSI, WID-SEC-W-2023-0809_BSI, WID-SEC-W-2023-0864_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-1017_BSI, WID-SEC-W-2023-1809_BSI, WID-SEC-W-2023-0137_BSI, WID-SEC-W-2022-0361_BSI, WID-SEC-W-2023-1031_BSI, WID-SEC-W-2023-0126_BSI RHSA-2023:3185_Red Hat, RHSA-2023:1661_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22971_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.19]					
CVE-2022-22950	6.5		Medium		Elevated	In Review
	CERTFR-2022-AVI-626, CERTFR-2022-AVI-523, CERTFR-2022-AVI-279, CERTFR-2024-AVI-0240, CERTFR-2022-AVI-539 GHSA-558x-2xjg-6232 WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2022-1035_BSI, WID-SEC-W-2023-1809_BSI ICSA-22-286-05_CISA RHSA-2022:8761_Red Hat, RHSA-2022:5555_Red Hat, RHSA-2022:5903_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22950_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.17), OSV org.springframework:spring-expression (Maven) [5.3.0, 5.3.17), cpe:/a:vmware_tanzu:spring_framework:5.3.17,					
CVE-2025-41242	5.9		Medium		None	In Review
	CERTFR-2025-AVI-0696, CERTFR-2025-AVI-0754, CERTFR-2025-AVI-0756 GHSA-r936-gwx5-v52f WID-SEC-W-2025-1832_BSI CVE-2025-41242_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:6.2.10,					
CVE-2024-38828	5.3		Medium		None	In Review
	CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0114, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2024-AVI-0991, CERTFR-2025-AVI-0481 GHSA-w3c8-7r8f-9jp8 WID-SEC-W-2025-0307_BSI, WID-SEC-W-2025-0821_BSI, WID-SEC-W-2024-3473_BSI, WID-SEC-W-2025-1572_BSI CVE-2024-38828_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.42,					
CVE-2024-38820	5.3		Medium		None	In Review

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	CERTFR-2025-AVI-0210, CERTFR-2024-AVI-1081, CERTFR-2024-AVI-0900, CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0114, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0190, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0604, CERTFR-2025-AVI-0054 GHSA-4gc7-5j7h-4qph WID-SEC-W-2025-0307_BSI, WID-SEC-W-2025-0521_BSI, WID-SEC-W-2024-3237_BSI, WID-SEC-W-2025-0819_BSI CVE-2024-38820_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.41), OSV org.springframework:spring-context (Maven) [0, 5.3.40]					
CVE-2024-38809	5.3		Medium		None	In Review
	CERTFR-2024-AVI-0689, CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0481 GHSA-2rmj-mq67-h97g WID-SEC-W-2024-1853_BSI, WID-SEC-W-2024-3180_BSI RHSA-2024:8064_Red Hat CVE-2024-38809_Red Hat					
	cpe:/a:vmware_tanzu:spring_framework:5.3.38, , cpe:/a:vmware_tanzu:spring_framework:6.1.12, cpe:/a:vmware_tanzu:spring_framework:6.0.23					
CVE-2022-22970	5.3		Medium		None	In Review
	CERTFR-2022-AVI-626, CERTFR-2023-AVI-0418, CERTFR-2023-AVI-0116, CERTFR-2022-AVI-454, CERTFR-2024-AVI-0240, CERTFR-2023-AVI-0276 GHSA-hh26-6xwr-ggv7 WID-SEC-W-2023-0809_BSI, WID-SEC-W-2023-0864_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI, WID-SEC-W-2023-0137_BSI, WID-SEC-W-2022-0361_BSI RHSA-2023:3185_Red Hat, RHSA-2023:1661_Red Hat, RHSA-2022:5532_Red Hat CVE-2022-22970_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.19], OSV org.springframework:spring-beans (Maven) [5.3.0, 5.3.20)					
CVE-2022-22968	5.3		Medium		Elevated	In Review
	CERTFR-2022-AVI-626, CERTFR-2022-AVI-952, CERTFR-2022-AVI-655, CERTFR-2022-AVI-344, CERTFR-2022-AVI-539, CERTFR-2022-AVI-935 GHSA-g5mm-vmx4-3rg7 WID-SEC-W-2022-0735_BSI, WID-SEC-W-2022-0607_BSI, WID-SEC-W-2024-0528_BSI RHSA-2022:5532_Red Hat, RHSA-2022:5101_Red Hat CVE-2022-22968_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.18], OSV org.springframework:spring-context (Maven) [5.3.0, 5.3.19)					
CVE-2024-38808	5.1		Medium		Elevated	In Review
	CERTFR-2024-AVI-0689, CERTFR-2024-AVI-0844, CERTFR-2024-AVI-0958, CERTFR-2025-AVI-0215, CERTFR-2025-AVI-0756 GHSA-9cmq-m9j5-mvww					

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Name	Score	$Score_{ctx}$	Severity	$Severity_{ctx}$	Priority	Status
	WID-SEC-W-2024-1853_BSI, WID-SEC-W-2024-3221_BSI RHSA-2024:6508_Red Hat, RHSA-2024:8887_Red Hat, RHSA-2024:8884_Red Hat, RHSA-2024:8886_Red Hat, RHSA-2024:8885_Red Hat CVE-2024-38808_Red Hat					
	cpe:/a:vmware:spring_framework [5.3.0, 5.3.39), OSV org.springframework:spring-expression (Maven) [0, 5.3.39), cpe:/a:vmware_tanzu:spring_framework:5.3.38, , cpe:/a:vmware_tanzu:spring_framework:5.3.39					
CVE-2025-22233	3.1		Low		None	In Review
	CERTFR-2025-AVI-0585, CERTFR-2025-AVI-0524, CERTFR-2025-AVI-0622, CERTFR-2025-AVI-0756, CERTFR-2025-AVI-0417, CERTFR-2025-AVI-0580 GHSA-4wp7-92pw-q264 WID-SEC-W-2025-1077_BSI CVE-2025-22233_Red Hat					
	OSV org.springframework:spring-context (Maven) [0, 5.3.39], cpe:/a:vmware_tanzu:spring_framework:5.3.43, , cpe:/a:vmware_tanzu:spring_framework:6.1.20, cpe:/a:vmware_tanzu:spring_framework:6.0.28, cpe:/a:vmware_tanzu:spring_framework:6.2.7					

Table 19: Spring Framework Vulnerabilites

3.4 Vulnerability Details

Details are provided for vulnerabilities which are either potential vulnerabilities or which have third-party advisories.

CVE-2025-48924

Description

Uncontrolled Recursion vulnerability in Apache Commons Lang. This issue affects Apache Commons Lang: Starting with commons-lang:commons-lang 2.0 to 2.6, and, from org.apache.commons:commons-lang3 3.0 before 3.18.0. The methods ClassUtils.getClass(...) can throw StackOverflowError on very long inputs. Because an Error is usually not handled by applications and libraries, a StackOverflowError could cause an application to stop. Users are recommended to upgrade to version 3.18.0, which fixes the issue.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-48924	2025-07-11	2025-07-28
MITRE	https://www.cve.org/CVERecord?id=CVE-2025-48924	2025-07-11	2025-07-28
CVE Details	https://www.cvedetails.com/cve/CVE-2025-48924	2025-07-11	2025-07-28

Affected Assets

Asset Name	Asset Type	Asset Version
C		3.0

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Apache Commons Lang	`commons-lang3-3.6.jar`	`3.6`
Apache Commons Lang	`commons-lang-2.4.jar`	`2.4`

Weakness
CWE-674

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	6.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N`	**Medium**

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-j288-q9x7-2f5v	Apache Commons Lang is vulnerable to Uncontrolled Recursion when processing long inputs	2025-07-11	2025-07-11

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2025-AVI-0754	Multiples vulnérabilités dans les produits VMware	2025-09-04	2025-09-04

Other

Id	Summary	Create Date	Update Date
RHSA-2025:16407_Red Hat	Red Hat Streams for Apache Kafka, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat Streams for Apache Kafka 3.0.1 serves as a replacement for Red Hat Streams for Apache Kafka 3.0.0, and includes security and bug fixes, and enhancements. * Cruise Control, Drain Cleaner: Netty: netty-codec-http2: Netty MadeYouReset HTTP/2 DDoS Vulnerability [amq-st-3.0] "(CVE-2025-55163)" * Kafka: org.apache.commons:commons-lang3 : Uncontrolled Recursion [amq-st-3.0] "(CVE-2025-48924)"	2025-09-22	2025-09-22
CVE-2025-48924_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2025-07-11	2025-07-11
RHSA-2025:12511_Red Hat	Red Hat Streams for Apache Kafka, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat Streams for Apache Kafka 3.0.0 serves as a replacement for Red Hat Streams for Apache Kafka 2.9.0, and includes security and bug fixes, and enhancements. Security Fix(es):	2025-08-01	2025-08-01

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* Cruise Control: json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) Security [amq-st-2] "(CVE-2023-1370)" * Cruise Control, Drain Cleaner: io.netty:netty-handler: SslHandler doesn't correctly validate packets which can lead to native crash when using native SSLEngine Security[amq-st-2] "(CVE-2025-24970)" * Cruise Control, Drain Cleaner: netty: Denial of Service attack on windows app using Netty Security [amq-st-2] "(CVE-2025-25193)" Cruise Control: kafka: Apache Kafka: SCRAM authentication vulnerable to replay attacks when used without encryption Security [amq-st-2] "(CVE-2024-56128)" * Cruise Control: kafka-clients: privilege escalation to filesystem read-access via automatic ConfigProvider Security [amq-st-2] "(CVE-2024-31141)" * Cruise Control, Operator: Jetty: Gzip Request Body Buffer Corruption Security[amq-st-2]"(CVE-2024-13009)" * Cruise Control: org.eclipse.jetty:jetty-http: jetty: Jetty URI parsing of invalid authority Security [amq-st-2] "(CVE-2024-6763)" * Cruise Control: commons-beanutils: Apache Commons BeanUtils: PropertyUtilsBean does not suppresses an enum's declaredClass property by default Security [amq-st-2] "(CVE-2025-48734)" * Cruise Control, Kafka, Drain Cleaner, Console: commons-lang-library: Uncontrolled recursion flaw in Apache Commons Lang library [amq-st-2] "(CVE-2025-48924)" * Opetator, Bridge: io.quarkus:quarkus-vertx package: data leak vulnerability has been discovered in the io.quarkus: quarkus-vertx package[amq-st-2] "(CVE-2025-49574)" * Kafka, Operator, Bridge, Cruise Control, Bridge: Connect2id Nimbus JOSE + JWT: Denial of service flaw [amq-st-2] "(CVE-2025-53864)" * Drain Cleaner: io.quarkus:quarkus-resteasy: Memory Leak in Quarkus RESTEasy Classic When Client Requests Timeout [amq-st-2] "(CVE-2025-1634)" * Drain Cleaner: netty: Denial of Service attack on windows app using Netty[amq-st-2] "(CVE-2024-47535)"		
WID-SEC-W-2025-1540_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Commons ist ein Apache-Projekt, das alle Aspekte der wiederverwendbaren Java-Komponenten behandelt. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache Commons Lang ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - UNIX	2025-07-13	2025-07-13
RHSA-2025:15697_Red Hat	Red Hat Streams for Apache Kafka, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat Streams for Apache Kafka 2.9.2 serves as a replacement for Red Hat Streams for Apache Kafka 2.9.1, and includes security and bug fixes, and enhancements. Security Fix(es): * Cruise Control, Drain Cleaner: Netty: netty-codec-http2: Netty MadeYouReset HTTP/2 DDoS Vulnerability [amq-st-2.9] "(CVE-2025-55163)" * Kafka: org.apache.commons:commons-lang3 : Uncontrolled Recursion [amq-st-2.9] "(CVE-2025-48924)"	2025-09-11	2025-09-11

Assessment Medium None In Review

Rationale
The vulnerability has automatically been marked as in review.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.07 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **78.89 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2025-41249

Description

The Spring Framework annotation detection mechanism may not correctly resolve annotations on methods within type hierarchies with a parameterized super type with unbounded generics. This can be an issue if such annotations are used for authorization decisions. Your application may be affected by this if you are using Spring Security's @EnableMethodSecurity feature. You are not affected by this if you are not using @EnableMethodSecurity or if you do not use security annotations on methods in generic superclasses or generic interfaces. This CVE is published in conjunction with CVE-2025-41248 https://spring.io/security/cve-2025-41248 .

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-41249	2025-09-16	
MITRE	https://www.cve.org/CVERecord?id=CVE-2025-41249	2025-09-16	
CVE Details	https://www.cvedetails.com/cve/CVE-2025-41249	2025-09-16	

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-285

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-jmp9-x22r-554x	Spring Framework annotation detection mechanism may result in improper authorization	2025-09-16	2025-09-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0792	Multiples vulnérabilités dans les produits Spring	2025-09-16	2025-09-16

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-2060_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Spring Security ist ein Framework, das Authentifizierung, Autorisierung und Schutz vor gängigen Angriffen bietet. Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Security und VMware Tanzu Spring Framework ausnutzen, um Sicherheitsvorkehrungen zu umgehen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-09-15	2025-09-15
CVE-2025-41249_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2025-09-16	2025-09-16

Assessment High Elevated In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.05 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **85.34 %** of all scored vulnerabilities.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Criteria	Explanation
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2025-41242

Description

Spring Framework MVC applications can be vulnerable to a “Path Traversal Vulnerability” when deployed on a non-compliant Servlet container. An application can be vulnerable when all the following are true: * the application is deployed as a WAR or with an embedded Servlet container * the Servlet container does not reject suspicious sequences https://jakarta.ee/specifications/servlet/6.1/jakarta-servlet-spec-6.1.html#uri-path-canonicalization * the application serves static resources https://docs.spring.io/spring-framework/reference/web/webmvc/mvc-config/static-resources.html#page-title with Spring resource handling We have verified that applications deployed on Apache Tomcat or Eclipse Jetty are not vulnerable, as long as default security features are not disabled in the configuration. Because we cannot check exploits against all Servlet containers and configuration variants, we strongly recommend upgrading your application.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-41242	2025-08-18	2025-08-25
MITRE	https://www.cve.org/CVERecord?id=CVE-2025-41242	2025-08-18	2025-08-25
CVE Details	https://www.cvedetails.com/cve/CVE-2025-41242	2025-08-18	2025-08-25

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-22

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	5.9	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-r936-gwx5-v52f	Spring Framework MVC Applications Path Traversal Vulnerability	2025-08-18	2025-08-18

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0696	Vulnérabilité dans Spring Framework	2025-08-14	2025-08-14
CERTFR-2025-AVI-0754	Multiples vulnérabilités dans les produits VMware	2025-09-04	2025-09-04

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-1832_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Informationen offenzulegen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-08-13	2025-08-13
CVE-2025-41242_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2025-08-18	2025-08-18

Assessment Medium None In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.09 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **73.11 %** of all scored vulnerabilities.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Criteria	Explanation
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2025-41234

Description

Description In Spring Framework, versions 6.0.x as of 6.0.5, versions 6.1.x and 6.2.x, an application is vulnerable to a reflected file download (RFD) attack when it sets a “Content-Disposition” header with a non-ASCII charset, where the filename attribute is derived from user-supplied input. Specifically, an application is vulnerable when all the following are true: * The header is prepared with org.springframework.http.ContentDisposition. * The filename is set via ContentDisposition.Builder#filename(String, Charset). * The value for the filename is derived from user-supplied input. * The application does not sanitize the user-supplied input. * The downloaded content of the response is injected with malicious commands by the attacker (see RFD paper reference for details). An application is not vulnerable if any of the following is true: * The application does not set a “Content-Disposition” response header. * The header is not prepared with org.springframework.http.ContentDisposition. * The filename is set via one of: * ContentDisposition.Builder#filename(String), or * ContentDisposition.Builder#filename(String, ASCII) * The filename is not derived from user-supplied input. * The filename is derived from user-supplied input but sanitized by the application. * The attacker cannot inject malicious content in the downloaded content of the response. Affected Spring Products and VersionsSpring Framework: * 6.2.0 - 6.2.7 * 6.1.0 - 6.1.20 * 6.0.5 - 6.0.28 * Older, unsupported versions are not affected MitigationUsers of affected versions should upgrade to the corresponding fixed version. Affected version(s)Fix versionAvailability6.2.x6.2.8OSS6.1.x6.1.21OSS6.0.x6.0.29 Commercial https://enterprise.spring.io/ No further mitigation steps are necessary. CWE-113 in `Content-Disposition` handling in VMware Spring Framework versions 6.0.5 to 6.2.7 allows remote attackers to launch Reflected File Download (RFD) attacks via unsanitized user input in `ContentDisposition.Builder#filename(String, Charset)` with non-ASCII charsets.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-41234	2025-06-12	2025-06-16
MITRE	https://www.cve.org/CVERecord?id=CVE-2025-41234	2025-06-12	2025-06-16
CVE Details	https://www.cvedetails.com/cve/CVE-2025-41234	2025-06-12	2025-06-16

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Component	Artifact Id	Version
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-113

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	6.5	`CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:L/A:N`	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-6r3c-xf4w-jxjm	Spring Framework vulnerable to a reflected file download (RFD)	2025-06-13	2025-06-13

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0506	Vulnérabilité dans Spring Framework	2025-06-13	2025-06-13
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-1319_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, authentisierter Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Dateien zu manipulieren. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-06-12	2025-06-12
CVE-2025-41234_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2025-06-12	2025-06-12

Assessment
Medium Elevated In Review

Rationale
The vulnerability has automatically been marked as in review.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:L/UI:R/S:C/C:H/I:L/A:N`
Keywords	**external attacker**
EPSS	This vulnerability has a **0.18 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **60.41 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2025-22233

Description

CVE-2024-38820 ensured Locale-independent, lowercase conversion for both the configured disallowedFields patterns and for request parameter names. However, there are still cases where it is possible to bypass the disallowedFields checks. Affected Spring Products and Versions Spring Framework: * 6.2.0 - 6.2.6 * 6.1.0 - 6.1.19 * 6.0.0 - 6.0.27 * 5.3.0 - 5.3.42 * Older, unsupported versions are also affected Mitigation Users of affected versions should upgrade to the corresponding fixed version. Affected version(s)Fix Version Availability 6.2.x 6.2.7 OSS6.1.x 6.1.20 OSS6.0.x 6.0.28 Commercial https://enterprise.spring.io/ 5.3.x 5.3.43 Commercial https://enterprise.spring.io/ No further mitigation steps are necessary. Generally, we recommend using a dedicated model object with properties only for data binding, or using constructor binding since constructor arguments explicitly declare what to bind together with turning off setter binding through the declarativeBinding flag. See the Model Design section in the reference documentation. For setting binding, prefer the use of allowedFields (an explicit list) over disallowedFields. Credit This issue was responsibly reported by the TERASOLUNA Framework Development Team from NTT DATA Group Corporation.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2025-22233	2025-05-16	2025-05-19
MITRE	https://www.cve.org/CVERecord?id=CVE-2025-22233	2025-05-16	2025-05-19
CVE Details	https://www.cvedetails.com/cve/CVE-2025-22233	2025-05-16	2025-05-19

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Component	Artifact Id	Version
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-20

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	3.1	`CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:N`	Low

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-4wp7-92pw-q264	Spring Framework DataBinder Case Sensitive Match Exception	2025-05-16	2025-05-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0417	Vulnérabilité dans Spring Framework	2025-05-16	2025-05-16
CERTFR-2025-AVI-0585	Multiples vulnérabilités dans VMware Tanzu	2025-07-11	2025-07-11
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0524	Multiples vulnérabilités dans VMware Tanzu	2025-06-19	2025-06-19
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2025-AVI-0580	Multiples vulnérabilités dans VMware Tanzu	2025-07-10	2025-07-10

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-1077_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, authentisierter Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Sicherheitsvorkehrungen zu umgehen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-05-15	2025-05-15
CVE-2025-22233_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2025-05-15	2025-05-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Assessment Low None In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.08 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **75.99 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-47554

Description

Uncontrolled Resource Consumption vulnerability in Apache Commons IO. The org.apache.commons.io.input.XmlStreamReader class may excessively consume CPU resources when processing maliciously crafted input. This issue affects Apache Commons IO: from 2.0 before 2.14.0. Users are recommended to upgrade to version 2.14.0 or later, which fixes the issue.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-47554	2024-10-03	2025-07-10
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-47554	2024-10-03	2025-07-10
CVE Details	https://www.cvedetails.com/cve/CVE-2024-47554	2024-10-03	2025-07-10

Affected Assets

Asset Name	Asset Type	Asset Version
C		`3.0`

Affected Components

Component	Artifact Id	Version
Apache Commons IO	`commons-io-2.7.jar`	`2.7`

Weakness
CWE-400

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	7.5	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	High
CVSS:4.0	OSV-GitHub, Inc.	8.7	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-78wr-2p64-hpwj	Apache Commons IO: Possible denial of service attack on untrusted input to XmlStreamReader	2024-10-03	2024-10-03

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-1081	Multiples vulnérabilités dans les produits IBM	2024-12-13	2024-12-13
CERTFR-2025-AVI-0058	Multiples vulnérabilités dans Oracle Weblogic	2025-01-22	2025-01-22
CERTFR-2025-AVI-0337	Multiples vulnérabilités dans les produits IBM	2025-04-18	2025-04-18
CERTFR-2025-AVI-0003	Multiples vulnérabilités dans les produits IBM	2025-01-03	2025-01-03
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0170	Multiples vulnérabilités dans les produits IBM	2025-02-28	2025-02-28
CERTFR-2025-AVI-0671	Multiples vulnérabilités dans les produits IBM	2025-08-08	2025-08-08
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-1563_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Oracle Supply Chain ist eine Sammlung von Applikationen für verschiedene Zwecke. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Supply Chain ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
WID-SEC-W-2025-0810_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-04-15	2025-04-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
STACKSA_2024_0113_0001_Stackable GmbH	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Stackable GmbH and provide a link to the original.	2024-12-10	2024-12-10
WID-SEC-W-2024-3082_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Commons ist ein Apache-Projekt, das alle Aspekte der wiederverwendbaren Java-Komponenten behandelt. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache Commons IO ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - UNIX	2024-10-03	2024-10-03
WID-SEC-W-2025-0001_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM DB2 ist ein relationales Datenbanksystem (RDBS) von IBM. # Angriff Ein entfernter oder lokaler Angreifer kann mehrere Schwachstellen in IBM DB2 on Cloud Pak for Data ausnutzen, um seine Privilegien zu erhöhen, beliebigen Code auszuführen, vertrauliche Informationen offenzulegen, Sicherheitsmaßnahmen zu umgehen oder einen Denial-of-Service-Zustand zu erzeugen. # Betroffene Betriebssysteme - Sonstiges	2025-01-01	2025-01-01
WID-SEC-W-2025-1570_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Insurance Applications ist eine Produktfamilie mit Lösungen für die Versicherungsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Insurance Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
WID-SEC-W-2025-0826_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Oracle Datenbank ist ein weit verbreitetes relationales Datenbanksystem. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle TimesTen In-Memory Database ausnutzen, um die Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0135_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit,	2025-01-21	2025-01-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows		
WID-SEC-W-2025-0819_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0805_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Utilities Applications ist eine Produktfamilie mit branchenspezifischen Lösungen für Ver- und Entsorger. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Utilities Applications ausnutzen, um die Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0814_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Komponenten der Oracle JDEdwards sind vollständig integrierte und komplette Lösungen geschäftlicher Anwendungen (ERP) für Unternehmen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle JD Edwards ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0817_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Hyperion bietet Lösungen für Business Intelligence, Planung und Konsolidierung. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Hyperion ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
RHSA-2024:9571_Red Hat	Red Hat Streams for Apache Kafka, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 2.8.0 serves as a replacement for Red Hat AMQ Streams 2.7.0, and includes security and bug fixes, and enhancements. Security Fix(es): * Zookeeper, Kafka, Cruise Control: org.eclipse.jetty/jetty-server: Jetty ThreadLimitHandler.getRemote() vulnerable to remote DoS attacks [amq-st-2] "(CVE-2024-8184)" * Zookeeper, Kafka : org.eclipse.jetty/jetty-servlets: Jetty DOS vulnerability on DosFilter [amq-st-2] "(CVE-2024-9823)" * Zookeeper, Kafka, Drain Cleaner, Cruise Control: Apache Commons IO: Possible denial of service attack on	2024-11-13	2024-11-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	untrusted input to XmlStreamReader "(CVE-2024-47554)" * Kafka: (com.google.protobuf:protobuf-java@3.23.4). Denial of Service (DoS) describes a family of attacks, all aimed at making a system inaccessible to its intended and legitimate users "(CVE-2024-7254)" "Drain Cleaner: Awaiting Analysis(CVE-2024-29025)" * Kroxylicoius: When establishing the connection with the upstream Kafka server using a TLS secured connection, Kroxylicious fails to properly verify the server's hostname, resulting in an insecure connection. For a successful attack to be performed, the attacker needs to perform a Man-in-the-Middle attack or compromise any external systems, such as DNS or network routing configuration. "(CVE-2024-8285)"		
WID-SEC-W-2025-0824_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-1565_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-07-15	2025-07-15
RHSA-2025:2416_Red Hat	Red Hat Streams for Apache Kafka, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat Streams for Apache Kafka 2.9.0 serves as a replacement for Red Hat Streams for Apache Kafka 2.8.0, and includes security and bug fixes, and enhancements. Security Fix(es): * Cruise Control:cio.netty:netty-common:4.1.115.Final-redhat [amq-st-2] "(CVE-2023-52428)" * Cruise Control:com.nimbusds:nimbus-jose-jwt:9.37.2.redhat [amq-st-2] "(CVE-2024-47535)" * Cruise Control:org.apache.kafka:kafka-clients:3.5.2.redhat+ [amq-st-2] "(CVE-2024-31141)" * Cruise Control:io:commons-io:2.15.1.redhat+ [amq-st-2] "(CVE-2024-47554)" * Cruise Control:org.eclipse.jetty:jetty-server:9.4.56.v20240826-redhat + [amq-st-2] "(CVE-2024-8184)" * Cruise Control:org.eclipse.jetty/jetty-server: Jetty ThreadLimitHandler.getRemote() vulnerable to remote DoS attacks [amq-st-2] "(CVE-2024-8184)" * Kafka Exporter:golang-github-danielqsj-kafka_exporter: Golang FIPS zeroed buffer [amq-st-2] "(CVE-2024-9355)" * Kafka Exporter:golang-github-danielqsj-kafka_exporter: net/http: Denial of service due to improper 100-continue handling in net/http [amq-st-2] "(CVE-2024-24791)"	2025-03-05	2025-03-05
WID-SEC-W-2025-0808_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten	2025-04-15	2025-04-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Oracle Supply Chain ist eine Sammlung von Applikationen für verschiedene Zwecke. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Supply Chain ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows		
WID-SEC-W-2025-0818_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0811_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Policy Automation dient der automatisierten Verwaltung und Durchsetzung von Richtlinien. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Policy Automation ausnutzen, um die Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-1572_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
WID-SEC-W-2025-1562_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Utilities Applications ist eine Produktfamilie mit branchenspezifischen Lösungen für Ver- und Entsorger. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Utilities Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
WID-SEC-W-2025-0822_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Construction and Engineering ist eine Sammlung	2025-04-15	2025-04-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	von Werkzeugen zur Unterstützung von Bau- und Ingenieurbüros. Sie umfasst u. a. Projektmanagement-Lösungen zur Verwaltung von Projekte, zur Schaffung von Transparenz, zur Zusammenarbeit und zur Verwaltung von Änderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Construction and Engineering ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows		
WID-SEC-W-2025-0823_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0143_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-01-21	2025-01-21
WID-SEC-W-2025-1560_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
CVE-2024-47554_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-10-03	2024-10-03
WID-SEC-W-2025-0807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Oracle Support Tools sind eine Sammlung von Werkzeugen zur Wartung und zum Support von Oracle Produkten. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Support Tools ausnutzen, um die Vertraulichkeit, Integrität	2025-04-15	2025-04-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows		
WID-SEC-W-2025-0147_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Construction and Engineering ist eine Sammlung von Werkzeugen zur Unterstützung von Bau- und Ingenieurbüros. Sie umfasst u. a. Projektmanagement-Lösungen zur Verwaltung von Projekte, zur Schaffung von Transparenz, zur Zusammenarbeit und zur Verwaltung von Änderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Construction and Engineering ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-01-21	2025-01-21

Assessment

High | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:4.0 OSV-GitHub, Inc.* provides the vector: `CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:N/VI:N/VA:H/SC:N/SI:N/SA:N`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.27 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **49.84 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2024-38828

Description

Spring MVC controller methods with an @RequestBody byte[] method parameter are vulnerable to a DoS attack.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-38828	2024-11-18	2025-05-09
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-38828	2024-11-18	2025-05-09
CVE Details	https://www.cvedetails.com/cve/CVE-2024-38828	2024-11-18	2025-05-09

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-400

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	5.3	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-w3c8-7r8f-9jp8	Spring MVC controller vulnerable to a DoS attack	2024-11-18	2024-11-18

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2025-AVI-0585	Multiples vulnérabilités dans VMware Tanzu	2025-07-11	2025-07-11
CERTFR-2025-AVI-0114	Multiples vulnérabilités dans les produits SAP	2025-02-11	2025-02-11
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2024-AVI-0991	Vulnérabilité dans Spring	2024-11-15	2024-11-15
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2025-AVI-0481	Multiples vulnérabilités dans les produits IBM	2025-06-06	2025-06-06

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-0821_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten	2025-04-15	2025-04-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle E-Business Suite ist eine Sammlung geschäftlicher Anwendungen für Unternehmen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle E-Business Suite ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows		
WID-SEC-W-2025-1572_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-07-15	2025-07-15
WID-SEC-W-2024-3473_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Windows	2024-11-14	2024-11-14
CVE-2024-38828_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-11-18	2024-11-18
WID-SEC-W-2025-0307_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung SAP stellt unternehmensweite Lösungen für Geschäftsprozesse wie Buchführung, Vertrieb, Einkauf und Lagerhaltung zur Verfügung. # Angriff Ein Angreifer kann mehrere Schwachstellen in der SAP-Software ausnutzen, um erhöhte Berechtigungen zu erlangen, Sicherheitsmaßnahmen zu umgehen, Cross-Site-Scripting- und Spoofing-Angriffe durchzuführen, Daten zu manipulieren, vertrauliche Informationen preiszugeben und einen Denial-of-Service-Zustand zu verursachen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2025-02-10	2025-02-10

Assessment Medium None In Review

Rationale
The vulnerability has automatically been marked as in review.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.24 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **52.18 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-38820

Description

The fix for CVE-2022-22968 made disallowedFields patterns in DataBinder case insensitive. However, String.toLowerCase() has some Locale dependent exceptions that could potentially result in fields not protected as expected.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-38820	2024-10-18	2024-11-29
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-38820	2024-10-18	2024-11-29
CVE Details	https://www.cvedetails.com/cve/CVE-2024-38820	2024-10-18	2024-11-29

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-178

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	5.3	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-4gc7-5j7h-4qph	Spring Framework DataBinder Case Sensitive Match Exception	2024-10-18	2024-10-18

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-1081	Multiples vulnérabilités dans les produits IBM	2024-12-13	2024-12-13
CERTFR-2024-AVI-0900	Multiples vulnérabilités dans Spring Framework	2024-10-18	2024-10-18
CERTFR-2025-AVI-0054	Multiples vulnérabilités dans Oracle MySQL	2025-01-22	2025-01-22
CERTFR-2025-AVI-0585	Multiples vulnérabilités dans VMware Tanzu	2025-07-11	2025-07-11
CERTFR-2025-AVI-0114	Multiples vulnérabilités dans les produits SAP	2025-02-11	2025-02-11
CERTFR-2025-AVI-0210	Multiples vulnérabilités dans VMware Tanzu	2025-03-14	2025-03-14
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0604	Multiples vulnérabilités dans Oracle Weblogic	2025-07-18	2025-07-18
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2025-AVI-0190	Multiples vulnérabilités dans les produits SAP	2025-03-11	2025-03-11

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-3237_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um Informationen offenzulegen oder Sicherheitsmaßnahmen zu umgehen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2024-10-17	2024-10-17
CVE-2024-38820_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-10-17	2024-10-17
WID-SEC-W-2025-0521_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. #	2025-03-10	2025-03-10

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Produktbeschreibung SAP stellt unternehmensweite Lösungen für Geschäftsprozesse wie Buchführung, Vertrieb, Einkauf und Lagerhaltung zur Verfügung. # Angriff Ein Angreifer kann diese Schwachstellen ausnutzen, um erhöhte Privilegien zu erlangen, beliebigen Code auszuführen, Cross-Site-Scripting-Angriffe durchzuführen, Sicherheitsmaßnahmen zu umgehen, einen Denial-of-Service-Zustand zu verursachen, vertrauliche Informationen offenzulegen und Daten zu manipulieren. # Betroffene Betriebssysteme - Linux - Sonstiges - Windows		
WID-SEC-W-2025-0819_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2025-0307_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung SAP stellt unternehmensweite Lösungen für Geschäftsprozesse wie Buchführung, Vertrieb, Einkauf und Lagerhaltung zur Verfügung. # Angriff Ein Angreifer kann mehrere Schwachstellen in der SAP-Software ausnutzen, um erhöhte Berechtigungen zu erlangen, Sicherheitsmaßnahmen zu umgehen, Cross-Site-Scripting- und Spoofing-Angriffe durchzuführen, Daten zu manipulieren, vertrauliche Informationen preiszugeben und einen Denial-of-Service-Zustand zu verursachen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2025-02-10	2025-02-10

Assessment

Medium **None** **In Review**

Rationale

The vulnerability has automatically been marked as in review.

Priority

None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.07 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **77.90 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

CVE-2024-38816

Description

Applications serving static resources through the functional web frameworks WebMvc.fn or WebFlux.fn are vulnerable to path traversal attacks. An attacker can craft malicious HTTP requests and obtain any file on the file system that is also accessible to the process in which the Spring application is running. Specifically, an application is vulnerable when both of the following are true: * the web application uses RouterFunctions to serve static resources * resource handling is explicitly configured with a FileSystemResource location However, malicious requests are blocked and rejected when any of the following is true: * the Spring Security HTTP Firewall https://docs.spring.io/spring-security/reference/servlet/exploits/firewall.html is in use * the application runs on Tomcat or Jetty

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-38816	2024-09-13	2025-03-18
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-38816	2024-09-13	2025-03-18
CVE Details	https://www.cvedetails.com/cve/CVE-2024-38816	2024-09-13	2025-03-18

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-22

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-cx7f-g6mp-7hqm	Path traversal vulnerability in functional web frameworks	2024-09-13	2024-09-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0776	Vulnérabilité dans Spring Framework	2024-09-13	2024-09-13
CERTFR-2024-AVI-0958	Multiples vulnérabilités dans les produits IBM	2024-11-08	2024-11-08
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2025-AVI-0585	Multiples vulnérabilités dans VMware Tanzu	2025-07-11	2025-07-11
CERTFR-2024-AVI-1006	Multiples vulnérabilités dans les produits Atlassian	2024-11-20	2024-11-20
CERTFR-2025-AVI-0210	Multiples vulnérabilités dans VMware Tanzu	2025-03-14	2025-03-14
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2024-AVI-1015	Multiples vulnérabilités dans les produits IBM	2024-11-22	2024-11-22
CERTFR-2025-AVI-0481	Multiples vulnérabilités dans les produits IBM	2025-06-06	2025-06-06

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-3508_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial of Service Angriff durchzuführen, vertrauliche Informationen preiszugeben und Sicherheitsmaßnahmen zu umgehen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-11-19	2024-11-19
RHSA-2024:11023_Red Hat	HawtIO 4.1.0 for Red Hat build of Apache Camel 4 GA Release is now available. The purpose of this text-only errata is to inform you about the enhancements that improve your developer experience and ensure the security and stability of your products. * serve-static: Improper Sanitization in serve-static (CVE-2024-43800) * send: Code Execution Vulnerability in Send Library (CVE-2024-43799) * org.springframework/spring-webmvc: Path Traversal Vulnerability in Spring Applications Using RouterFunctions and FileSystemResource (CVE-2024-38816) * org.eclipse.jetty/jetty-server: Jetty ThreadLimitHandler.getRemote() vulnerable to remote DoS attacks (CVE-2024-8184) * quarkus-core: Leak of local configuration properties into Quarkus applications (CVE-2024-2700) * braces: fails to limit the number of characters it can handle (CVE-2024-4068) * undertow: Improper State Management in Proxy Protocol parsing causes information leakage (CVE-2024-7885) * path-to-regexp: Backtracking regular expressions cause ReDoS (CVE-2024-45296) * express: Improper Input Handling in Express Redirects (CVE-2024-43796)	2024-12-12	2024-12-12
CVE-2024-38816_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-09-13	2024-09-13
WID-SEC-W-2024-3681_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit	2024-12-10	2024-12-10

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Bitbucket ist ein Git-Server zur Sourcecode-Versionskontrolle. # Angriff Ein entfernter Angreifer kann mehrere Schwachstellen in Atlassian Bitbucket ausnutzen, um Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen oder einen Denial-of-Service-Zustand zu erzeugen. # Betroffene Betriebssysteme - UNIX		
WID-SEC-W-2024-3180_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Camel ist ein Integrations-Framework, das Enterprise Integration Patterns implementiert. JBoss A-MQ ist eine Messaging-Plattform. JBoss Enterprise Application Platform ist eine skalierbare Plattform für Java-Anwendungen, inklusive JBoss Application Server, JBoss Hibernate und Boss Seam. Red Hat JBoss Data Grid ist eine verteilte In-Memory-Datenbank für den schnellen Zugriff auf große Datenvolumen und Skalierbarkeit. # Angriff Ein entfernter anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Apache Camel und in mehreren Red Hat-Produkten ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, vertrauliche Informationen preiszugeben und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-10-14	2024-10-14
WID-SEC-W-2024-3195_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges	2024-10-15	2024-10-15
WID-SEC-W-2024-2135_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Informationen offenzulegen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-09-12	2024-09-12
RHSA-2024:8064_Red Hat	Red Hat build of Apache Camel 4.4.3 for Spring Boot release and security update is now available. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * org.apache.avro/avro: Schema parsing may trigger Remote Code Execution (RCE) (CVE-2024-47561) * com.nimbusds/nimbus-jose-jwt: large JWE p2c header value causes Denial of Service (CVE-2023-52428) * org.springframework/spring-webmvc: Path Traversal Vulnerability in Spring Applications Using RouterFunctions and FileSystemResource (CVE-2024-38816) * ca.uhn.hapi.fhir/org.hl7.fhir.dstu2016may: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.dstu3: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.r4: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core`	2024-10-14	2024-10-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	(CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.r5: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.utilities: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * org.springframework/spring-web: Spring Framework DoS via conditional HTTP request (CVE-2024-38809) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		

Assessment High Due In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority Due

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **93.37 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **0.19 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-38809

Description

Applications that parse ETags from "If-Match" or "If-None-Match" request headers are vulnerable to DoS attack. Users of affected versions should upgrade to the corresponding fixed version. Users of older, unsupported versions could enforce a size limit on "If-Match" and "If-None-Match" headers, e.g. through a Filter.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-38809	2024-09-27	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-38809	2024-09-27	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2024-38809	2024-09-27	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-400

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	5.3	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`	**Medium**

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-2rmj-mq67-h97g	Spring Framework DoS via conditional HTTP request	2024-09-24	2024-09-24

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0844	Multiples vulnérabilités dans les produits SAP	2024-10-08	2024-10-08
CERTFR-2024-AVI-0958	Multiples vulnérabilités dans les produits IBM	2024-11-08	2024-11-08
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2024-AVI-0689	Multiples vulnérabilités dans Spring Framework	2024-08-16	2024-08-16
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0481	Multiples vulnérabilités dans les produits IBM	2025-06-06	2025-06-06

Other

Id	Summary	Create Date	Update Date
CVE-2024-38809_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-09-24	2024-09-24
RHSA-2024:8064_Red Hat	Red Hat build of Apache Camel 4.4.3 for Spring Boot release and security update is now available. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * org.apache.avro/avro: Schema parsing may trigger Remote Code Execution (RCE) (CVE-2024-47561) * com.nimbusds/nimbus-jose-jwt: large JWE p2c header value causes Denial of Service (CVE-2023-52428)	2024-10-14	2024-10-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* org.springframework/spring-webmvc: Path Traversal Vulnerability in Spring Applications Using RouterFunctions and FileSystemResource (CVE-2024-38816) * ca.uhn.hapi.fhir/org.hl7.fhir.dstu2016may: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.dstu3: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.r4: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.r5: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * ca.uhn.hapi.fhir/org.hl7.fhir.utilities: XXE vulnerability in XSLT transforms in `org.hl7.fhir.core` (CVE-2024-45294) * org.springframework/spring-web: Spring Framework DoS via conditional HTTP request (CVE-2024-38809) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2024-3180_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Camel ist ein Integrations-Framework, das Enterprise Integration Patterns implementiert. JBoss A-MQ ist eine Messaging-Plattform. JBoss Enterprise Application Platform ist eine skalierbare Plattform für Java-Anwendungen, inklusive JBoss Application Server, JBoss Hibernate und Boss Seam. Red Hat JBoss Data Grid ist eine verteilte In-Memory-Datenbank für den schnellen Zugriff auf große Datenvolumen und Skalierbarkeit. # Angriff Ein entfernter anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Apache Camel und in mehreren Red Hat-Produkten ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, vertrauliche Informationen preiszugeben und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-10-14	2024-10-14
WID-SEC-W-2024-1853_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-08-14	2024-08-14

Assessment

Medium **None** **In Review**

Rationale

The vulnerability has automatically been marked as in review.

Priority

None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`
Keywords	No keyword sets matched.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Criteria	Explanation
EPSS	This vulnerability has a **0.06 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **81.54 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-38808

Description

In Spring Framework versions 5.3.0 - 5.3.38 and older unsupported versions, it is possible for a user to provide a specially crafted Spring Expression Language (SpEL) expression that may cause a denial of service (DoS) condition. Specifically, an application is vulnerable when the following is true: * The application evaluates user-supplied SpEL expressions.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-38808	2024-08-20	2025-06-18
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-38808	2024-08-20	2025-06-18
CVE Details	https://www.cvedetails.com/cve/CVE-2024-38808	2024-08-20	2025-06-18

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	4.3	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:L`	**Medium**
CVSS:4.0	OSV-GitHub, Inc.	5.1	`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N`	**Medium**

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-9cmq-m9j5-mvww	Spring Framework vulnerable to Denial of Service	2024-08-20	2024-08-20

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0844	Multiples vulnérabilités dans les produits SAP	2024-10-08	2024-10-08
CERTFR-2024-AVI-0958	Multiples vulnérabilités dans les produits IBM	2024-11-08	2024-11-08
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2024-AVI-0689	Multiples vulnérabilités dans Spring Framework	2024-08-16	2024-08-16
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05

Other

Id	Summary	Create Date	Update Date
CVE-2024-38808_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-08-20	2024-08-20
WID-SEC-W-2024-1853_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-08-14	2024-08-14
RHSA-2024:6508_Red Hat	Red Hat build of Apache Camel 4.4.2 for Spring Boot release and security update is now available. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * undertow: Improper State Management in Proxy Protocol parsing causes information leakage (CVE-2024-7885) * org.springframework/spring-expression: From NVD collector (CVE-2024-38808) * org.apache.cxf/cxf-rt-transports-http: unrestricted memory consumption in CXF HTTP clients (CVE-2024-5971) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-09-09	2024-09-09
RHSA-2024:8884_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fixes: * jenkins: Item creation restriction bypass vulnerability (CVE-2024-47804) * jenkins: Exposure of multi-line secrets through error messages (CVE-2024-47803) * jenkins: Enabling Secure Server Identity Checks for Safer SMTPS Communication (CVE-2021-44549) * jenkins: Denial of service when processing a specially crafted Spring Expression Language expression (CVE-2024-38808) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments,	2024-11-05	2024-11-05

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	and other related information, refer to the CVE page listed in the References section.		
RHSA-2024:8885_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fixes: * jenkins: Item creation restriction bypass vulnerability (CVE-2024-47804) * jenkins: Exposure of multi-line secrets through error messages (CVE-2024-47803) * jenkins: Enabling Secure Server Identity Checks for Safer SMTPS Communication (CVE-2021-44549) * jenkins: Denial of service when processing a specially crafted Spring Expression Language expression (CVE-2024-38808) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page listed in the References section.	2024-11-05	2024-11-05
WID-SEC-W-2024-3221_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-10-15	2024-10-15
RHSA-2024:8887_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * jenkins: Item creation restriction bypass vulnerability (CVE-2024-47804) * jenkins: Exposure of multi-line secrets through error messages (CVE-2024-47803) * jenkins: Enabling Secure Server Identity Checks for Safer SMTPS Communication (CVE-2021-44549) * jenkins: Denial of service when processing a specially crafted Spring Expression Language expression (CVE-2024-38808) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page listed in the References section.	2024-11-05	2024-11-05
RHSA-2024:8886_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * jenkins: Exposure of multi-line secrets through error messages (CVE-2024-47803) * jenkins: Item creation restriction bypass vulnerability (CVE-2024-47804) * jenkins: Enabling Secure Server Identity Checks for Safer SMTPS Communication (CVE-2021-44549) * jenkins: Denial of service when processing a specially crafted Spring Expression Language expression (CVE-2024-38808) * jenkins-2-plugins: jenkins-plugin/script-security: sandbox bypass via crafted constructor bodies (CVE-2024-34144) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page listed in the References section.	2024-11-05	2024-11-05

Assessment

Medium **Elevated** **In Review**

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:4.0 OSV-GitHub, Inc.* provides the vector:

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Criteria	Explanation
	CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:A/VC:N/VI:N/VA:L/SC:N/SI:N/SA:N
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.27 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **49.38 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-25710

Description

Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in Apache Commons Compress.This issue affects Apache Commons Compress: from 1.3 through 1.25.0. Users are recommended to upgrade to version 1.26.0 which fixes the issue.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-25710	2024-02-19	2025-02-13
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-25710	2024-02-19	2025-02-13
CVE Details	https://www.cvedetails.com/cve/CVE-2024-25710	2024-02-19	2025-02-13

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	commons-compress-1.18.jar	1.18

Weakness

CWE-835

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	5.5	CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H	Medium

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-4g9r-vxhx-9pgx	Apache Commons Compress: Denial of service caused by an infinite loop for a corrupted DUMP file	2024-02-19	2024-02-19

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0512	Multiples vulnérabilités dans les produits IBM	2025-06-13	2025-06-13
CERTFR-2024-AVI-1081	Multiples vulnérabilités dans les produits IBM	2024-12-13	2024-12-13
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2024-AVI-0903	Multiples vulnérabilités dans les produits IBM	2024-10-18	2024-10-18
CERTFR-2024-AVI-0305	Multiples vulnérabilités dans les produits IBM	2024-04-12	2024-04-12
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25
CERTFR-2024-AVI-1103	Multiples vulnérabilités dans les produits IBM	2024-12-20	2024-12-20
CERTFR-2024-AVI-0939	Multiples vulnérabilités dans les produits IBM	2024-10-31	2024-10-31
CERTFR-2024-AVI-0330	Multiples vulnérabilités dans les produits IBM	2024-04-19	2024-04-19
CERTFR-2024-AVI-0958	Multiples vulnérabilités dans les produits IBM	2024-11-08	2024-11-08
CERTFR-2024-AVI-1061	Multiples vulnérabilités dans les produits Splunk	2024-12-11	2024-12-11
CERTFR-2024-AVI-1051	Multiples vulnérabilités dans les produits IBM	2024-12-06	2024-12-06
CERTFR-2024-AVI-1067	Multiples vulnérabilités dans les produits Atlassian	2024-12-11	2024-12-11

Other

Id	Summary	Create Date	Update Date
RHSA-2024:1797_Red Hat	This release of Red Hat build of Quarkus 2.13.9.SP2 includes security updates, bug fixes, and enhancements. For more information, see the release notes page listed in the References section. Security Fix(es): * CVE-2024-1597 org.postgresql/postgresql: pgjdbc: PostgreSQL JDBC Driver allows attacker to inject SQL if using PreferQueryMode=SIMPLE [quarkus-2] * CVE-2024-25710 org.apache.commons/commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file [quarkus-2] * CVE-2024-26308 org.apache.commons/commons-compress: OutOfMemoryError unpacking broken Pack200 file [quarkus-2]	2024-04-22	2024-04-22
RHSA-2025:7625_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.13.0 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * (CVE-2020-23064) jquery: Cross-site scripting * (CVE-2024-25710) commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file * (CVE-2024-26308) commons-compress: OutOfMemoryError unpacking broken Pack200 file For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2025-05-14	2025-05-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
OXAS-ADV-2024-0003_Open-Exchange		2024-04-24	2024-04-24
WID-SEC-W-2024-3678_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial of Service Angriff durchzuführen, Daten zu manipulieren oder Sicherheitsvorkehrungen zu umgehen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2024-12-10	2024-12-10
WID-SEC-W-2024-1360_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM DB2 ist ein relationales Datenbanksystem (RDBS) von IBM. # Angriff Ein entfernter, authentisierter Angreifer kann mehrere Schwachstellen in IBM DB2 ausnutzen, um einen Denial of Service Angriff durchzuführen, beliebigen Code auszuführen und vertrauliche Informationen offenzulegen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-06-11	2024-06-11
RHSA-2024:4057_Red Hat	This release includes security, bug fixes, and enhancements. Security Fix(es): * keycloak: org.keycloak.protocol.oidc: unvalidated cross-origin messages in checkLoginIframe leads to DDoS (CVE-2024-1249) * keycloak: XSS via assertion consumer service URL in SAML POST-binding flow (CVE-2023-6717) * pgjdbc: PostgreSQL JDBC Driver allows attacker to inject SQL if using PreferQueryMode=SIMPLE (CVE-2024-1597) * camel-core: Exposure of sensitive data by crafting a malicious EventFactory (CVE-2024-22371) * commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file (CVE-2024-25710) * commons-compress: OutOfMemoryError unpacking broken Pack200 file (CVE-2024-26308) * jose4j: denial of service via specially crafted JWE (CVE-2023-51775) For more details about the security issues, including the impact, a CVSS score, acknowledgements, and other related information, refer to the CVE pages listed in the References section.	2024-06-24	2024-06-24
WID-SEC-W-2025-0225_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Dell PowerProtect Data Domain Appliances sind speziell für Backup und Daten-Deduplizierung ausgelegte Systeme. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell PowerProtect Data Domain ausnutzen, um erhöhte Rechte zu erlangen, einen Denial-of-Service-Zustand herbeizuführen und einen nicht näher spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Sonstiges	2025-01-30	2025-01-30
WID-SEC-W-2024-0414_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Commons ist ein Apache-Projekt, das alle Aspekte der wiederverwendbaren Java-Komponenten behandelt. # Angriff Ein lokaler Angreifer kann mehrere Schwachstellen in Apache	2024-02-18	2024-02-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Commons ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - MacOS X - UNIX - Windows		
WID-SEC-W-2024-3674_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Splunk Enterprise ermöglicht Monitoring und Analyse von Clickstream-Daten und Kundentransaktionen. # Angriff Ein Angreifer kann mehrere Schwachstellen in Splunk Splunk Enterprise ausnutzen, um vertrauliche Informationen offenzulegen, Sicherheitsmaßnahmen zu umgehen, beliebigen Code auszuführen oder unspezifische Angriffe durchzuführen. # Betroffene Betriebssysteme - Linux - Windows	2024-12-10	2024-12-10
RHSA-2024:1924_Red Hat	Migration Toolkit for Runtimes 1.2.5 ZIP artifacts Security Fix(es): * commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file (CVE-2024-25710) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-04-18	2024-04-18
WID-SEC-W-2025-0814_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Komponenten der Oracle JDEdwards sind vollständig integrierte und komplette Lösungen geschäftlicher Anwendungen (ERP) für Unternehmen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle JD Edwards ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
RHSA-2024:2833_Red Hat	This release of Red Hat Integration - Service Registry 2.5.11 GA includes the following security fixes. Security Fix(es): * commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file [rhint-serv-2] (CVE-2024-25710) * vert.x: io.vertx/vertx-core: memory leak due to the use of Netty FastThreadLocal data structures in Vertx [rhint-serv-2] (CVE-2024-1023) * vertx-core: io.vertx:vertx-core: memory leak when a TCP server is configured with TLS and SNI support [rhint-serv-2] (CVE-2024-1300) * commons-compress: OutOfMemoryError unpacking broken Pack200 file [rhint-serv-2] (CVE-2024-26308) * netty-codec-http: Allocation of Resources Without Limits or Throttling [rhint-serv-2] (CVE-2024-29025) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-05-14	2024-05-14
CVE-2024-25710_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-02-19	2024-02-19
WID-SEC-W-2024-1642_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		
RHSA-2024:1662_Red Hat	This release of Red Hat build of Quarkus 3.2.11 includes security updates, bug fixes, and enhancements. For more information, see the release notes page listed in the References section. Security Fix(es): * CVE-2024-1597 org.postgresql/postgresql: pgjdbc: PostgreSQL JDBC Driver allows attacker to inject SQL if using PreferQueryMode=SIMPLE [quarkus-3.2] * CVE-2024-1979 io.quarkus/quarkus-kubernetes-deployment: quarkus: information leak in annotation [quarkus-3.2] * CVE-2024-1726 io.quarkus.resteasy.reactive/resteasy-reactive: quarkus: security checks for some inherited endpoints performed after serialization in RESTEasy Reactive may trigger a denial of service [quarkus-3.2] * CVE-2024-25710 org.apache.commons/commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file [quarkus-3.2] * CVE-2024-26308 org.apache.commons/commons-compress: OutOfMemoryError unpacking broken Pack200 file [quarkus-3.2] * CVE-2024-1300 io.vertx/vertx-core: io.vertx:vertx-core: memory leak when a TCP server is configured with TLS and SNI support [quarkus-3.2] * CVE-2024-1023 io.vertx/vertx-core: memory leak due to the use of Netty FastThreadLocal data structures in Vertx [quarkus-3.2]	2024-04-03	2024-04-03
WID-SEC-W-2025-0818_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2025-04-15	2025-04-15
RHSA-2024:3527_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 2.7.0 serves as a replacement for Red Hat AMQ Streams 2.6.0, and includes security and bug fixes, and enhancements. Security Fix(es): * lz4: memory corruption due to an integer overflow bug caused by memmove argument (CVE-2021-3520) * zstd: Race condition allows attacker to access world-readable destination file (CVE-2021-24032) * RocksDB: zstd: mysql: buffer overrun in util.c (CVE-2022-4899) * netty-codec-http: Allocation of Resources Without Limits or Throttling (CVE-2024-29025) * commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file (CVE-2024-25710) * apache-commons-text: variable interpolation RCE (CVE-2022-42889) * snappy-java: Missing upper bound check on chunk length in snappy-java can lead to Denial of Service (DoS) impact (CVE-2023-43642) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * protobuf-java: timeout in parser leads to DoS (CVE-2022-3171) * Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * bc-java: Out of memory while parsing ASN.1 crafted data in org.bouncycastle.openssl.PEMParser class (CVE-2023-33202) * bouncycastle: potential blind LDAP injection attack using a self-signed certificate (CVE-2023-33201) * json-path: stack-based buffer overflow in Criteria.parse method (CVE-2023-51074) * guava: insecure temporary directory creation (CVE-2023-2976) * io.vertx:vertx-core: memory leak when a TCP server is configured with TLS and SNI support (CVE-2024-1300) * io.vertx/vertx-core: memory leak due to the use	2024-05-30	2024-05-30

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	of Netty FastThreadLocal data structures in Vertx (CVE-2024-1023) * quarkus-core: Leak of local configuration properties into Quarkus applications (CVE-2024-2700)		
RHSA-2024:1706_Red Hat	An update for Red Hat Build of Apache Camel 4.0 for Quarkus 3.2 is now available (updates to RHBQ 3.2.11). The purpose of this text-only errata is to inform you about the enhancements that improve your developer experience and ensure the security and stability of your products: * TRIAGE CVE-2024-25710 commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file * TRIAGE CVE-2024-26308 commons-compress: OutOfMemoryError unpacking broken Pack200 file * TRIAGE CVE-2024-1300 vertx-core: io.vertx:vertx-core: memory leak when a TCP server is configured with TLS and SNI support * TRIAGE CVE-2024-1023 vert.x: io.vertx/vertx-core: memory leak due to the use of Netty FastThreadLocal data structures in Vertx	2024-04-09	2024-04-09
WID-SEC-W-2024-0818_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Integration umfasst diverse Integrations- und Messaging-Technologien, mit denen sich Anwendungen und Daten in Hybrid-Infrastrukturen verbinden lassen. # Angriff Ein entfernter authentifizierter oder anonymer Angreifer kann mehrere Schwachstellen in Red Hat Integration ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen oder Sicherheitsmaßnahmen zu umgehen. # Betroffene Betriebssysteme - Linux	2024-04-08	2024-04-08
RHSA-2024:1509_Red Hat	Red Hat Data Grid is an in-memory, distributed, NoSQL datastore solution. It increases application response times and allows for dramatically improving performance while providing availability, reliability, and elastic scale. Data Grid 8.4.7 replaces Data Grid 8.4.6 and includes bug fixes and enhancements. Find out more about Data Grid 8.4.7 in the Release Notes[3]. Security Fix(es): * TRIAGE CVE-2024-25710 commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file [jdg-8] (CVE-2024-25710) * TRIAGE CVE-2024-26308 commons-compress: OutOfMemoryError unpacking broken Pack200 file [jdg-8] (CVE-2024-26308) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-03-26	2024-03-26
WID-SEC-W-2024-3663_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Bamboo ist ein Werkzeug zur kontinuierlichen Integration und Bereitstellung, das automatisierte Builds, Tests und Freigaben in einem einzigen Arbeitsablauf verbindet. # Angriff Ein entfernter Angreifer kann mehrere Schwachstellen in Atlassian Bamboo ausnutzen, um Dateien zu manipulieren oder einen Denial-of-Service-Zustand zu erzeugen. # Betroffene Betriebssysteme - Windows	2024-12-10	2024-12-10
RHSA-2024:3989_Red Hat	Migration Toolkit for Applications 6.2.3 Images Security Fix(es) from Bugzilla: * keycloak: path transversal in redirection validation (CVE-2024-1132) * webpack-dev-middleware: lack of URL validation may lead to file leak (CVE-2024-29180) * axios: exposure of confidential data stored in cookies (CVE-2023-45857) * css-tools: Improper Input Validation causes Denial of Service via Regular Expression (CVE-2023-26364) * css-tools: regular expression denial of service (ReDoS) when parsing CSS (CVE-2023-48631) * follow-redirects:	2024-06-20	2024-06-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Improper Input Validation due to the improper handling of URLs by the url.parse() (CVE-2023-26159) * io.vertx/vertx-core: memory leak due to the use of Netty FastThreadLocal data structures in Vertx (CVE-2024-1023) * io.vertx:vertx-core: memory leak when a TCP server is configured with TLS and SNI support (CVE-2024-1300) * commons-compress: Denial of service caused by an infinite loop for a corrupted DUMP file (CVE-2024-25710) * commons-compress: OutOfMemoryError unpacking broken Pack200 file (CVE-2024-26308) * follow-redirects: Possible credential leak (CVE-2024-28849) * jetty: Improper addition of quotation marks to user inputs in CgiServlet (CVE-2023-36479) * commons-configuration: StackOverflowError calling ListDelimiterHandler.flatten(Object, int) with a cyclical object tree (CVE-2024-29133) * commons-configuration: StackOverflowError adding property in AbstractListDelimiterHandler.flattenIterator() (CVE-2024-29131)		

Assessment Medium | None | In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.01 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **98.74 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2024-22262

Description

Applications that use UriComponentsBuilder to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks. This is the same as CVE-2024-22259 https://spring.io/security/cve-2024-22259 and CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-22262	2024-04-16	2025-02-13
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-22262	2024-04-16	2025-02-13
CVE Details	https://www.cvedetails.com/cve/CVE-2024-22262	2024-04-16	2025-02-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-601

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	8.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-2wrp-6fg6-hmc5	Spring Framework URL Parsing with Host Validation	2024-04-16	2024-04-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2024-AVI-0595	Multiples vulnérabilités dans Oracle MySQL	2024-07-17	2024-07-17
CERTFR-2024-AVI-0504	Multiples vulnérabilités dans les produits Atlassian	2024-06-19	2024-06-19
CERTFR-2024-AVI-0886	Multiples vulnérabilités dans Oracle Systems	2024-10-16	2024-10-16
CERTFR-2024-AVI-0498	Multiples vulnérabilités dans les produits IBM	2024-06-14	2024-06-14
CERTFR-2024-AVI-0599	Multiples vulnérabilités dans Oracle Weblogic	2024-07-17	2024-07-17
CERTFR-2024-AVI-0298	Vulnérabilité dans Spring Framework	2024-04-11	2024-04-11
CERTFR-2024-AVI-0514	Multiples vulnérabilités dans les produits IBM	2024-06-21	2024-06-21
CERTFR-2024-AVI-0506	Multiples vulnérabilités dans Juniper Secure Analytics	2024-06-19	2024-06-19
CERTFR-2024-AVI-0470	Multiples vulnérabilités dans les produits IBM	2024-06-07	2024-06-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Other

Id	Summary	Create Date	Update Date
ICSA-25-261-04_CISA	# Summary Hitachi Energy is aware of multiple reported vulnerabilities that affect the Asset Suite product versions mentioned in this document below. If exploited these vulnerabilities can potentially impact on confidentiality, integrity and availability of the product. Please refer to the Recommended Immediate Actions for information about the mitigation/ remediation. # Notice The information in this document is subject to change without notice and should not be construed as a commitment by Hitachi Energy. Hitachi Energy provides no warranty, express or implied, including warranties of merchantability and fitness for a particular purpose, for the information contained in this document, and assumes no responsibility for any errors that may appear in this document. In no event shall Hitachi Energy or any of its suppliers be liable for direct, indirect, special, incidental or consequential damages of any nature or kind arising from the use of this document, or from the use of any hardware or software described in this document, even if Hitachi Energy or its suppliers have been advised of the possibility of such damages. This document and parts hereof must not be reproduced or copied without written permission from Hitachi Energy and the contents hereof must not be imparted to a third party nor used for any unauthorized purpose. All rights to registrations and trademarks reside with their respective owners. # Support For additional information and support please contact your product provider or Hitachi Energy service organization. For contact information, see https://www.hitachienergy.com/contact-us/ for Hitachi Energy contact-centers. # General Mitigation Factors Recommended security practices and firewall configurations can help protect a process control network from attacks that originate from outside the network. Such practices include that process control systems are physically protected from direct access by unauthorized personnel, have no direct connections to the Internet, and are separated from other networks by means of a firewall system that has a minimal number of ports exposed, and others that have to be evaluated case by case. Process control systems should not be used for Internet surfing, instant messaging, or receiving e-mails. Portable computers and removable storage media should be carefully scanned for viruses before they are connected to a control system. Proper password policies and processes should be followed. # Legal Notice All information products included in https://us-cert.cisa.gov/ics are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see https://us-cert.cisa.gov/tlp/. # Advisory Conversion Disclaimer This ICSA is a verbatim republication of Hitachi Energy PSIRT 8DBD000221 from a direct conversion of the vendor's Common Security Advisory Framework (CSAF) advisory. This is republished to CISA's website as a means of increasing visibility and is provided "as-is" for informational purposes only. CISA is not responsible for the editorial or technical accuracy of republished advisories and provides no warranties of any kind regarding any information contained within this advisory. Further, CISA does not endorse any commercial product or service. Please contact Hitachi Energy PSIRT directly for any questions regarding this advisory. # Critical infrastructure sectors Energy # Countries/areas deployed Worldwide # Company headquarters location Switzerland # Recommended Practices CISA recommends users take defensive measures to minimize the exploitation risk of this vulnerability. # Recommended Practices Minimize network exposure for all control system devices and/or systems, and ensure they are not accessible from the internet. # Recommended Practices Locate control	2025-08-26	2025-08-26

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	system networks and remote devices behind firewalls and isolate them from business networks. # Recommended Practices When remote access is required, use more secure methods, such as Virtual Private Networks (VPNs), recognizing VPNs may have vulnerabilities and should be updated to the most recent version available. Also recognize VPN is only as secure as its connected devices. # Recommended Practices CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures. # Recommended Practices CISA also provides a section for control systems security recommended practices on the ICS webpage on cisa.gov. Several CISA products detailing cyber defense best practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies. # Recommended Practices CISA encourages organizations to implement recommended cybersecurity strategies for proactive defense of ICS assets. Additional mitigation guidance and recommended practices are publicly available on the ICS webpage at cisa.gov in the technical information paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies. # Recommended Practices Organizations observing suspected malicious activity should follow established internal procedures and report findings to CISA for tracking and correlation against other incidents.		
WID-SEC-W-2024-0854_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Daten zu manipulieren oder Informationen offenzulegen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2024-04-10	2024-04-10
WID-SEC-W-2024-3195_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges	2024-10-15	2024-10-15
WID-SEC-W-2024-1656_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-1641_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. #	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Produktbeschreibung Construction and Engineering ist eine Sammlung von Werkzeugen zur Unterstützung von Bau- und Ingenieurbüros. Sie umfasst u. a. Projektmanagement-Lösungen zur Verwaltung von Projekte, zur Schaffung von Transparenz, zur Zusammenarbeit und zur Verwaltung von Änderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Construction and Engineering ausnutzen, um die Vertraulichkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		
WID-SEC-W-2024-3218_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Systems umfasst eine Sammlung von Hardware, Betriebssystemen, Servern und Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Systems ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-10-15	2024-10-15
WID-SEC-W-2024-1622_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - UNIX - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-3192_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-10-15	2024-10-15
CVE-2024-22262_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-04-16	2024-04-16
WID-SEC-W-2024-1638_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		
WID-SEC-W-2024-1642_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-1313_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um Dateien zu manipulieren, um einen Denial-of-Service-Zustand erzuegen, um vertrauliche Informationen offenzulegen, um die Sicherheitsmaßnahmen zu umgehen und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux	2024-06-06	2024-06-06
WID-SEC-W-2024-1207_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Bitbucket ist ein Git-Server zur Sourcecode-Versionskontrolle. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Atlassian Bitbucket ausnutzen, um die Vertraulichkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-05-21	2024-05-21
WID-SEC-W-2024-1659_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Insurance Applications ist eine Produktfamilie mit Lösungen für die Versicherungsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Insurance Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-1654_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - Windows	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-1637_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-1643_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16
WID-SEC-W-2024-3191_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges	2024-10-15	2024-10-15
RHSA-2024:3708_Red Hat	Red Hat build of Apache Camel 3.20.6 for Spring Boot release and security update is now available. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * xalan: OpenJDK: integer truncation issue in Xalan-J (JAXP, 8285407) (CVE-2022-34169) * jettison: stack overflow in JSONObject() allows attackers to cause a Denial of Service (DoS) via crafted JSON data (CVE-2022-45685) * santuario: Private Key disclosure in debug-log output (CVE-2023-44483) * springframework: URL Parsing with Host Validation (CVE-2024-22262) * cxf-core: Apache CXF SSRF Vulnerability using the Aegis databinding (CVE-2024-28752) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-06-06	2024-06-06

Assessment High Elevated In Review

Rationale
The vulnerability has automatically been marked as in review.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **6.25 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **9.42 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-22259

Description

Applications that use UriComponentsBuilder in Spring Framework to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks. This is the same as CVE-2024-22243 https://spring.io/security/cve-2024-22243 , but with different input.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-22259	2024-03-16	2025-06-10
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-22259	2024-03-16	2025-06-10
CVE Details	https://www.cvedetails.com/cve/CVE-2024-22259	2024-03-16	2025-06-10

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-601

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	8.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-hgjh-9rj2-g67j	Spring Framework URL Parsing with Host Validation Vulnerability	2024-03-16	2024-03-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0844	Multiples vulnérabilités dans les produits SAP	2024-10-08	2024-10-08
CERTFR-2024-AVI-0223	Vulnérabilité dans Spring Framework	2024-03-15	2024-03-15
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2024-AVI-0504	Multiples vulnérabilités dans les produits Atlassian	2024-06-19	2024-06-19
CERTFR-2024-AVI-0514	Multiples vulnérabilités dans les produits IBM	2024-06-21	2024-06-21
CERTFR-2024-AVI-0506	Multiples vulnérabilités dans Juniper Secure Analytics	2024-06-19	2024-06-19
CERTFR-2024-AVI-0470	Multiples vulnérabilités dans les produits IBM	2024-06-07	2024-06-07

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-0869_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-04-16	2024-04-16
WID-SEC-W-2024-1313_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um Dateien zu manipulieren, um einen Denial-of-Service-Zustand erzuegen, um vertrauliche Informationen offenzulegen, um die Sicherheitsmaßnahmen zu umgehen und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux	2024-06-06	2024-06-06
CVE-2024-22259_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of	2024-03-16	2024-03-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	it, you must provide attribution to Red Hat Inc. and provide a link to the original.		
WID-SEC-W-2024-0639_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Dateien zu manipulieren oder Informationen offenzulegen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-03-14	2024-03-14
RHSA-2024:2945_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.12.0 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * (CVE-2023-6717) keycloak: XSS via assertion consumer service URL in SAML POST-binding flow * (CVE-2024-1132) keycloak: path transversal in redirection validation * (CVE-2024-1249) keycloak: org.keycloak.protocol.oidc: unvalidated cross-origin messages in checkLoginIframe leads to DDoS * (CVE-2024-22259) springframework: URL Parsing with Host Validation * (CVE-2022-41678) Apache ActiveMQ: Deserialization vulnerability on Jolokia that allows authenticated users to perform RCE * (CVE-2023-44981) zookeeper: Authorization Bypass in Apache ZooKeeper * (CVE-2023-6378) logback: serialization vulnerability in logback receiver * (CVE-2023-6481) logback: A serialization vulnerability in logback receiver * (CVE-2024-29025) netty-codec-http: Allocation of Resources Without Limits or Throttling * (CVE-2024-29131) commons-configuration: StackOverflowError adding property in AbstractListDelimiterHandler.flattenIterator() * (CVE-2024-29133) commons-configuration: StackOverflowError calling ListDelimiterHandler.flatten(Object, int) with a cyclical object tree For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2024-05-21	2024-05-21
WID-SEC-W-2024-1637_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16

Assessment High Due In Review

Rationale
The vulnerability has automatically been marked as in review.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Priority Due

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **30.51 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **3.43 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2024-22243

Description

Applications that use UriComponentsBuilder to parse an externally provided URL (e.g. through a query parameter) AND perform validation checks on the host of the parsed URL may be vulnerable to a open redirect https://cwe.mitre.org/data/definitions/601.html attack or to a SSRF attack if the URL is used after passing validation checks.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2024-22243	2024-02-23	2025-02-13
MITRE	https://www.cve.org/CVERecord?id=CVE-2024-22243	2024-02-23	2025-02-13
CVE Details	https://www.cvedetails.com/cve/CVE-2024-22243	2024-02-23	2025-02-13

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-601

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	OSV-GitHub, Inc.	8.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-ccgv-vj62-xf9h	Spring Web vulnerable to Open Redirect or Server Side Request Forgery	2024-02-23	2024-02-23

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0215	Multiples vulnérabilités dans VMware Tanzu Gemfire	2025-03-17	2025-03-17
CERTFR-2024-AVI-0504	Multiples vulnérabilités dans les produits Atlassian	2024-06-19	2024-06-19
CERTFR-2024-AVI-0154	Vulnérabilité dans Spring Framework	2024-02-22	2024-02-22
CERTFR-2024-AVI-0514	Multiples vulnérabilités dans les produits IBM	2024-06-21	2024-06-21
CERTFR-2024-AVI-0506	Multiples vulnérabilités dans Juniper Secure Analytics	2024-06-19	2024-06-19
CERTFR-2024-AVI-0470	Multiples vulnérabilités dans les produits IBM	2024-06-07	2024-06-07

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2025-0810_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2025-04-15	2025-04-15
WID-SEC-W-2024-0457_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um Informationen offenzulegen oder einen Phishing-Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Windows	2024-02-21	2024-02-21
CVE-2024-22243_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2024-02-21	2024-02-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-1313_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um Dateien zu manipulieren, um einen Denial-of-Service-Zustand erzuegen, um vertrauliche Informationen offenzulegen, um die Sicherheitsmaßnahmen zu umgehen und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux	2024-06-06	2024-06-06
RHSA-2024:3354_Red Hat	Red Hat Fuse 7.13.0 is released which includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * undertow: OutOfMemoryError due to @MultipartConfig handling (CVE-2023-3223) * jetty-servlets: jetty: Improper addition of quotation marks to user inputs in CgiServlet (CVE-2023-36479) * jetty: Improper validation of HTTP/1 content-length (CVE-2023-40167) * jetty-http: jetty: Improper validation of HTTP/1 content-length (CVE-2023-40167) * avro: apache-avro: Apache Avro Java SDK: Memory when deserializing untrusted data in Avro Java SDK (CVE-2023-39410) * JSON-java: parser confusion leads to OOM (CVE-2023-5072) * http2-hpack: jetty: hpack header values cause denial of service in http/2 (CVE-2023-36478) * spring-boot: org.springframework.boot:spring-boot-actuator class vulnerable to denial of service (CVE-2023-34055) * tomcat: HTTP request smuggling via malformed trailer headers (CVE-2023-46589) * activemq: Apache ActiveMQ: Deserialization vulnerability on Jolokia that allows authenticated users to perform RCE (CVE-2022-41678) * logback: serialization vulnerability in logback receiver (CVE-2023-6378) * logback: A serialization vulnerability in logback receiver (CVE-2023-6481) * solr: : Apache Solr: Host environment variables are published via the Metrics API (CVE-2023-50290) * shiro: path traversal attack may lead to authentication bypass (CVE-2023-46749) * tomcat: Leaking of unrelated request bodies in default error page (CVE-2024-21733) * springframework: URL Parsing with Host Validation (CVE-2024-22243) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-05-23	2024-05-23
OXAS-ADV-2024-0005_Open-Exchange		2024-07-08	2024-07-08
WID-SEC-W-2024-0868_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Construction and Engineering ist eine Sammlung von Werkzeugen zur Unterstützung von Bau- und Ingenieurbüros. Sie umfasst u. a. Projektmanagement-Lösungen zur Verwaltung von Projekte, zur Schaffung von Transparenz, zur Zusammenarbeit und zur Verwaltung von Änderungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Construction and Engineering ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-04-16	2024-04-16
WID-SEC-W-2024-1637_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		

Assessment High Due In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority Due

Criteria	Explanation
CVSS Overall	*CVSS:3.1 OSV-GitHub, Inc.* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **48.23 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **2.33 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2023-34053

Description

In Spring Framework versions 6.0.0 - 6.0.13, it is possible for a user to provide specially crafted HTTP requests that may cause a denial-of-service (DoS) condition. Specifically, an application is vulnerable when all of the following are true: * the application uses Spring MVC or Spring WebFlux * io.micrometer:micrometer-core is on the classpath * an ObservationRegistry is configured in the application to record observations Typically, Spring Boot applications need the org.springframework.boot:spring-boot-actuator dependency to meet all conditions.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2023-34053	2023-11-28	2025-02-13
MITRE	https://www.cve.org/CVERecord?id=CVE-2023-34053	2023-11-28	2025-02-13
CVE Details	https://www.cvedetails.com/cve/CVE-2023-34053	2023-11-28	2025-02-13

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	7.5	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-v94h-hvhg-mf9h	Spring Framework vulnerable to denial of service	2023-11-28	2023-11-28

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0145	Multiples vulnérabilités dans les produits IBM	2024-02-16	2024-02-16
CERTFR-2023-AVI-0980	Multiples vulnérabilités dans les produits Spring	2023-11-27	2023-11-27

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-0869_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-04-16	2024-04-16
WID-SEC-W-2024-0106_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2024-01-16	2024-01-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CVE-2023-34053_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2023-11-27	2023-11-27
WID-SEC-W-2023-3009_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. Spring Boot ist ein Framework zur Entwicklung von Java Anwendungen. Spring Boot basiert auf dem Spring Framework. # Angriff Ein entfernter, authentisierter Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework und VMware Tanzu Spring Boot ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - MacOS X - Windows	2023-11-26	2023-11-26
WID-SEC-W-2024-0870_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-04-16	2024-04-16

Assessment

High | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.45 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **36.92 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

CVE-2023-20863

Description

In spring framework versions prior to 5.2.24 release+ ,5.3.27+ and 6.0.8+ , it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2023-20863	2023-04-13	2025-02-07
MITRE	https://www.cve.org/CVERecord?id=CVE-2023-20863	2023-04-13	2025-02-07
CVE Details	https://www.cvedetails.com/cve/CVE-2023-20863	2023-04-13	2025-02-07

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness

CWE-400, CWE-917

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	6.5	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`	**Medium**

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-wxqc-pxw9-g2p8	Spring Framework vulnerable to denial of service	2023-04-13	2023-04-13

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0324	Multiples vulnérabilités dans Oracle Systems	2024-04-18	2024-04-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0863	Multiples vulnérabilités dans Oracle MySQL	2023-10-18	2023-10-18
CERTFR-2023-AVI-0567	Multiples vulnérabilités dans Oracle WebLogic	2023-07-19	2023-07-19
CERTFR-2023-AVI-0990	Multiples vulnérabilités dans les produits IBM	2023-12-01	2023-12-01
CERTFR-2024-AVI-0010	Multiples vulnérabilités dans les produits IBM	2024-01-05	2024-01-05
CERTFR-2023-AVI-0798	Multiples vulnérabilités dans les produits IBM	2023-10-03	2023-10-03
CERTFR-2023-AVI-0513	Multiples vulnérabilités dans les produits IBM	2023-07-07	2023-07-07

Other

Id	Summary	Create Date	Update Date
RHSA-2023:2099_Red Hat	A patch is now available for Camel for Spring Boot 3.18.3. The purpose of this text-only errata is to inform you about the security issues fixed in this release. Security Fix(es): * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20863) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-05-03	2023-05-03
WID-SEC-W-2023-0966_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2023-04-13	2023-04-13
WID-SEC-W-2023-2690_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2023-10-17	2023-10-17
WID-SEC-W-2023-2688_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-10-17	2023-10-17
WID-SEC-W-2023-1813_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen	2023-07-18	2023-07-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows		
WID-SEC-W-2023-1142_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Enterprise Linux (RHEL) ist eine populäre Linux-Distribution. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Red Hat Integration Camel for Spring Boot ausnutzen, um die Vertraulichkeit, Verfügbarkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - Linux	2023-05-03	2023-05-03
RHSA-2023:2100_Red Hat	This release of Camel for Spring Boot 3.20.1 serves as a replacement for Camel for Spring Boot 3.18.3 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * JXPath: untrusted XPath expressions may lead to RCE attack (CVE-2022-41852) * hsqldb: Untrusted input may lead to RCE attack (CVE-2022-41853) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * apache-commons-net: FTP client trusts the host from PASV response by default (CVE-2021-37533) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * apache-spark: XSS vulnerability in log viewer UI Javascript (CVE-2022-31777) * Apache Pulsar: Improper Hostname Verification in Java Client and Proxy can expose authentication data via MITM (CVE-2022-33681) * apache-ivy: Directory Traversal (CVE-2022-37865) * : Apache Ivy: Ivy Path traversal (CVE-2022-37866) * batik: Server-Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.composer.Composer.composeSequenceNode (CVE-2022-38749) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.constructor.BaseConstructor.constructObject (CVE-2022-38750) * snakeyaml: Uncaught exception in java.base/java.util.regex.Pattern$Ques.match (CVE-2022-38751) * snakeyaml: Uncaught exception in java.base/java.util.ArrayList.hashCode (CVE-2022-38752) * scandium: Failing DTLS handshakes may cause throttling to block processing of records (CVE-2022-39368) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * xstream: Xstream to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40151) * woodstox-core: woodstox to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40152) * xstream: Xstream to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40156) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS	2023-05-03	2023-05-03

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	(CVE-2022-42003) * jackson-databind: use of deeply nested arrays (CVE-2022-42004) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * Apache Commons FileUpload: FileUpload DoS with excessive parts (CVE-2023-24998) * jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20863) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-1847_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM InfoSphere Information Server ist eine Softwareplattform zur Integration heterogener Daten. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in IBM InfoSphere Information Server ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Windows - Sonstiges	2023-07-20	2023-07-20
WID-SEC-W-2023-2681_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-10-17	2023-10-17
WID-SEC-W-2023-2674_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-10-17	2023-10-17
WID-SEC-W-2023-1782_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Utilities Applications ist eine Produktfamilie mit branchenspezifischen Lösungen für Ver- und Entsorger. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Utilities Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-07-18	2023-07-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2023-1811_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Construction and Engineering ist eine Sammlung von Werkzeugen zur Unterstützung von Bau- und Ingenieurbüros. Sie umfasst u. a. Projektmanagement-Lösungen zur Verwaltung von Projekte, zur Schaffung von Transparenz, zur Zusammenarbeit und zur Verwaltung von Änderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Construction and Engineering ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2024-0888_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Systems umfasst eine Sammlung von Hardware, Betriebssystemen, Servern und Anwendungen. # Angriff Ein Angreifer kann mehrere Schwachstellen in Oracle Systems ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-04-16	2024-04-16
WID-SEC-W-2023-1808_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
CVE-2023-20863_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2023-04-13	2023-04-13
WID-SEC-W-2023-1807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2024-3197_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen.	2024-10-15	2024-10-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	# Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows		
WID-SEC-W-2023-1812_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2024-0871_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-04-16	2024-04-16
WID-SEC-W-2023-2675_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-10-17	2023-10-17
WID-SEC-W-2023-2679_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-10-17	2023-10-17
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen,	2024-02-29	2024-02-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows		
WID-SEC-W-2023-1804_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Insurance Applications ist eine Produktfamilie mit Lösungen für die Versicherungsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Insurance Applications ausnutzen, um die Vertraulichkeit und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2023-1791_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-07-18	2023-07-18

Assessment **Medium** **Elevated** **In Review**

Rationale
The vulnerability has automatically been marked as in review.

Priority **Elevated**

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.85 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **25.82 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2023-20861

Description

In Spring Framework versions 6.0.0 - 6.0.6, 5.3.0 - 5.3.25, 5.2.0.RELEASE - 5.2.22.RELEASE, and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial-of-service (DoS) condition.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2023-20861	2023-03-23	2025-02-25
MITRE	https://www.cve.org/CVERecord?id=CVE-2023-20861	2023-03-23	2025-02-25
CVE Details	https://www.cvedetails.com/cve/CVE-2023-20861	2023-03-23	2025-02-25

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-400

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	6.5	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`	**Medium**

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-564r-hj7v-mcr5	Spring Framework vulnerable to denial of service via specially crafted SpEL expression	2023-03-23	2023-03-23

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0990	Multiples vulnérabilités dans les produits IBM	2023-12-01	2023-12-01
CERTFR-2024-AVI-0010	Multiples vulnérabilités dans les produits IBM	2024-01-05	2024-01-05
CERTFR-2023-AVI-0513	Multiples vulnérabilités dans les produits IBM	2023-07-07	2023-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Other

Id	Summary	Create Date	Update Date
RHSA-2023:3622_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * maven-shared-utils: Command injection via Commandline class (CVE-2022-29599) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * Jenkins plugin: CSRF vulnerability in Blue Ocean Plugin (CVE-2022-30953) * Jenkins plugin: missing permission checks in Blue Ocean Plugin (CVE-2022-30954) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * Jenkins: Temporary file parameter created with insecure permissions (CVE-2023-27903) * Jenkins: Information disclosure through error stack traces related to agents (CVE-2023-27904) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-06-15	2023-06-15
RHSA-2024:0778_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * apache-commons-text: variable interpolation RCE (CVE-2022-42889) * google-oauth-client: missing PKCE support in accordance with the RFC for OAuth 2.0 for Native Apps can lead to improper authorization (CVE-2020-7692) * maven: Block repositories using http by default (CVE-2021-26291) * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * maven-shared-utils: Command injection via Commandline class (CVE-2022-29599) * jenkins-2-plugins/script-security: Sandbox bypass vulnerability in Script Security Plugin (CVE-2023-24422) * jenkins: Arbitrary file read vulnerability through the CLI can lead to RCE (CVE-2024-23897) * jenkins: cross-site WebSocket hijacking (CVE-2024-23898) * golang: go/parser: stack exhaustion in all Parse* functions (CVE-2022-1962) * guava: insecure temporary directory creation (CVE-2023-2976) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * spring-security: Empty SecurityContext Is Not Properly Saved Upon Logout (CVE-2023-20862) * jenkins-2-plugins/JUnit: Stored XSS vulnerability in JUnit Plugin (CVE-2023-25761) * jenkins-2-plugins/pipeline-build-step: Stored XSS vulnerability in Pipeline: Build Step Plugin (CVE-2023-25762) * jetty-server: OutOfMemoryError for large multipart without filename read via request.getParameter() (CVE-2023-26048) * jetty-server: Cookie parsing of quoted values can exfiltrate values from other cookies (CVE-2023-26049) * Jenkins: Open redirect vulnerability in OpenShift Login Plugin (CVE-2023-37947) * jetty: Improper validation of HTTP/1 content-length (CVE-2023-40167) * jenkins-plugins: cloudbees-folder: CSRF vulnerability in Folders Plugin (CVE-2023-40337) * jenkins-plugins: cloudbees-folder: Information disclosure in Folders Plugin (CVE-2023-40338) * jenkins-plugins: config-file-provider: Improper masking of credentials in Config File Provider Plugin (CVE-2023-40339) * jenkins-plugins: blueocean: CSRF vulnerability in Blue Ocean Plugin allows capturing credentials (CVE-2023-40341) * Jenkins: Temporary file parameter created with insecure permissions (CVE-2023-27903) * Jenkins: Information disclosure through error stack traces related to agents (CVE-2023-27904) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2024-02-12	2024-02-12
WID-SEC-W-2023-0697_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür	2023-03-20	2023-03-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um Sicherheitsvorkehrungen zu umgehen oder einen Denial of Service Zustand herbeizuführen. # Betroffene Betriebssysteme - Linux - UNIX - Windows		
CVE-2023-20861_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2023-03-20	2023-03-20
RHSA-2023:3771_Red Hat	The VDSM service is required by a Virtualization Manager to manage the Linux hosts. VDSM manages and monitors the host's storage, memory and networks as well as virtual machine creation, other host administration tasks, statistics gathering, and log collection. The following packages have been upgraded to a later upstream version: ovirt-dependencies (4.5.3), ovirt-engine (4.5.3.8), vdsm (4.50.3.8). (BZ#2180717) Security Fix(es): * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Bug Fix(es): * Previously, a host with Secure Intel Icelake Server Family could become non-operational because it did not provide the "taa-no" CPU feature. In this release, the check has been fixed in the Manager, and such hosts work properly. (BZ#2184623) * Previously, when creating bonds on a host outside the Manager and adding the host without starting it, the Rx\Tx drop count is shown as null. As a result, a Null Pointer Exception is thrown in the Administration Portal > Compute > Hosts > Network Interfaces tab. With this release, null values are accepted, and there are no exceptions displayed in the Network Interfaces tab. (BZ#2180230) * Previously, the Volume Extend Logic method skipped sparse volumes. As a result, RAW sparse volumes (on file storage) were not extended properly. In this release, RAW sparse volumes are extended as expected. (BZ#2210036)	2023-06-21	2023-06-21
RHSA-2023:3610_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * maven-shared-utils: Command injection via Commandline class (CVE-2022-29599) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * jenkins-2-plugins/script-security: Sandbox bypass vulnerability in Script Security Plugin (CVE-2023-24422) * jenkins-2-plugin: workflow-job: Stored XSS vulnerability in Pipeline: Job Plugin (CVE-2023-32977) * jackson-databind: Possible DoS if using JDK serialization to serialize JsonNode (CVE-2021-46877) * Jenkins plugin: CSRF vulnerability in Blue Ocean Plugin (CVE-2022-30953) * Jenkins plugin: missing permission checks in Blue Ocean Plugin (CVE-2022-30954) * jettison: parser crash by stackoverflow (CVE-2022-40149) * net/http, golang.org/x/net/http2: avoid quadratic complexity in HPACK decoding (CVE-2022-41723) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos (CVE-2022-45693) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * jenkins-2-plugin: pipeline-utility-steps: Arbitrary file write vulnerability on agents in Pipeline Utility Steps Plugin (CVE-2023-32981) *	2023-06-15	2023-06-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-1813_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2023-1808_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
WID-SEC-W-2023-1807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
RHSA-2023:3185_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.10.3 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * RESTEasy: creation of insecure temp files (CVE-2023-0482) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-05-17	2023-05-17
RHSA-2023:4983_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users	2023-09-05	2023-09-05

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	to create, manage, validate, and deploy process applications and decision services. This asynchronous security patch is an update to Red Hat Process Automation Manager 7. Security Fixes: * apache-bcel: Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * decode-uri-component: improper input validation resulting in DoS (CVE-2022-38900) * mina-sshd: Java unsafe deserialization vulnerability (CVE-2022-45047) * spring-boot: Spring Boot Welcome Page DoS Vulnerability (CVE-2023-20883) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * loader-utils: regular expression denial of service in interpolateName.js (CVE-2022-37599) * protobuf-java: timeout in parser leads to DoS (CVE-2022-3171) * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * woodstox-core: woodstox to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40152) * RESTEasy: creation of insecure temp files (CVE-2023-0482) * sshd-core: mina-sshd-core: Memory leak denial of service in Apache Mina SSHD Server (CVE-2021-30129) For more details about the security issues, including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE pages listed in the References section.		
WID-SEC-W-2023-1812_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
RHSA-2023:4612_Red Hat	Red Hat support for Spring Boot provides an application platform that reduces the complexity of developing and operating applications (monoliths and microservices) for OpenShift as a containerized platform. This release of Red Hat support for Spring Boot 2.7.13 serves as a replacement for Red Hat support for Spring Boot 2.7.12, and includes security, bug fixes and enhancements. For more information, see the release notes linked in the References section. Security Fix(es): * snakeyaml: Constructor Deserialization Remote Code Execution (CVE-2022-1471) * undertow: Infinite loop in SslConduit during close (CVE-2023-1108) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * jackson-databind: Possible DoS if using JDK serialization to serialize JsonNode (CVE-2021-46877) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * reactor-netty-http: Log request headers in some cases of invalid HTTP requests (CVE-2022-31684) * tomcat: JsonErrorReportValve injection (CVE-2022-45143) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-08-16	2023-08-16
WID-SEC-W-2023-1142_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Enterprise Linux (RHEL) ist eine populäre Linux-Distribution. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Red Hat Integration Camel for Spring Boot ausnutzen, um die Vertraulichkeit, Verfügbarkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - Linux	2023-05-03	2023-05-03

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2023:2100_Red Hat	This release of Camel for Spring Boot 3.20.1 serves as a replacement for Camel for Spring Boot 3.18.3 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * JXPath: untrusted XPath expressions may lead to RCE attack (CVE-2022-41852) * hsqldb: Untrusted input may lead to RCE attack (CVE-2022-41853) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * apache-commons-net: FTP client trusts the host from PASV response by default (CVE-2021-37533) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * apache-spark: XSS vulnerability in log viewer UI Javascript (CVE-2022-31777) * Apache Pulsar: Improper Hostname Verification in Java Client and Proxy can expose authentication data via MITM (CVE-2022-33681) * apache-ivy: Directory Traversal (CVE-2022-37865) * : Apache Ivy: Ivy Path traversal (CVE-2022-37866) * batik: Server-Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.composer.Composer.composeSequenceNode (CVE-2022-38749) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.constructor.BaseConstructor.constructObject (CVE-2022-38750) * snakeyaml: Uncaught exception in java.base/ java.util.regex.Pattern$Ques.match (CVE-2022-38751) * snakeyaml: Uncaught exception in java.base/java.util.ArrayList.hashCode (CVE-2022-38752) * scandium: Failing DTLS handshakes may cause throttling to block processing of records (CVE-2022-39368) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * xstream: Xstream to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40151) * woodstox-core: woodstox to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40152) * xstream: Xstream to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40156) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS (CVE-2022-42003) * jackson-databind: use of deeply nested arrays (CVE-2022-42004) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * Apache Commons FileUpload: FileUpload DoS with excessive parts (CVE-2023-24998) * jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20863) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-05-03	2023-05-03
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. #	2024-02-29	2024-02-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows		
WID-SEC-W-2023-1755_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM InfoSphere Information Server ist eine Softwareplattform zur Integration heterogener Daten. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM InfoSphere Information Server ausnutzen, um beliebigen Programmcode auszuführen, Sicherheitsvorkehrungen zu umgehen oder einen Denial of Service Zustand herbeizuführen. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-16	2023-07-16
WID-SEC-W-2024-0874_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Enterprise Manager (OEM) ist ein Set von System Management Werkzeugen von Oracle für Oracle Umgebungen. Es beinhaltet Werkzeuge zum Monitoring von Oracle Umgebung und zur Automatisierung von Datenbank- und Applikations Administration. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Enterprise Manager ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-04-16	2024-04-16
RHSA-2023:3954_Red Hat	This release of Red Hat Fuse 7.12 serves as a replacement for Red Hat Fuse 7.11 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * hazelcast: Hazelcast connection caching (CVE-2022-36437) * spring-security: Authorization rules can be bypassed via forward or include dispatcher types in Spring Security (CVE-2022-31692) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * Apache CXF: SSRF Vulnerability (CVE-2022-46364) * Undertow: Infinite loop in SslConduit during close (CVE-2023-1108) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * spring-boot: Spring Boot Welcome Page DoS Vulnerability (CVE-2023-20883) * jakarta-commons-httpclient: missing connection hostname check against X.509 certificate name (CVE-2012-5783) * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * Moment.js: Path traversal in moment.locale (CVE-2022-24785) * batik: Server-Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) *	2023-06-29	2023-06-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * engine.io: Specially crafted HTTP request can trigger an uncaught exception (CVE-2022-41940) * postgresql-jdbc: Information leak of prepared statement data due to insecure temporary file permissions (CVE-2022-41946) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * Apache CXF: directory listing / code exfiltration (CVE-2022-46363) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * bouncycastle: potential blind LDAP injection attack using a self-signed certificate (CVE-2023-33201) * tomcat: JsonErrorReportValve injection (CVE-2022-45143) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		

Assessment

Medium | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.37 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **41.56 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2023-20860

Description

Spring Framework running version 6.0.0 - 6.0.6 or 5.3.0 - 5.3.25 using "**" as a pattern in Spring Security configuration with the mvcRequestMatcher creates a mismatch in pattern matching between Spring Security and Spring MVC, and the potential for a security bypass.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2023-20860	2023-03-27	2025-02-19
MITRE	https://www.cve.org/CVERecord?id=CVE-2023-20860	2023-03-27	2025-02-19
CVE Details	https://www.cvedetails.com/cve/CVE-2023-20860	2023-03-27	2025-02-19

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	7.5	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-7phw-cxx7-q9vq	Spring Framework is vulnerable to security bypass via mvcRequestMatcher pattern mismatch	2023-03-28	2023-03-28

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0398	Multiples vulnérabilités dans le cadriciel VMware Spring	2023-05-19	2023-05-19
CERTFR-2023-AVI-0567	Multiples vulnérabilités dans Oracle WebLogic	2023-07-19	2023-07-19
CERTFR-2023-AVI-0990	Multiples vulnérabilités dans les produits IBM	2023-12-01	2023-12-01
CERTFR-2023-AVI-0397	Vulnérabilité dans IBM Sterling Connect	2023-05-19	2023-05-19
CERTFR-2024-AVI-0010	Multiples vulnérabilités dans les produits IBM	2024-01-05	2024-01-05
CERTFR-2023-AVI-0513	Multiples vulnérabilités dans les produits IBM	2023-07-07	2023-07-07

Other

Id	Summary	Create Date	Update Date
RHSA-2023:3622_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * maven-shared-utils: Command injection via Commandline class (CVE-2022-29599) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * Jenkins plugin: CSRF vulnerability in Blue Ocean Plugin (CVE-2022-30953) * Jenkins plugin:	2023-06-15	2023-06-15

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	missing permission checks in Blue Ocean Plugin (CVE-2022-30954) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * Jenkins: Temporary file parameter created with insecure permissions (CVE-2023-27903) * Jenkins: Information disclosure through error stack traces related to agents (CVE-2023-27904) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-0697_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um Sicherheitsvorkehrungen zu umgehen oder einen Denial of Service Zustand herbeizuführen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2023-03-20	2023-03-20
RHSA-2023:3771_Red Hat	The VDSM service is required by a Virtualization Manager to manage the Linux hosts. VDSM manages and monitors the host's storage, memory and networks as well as virtual machine creation, other host administration tasks, statistics gathering, and log collection. The following packages have been upgraded to a later upstream version: ovirt-dependencies (4.5.3), ovirt-engine (4.5.3.8), vdsm (4.50.3.8). (BZ#2180717) Security Fix(es): * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Bug Fix(es): * Previously, a host with Secure Intel Icelake Server Family could become non-operational because it did not provide the "taa-no" CPU feature. In this release, the check has been fixed in the Manager, and such hosts work properly. (BZ#2184623) * Previously, when creating bonds on a host outside the Manager and adding the host without starting it, the Rx\Tx drop count is shown as null. As a result, a Null Pointer Exception is thrown in the Administration Portal > Compute > Hosts > Network Interfaces tab. With this release, null values are accepted, and there are no exceptions displayed in the Network Interfaces tab. (BZ#2180230) * Previously, the Volume Extend Logic method skipped sparse volumes. As a result, RAW sparse volumes (on file storage) were not extended properly. In this release, RAW sparse volumes are extended as expected. (BZ#2210036)	2023-06-21	2023-06-21
RHSA-2023:3663_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * log4j1-chainsaw, log4j1-socketappender: DoS via hashmap logging (CVE-2023-26464) * Jenkins: XSS vulnerability in plugin manager (CVE-2023-27898) * Jenkins: Temporary plugin file created with insecure permissions (CVE-2023-27899) * jenkins-2-plugin: workflow-job: Stored XSS vulnerability in Pipeline: Job Plugin (CVE-2023-32977) * http2-server: Invalid HTTP/2 requests cause DoS (CVE-2022-2048)	2023-06-19	2023-06-19

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* springframework: BCrypt skips salt rounds for work factor of 31 (CVE-2022-22976) * jettison: parser crash by stackoverflow (CVE-2022-40149) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS (CVE-2022-42003) * jackson-databind: use of deeply nested arrays (CVE-2022-42004) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * jenkins-2-plugin: pipeline-utility-steps: Arbitrary file write vulnerability on agents in Pipeline Utility Steps Plugin (CVE-2023-32981) * jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) * Jenkins: Temporary file parameter created with insecure permissions (CVE-2023-27903) * Jenkins: Information disclosure through error stack traces related to agents (CVE-2023-27904) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2023:3610_Red Hat	Jenkins is a continuous integration server that monitors executions of repeated jobs, such as building a software project or jobs run by cron. Security Fix(es): * maven-shared-utils: Command injection via Commandline class (CVE-2022-29599) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * jenkins-2-plugins/script-security: Sandbox bypass vulnerability in Script Security Plugin (CVE-2023-24422) * jenkins-2-plugin: workflow-job: Stored XSS vulnerability in Pipeline: Job Plugin (CVE-2023-32977) * jackson-databind: Possible DoS if using JDK serialization to serialize JsonNode (CVE-2021-46877) * Jenkins plugin: CSRF vulnerability in Blue Ocean Plugin (CVE-2022-30953) * Jenkins plugin: missing permission checks in Blue Ocean Plugin (CVE-2022-30954) * jettison: parser crash by stackoverflow (CVE-2022-40149) * net/http, golang.org/x/net/http2: avoid quadratic complexity in HPACK decoding (CVE-2022-41723) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos (CVE-2022-45693) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * jenkins-2-plugin: pipeline-utility-steps: Arbitrary file write vulnerability on agents in Pipeline Utility Steps Plugin (CVE-2023-32981) * jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-06-15	2023-06-15
WID-SEC-W-2023-1807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
RHSA-2023:3185_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.10.3 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) *	2023-05-17	2023-05-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * RESTEasy: creation of insecure temp files (CVE-2023-0482) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2023:4983_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This asynchronous security patch is an update to Red Hat Process Automation Manager 7. Security Fixes: * apache-bcel: Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * decode-uri-component: improper input validation resulting in DoS (CVE-2022-38900) * mina-sshd: Java unsafe deserialization vulnerability (CVE-2022-45047) * spring-boot: Spring Boot Welcome Page DoS Vulnerability (CVE-2023-20883) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * loader-utils: regular expression denial of service in interpolateName.js (CVE-2022-37599) * protobuf-java: timeout in parser leads to DoS (CVE-2022-3171) * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * woodstox-core: woodstox to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40152) * RESTEasy: creation of insecure temp files (CVE-2023-0482) * sshd-core: mina-sshd-core: Memory leak denial of service in Apache Mina SSHD Server (CVE-2021-30129) For more details about the security issues, including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE pages listed in the References section.	2023-09-05	2023-09-05
RHSA-2023:3625_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. This advisory contains the RPM packages for Red Hat OpenShift Container Platform 4.10.62. See the following advisory for the container images for this release: https://access.redhat.com/errata/RHSA-2023:3626 Security Fix(es): * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * jenkins-2-plugin: workflow-job: Stored XSS vulnerability in Pipeline: Job Plugin (CVE-2023-32977) * jenkins-2-plugin: email-ext: Missing permission check in Email Extension Plugin (CVE-2023-32979) * jenkins-2-plugin: email-ext: CSRF vulnerability in Email Extension Plugin (CVE-2023-32980) * jenkins-2-plugin: pipeline-utility-steps: Arbitrary file write vulnerability on agents in Pipeline Utility Steps Plugin (CVE-2023-32981) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. All OpenShift Container Platform 4.10 users are advised to upgrade to these updated packages and images when they are available in the appropriate release channel. To check for available updates, use the OpenShift CLI (oc) or web console. Instructions for upgrading a cluster are available at https://docs.openshift.com/container-platform/4.10/updating/updating-cluster-cli.html	2023-06-23	2023-06-23
RHSA-2023:4612_Red Hat	Red Hat support for Spring Boot provides an application platform that reduces the complexity of developing and operating applications (monoliths and microservices) for OpenShift as a containerized platform.	2023-08-16	2023-08-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	This release of Red Hat support for Spring Boot 2.7.13 serves as a replacement for Red Hat support for Spring Boot 2.7.12, and includes security, bug fixes and enhancements. For more information, see the release notes linked in the References section. Security Fix(es): * snakeyaml: Constructor Deserialization Remote Code Execution (CVE-2022-1471) * undertow: Infinite loop in SslConduit during close (CVE-2023-1108) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * jackson-databind: Possible DoS if using JDK serialization to serialize JsonNode (CVE-2021-46877) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * reactor-netty-http: Log request headers in some cases of invalid HTTP requests (CVE-2022-31684) * tomcat: JsonErrorReportValve injection (CVE-2022-45143) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-1142_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Enterprise Linux (RHEL) ist eine populäre Linux-Distribution. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Red Hat Integration Camel for Spring Boot ausnutzen, um die Vertraulichkeit, Verfügbarkeit und Integrität zu gefährden. # Betroffene Betriebssysteme - Linux	2023-05-03	2023-05-03
RHSA-2023:2100_Red Hat	This release of Camel for Spring Boot 3.20.1 serves as a replacement for Camel for Spring Boot 3.18.3 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. The purpose of this text-only errata is to inform you about the security issues fixed. Security Fix(es): * snakeyaml: Denial of Service due to missing nested depth limitation for collections (CVE-2022-25857) * JXPath: untrusted XPath expressions may lead to RCE attack (CVE-2022-41852) * hsqldb: Untrusted input may lead to RCE attack (CVE-2022-41853) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * apache-commons-net: FTP client trusts the host from PASV response by default (CVE-2021-37533) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * apache-spark: XSS vulnerability in log viewer UI Javascript (CVE-2022-31777) * Apache Pulsar: Improper Hostname Verification in Java Client and Proxy can expose authentication data via MITM (CVE-2022-33681) * apache-ivy: Directory Traversal (CVE-2022-37865) * : Apache Ivy: Ivy Path traversal (CVE-2022-37866) * batik: Server-Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.composer.Composer.composeSequenceNode (CVE-2022-38749) * snakeyaml: Uncaught exception in org.yaml.snakeyaml.constructor.BaseConstructor.constructObject (CVE-2022-38750) * snakeyaml: Uncaught exception in java.base/ java.util.regex.Pattern$Ques.match (CVE-2022-38751) * snakeyaml: Uncaught exception in java.base/java.util.ArrayList.hashCode (CVE-2022-38752) * scandium: Failing DTLS handshakes may cause throttling to block processing of records (CVE-2022-39368) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * xstream: Xstream to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40151) * woodstox-core: woodstox to serialise XML data was vulnerable to Denial of Service attacks (CVE-2022-40152) * xstream: Xstream to serialise XML data was	2023-05-03	2023-05-03

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	vulnerable to Denial of Service attacks (CVE-2022-40156) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS (CVE-2022-42003) * jackson-databind: use of deeply nested arrays (CVE-2022-42004) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * jettison: Uncontrolled Recursion in JSONArray (CVE-2023-1436) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * Apache Commons FileUpload: FileUpload DoS with excessive parts (CVE-2023-24998) * jettison: memory exhaustion via user-supplied XML or JSON data (CVE-2022-40150) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20863) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
CVE-2023-20860_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2023-03-20	2023-03-20
WID-SEC-W-2023-1755_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM InfoSphere Information Server ist eine Softwareplattform zur Integration heterogener Daten. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM InfoSphere Information Server ausnutzen, um beliebigen Programmcode auszuführen, Sicherheitsvorkehrungen zu umgehen oder einen Denial of Service Zustand herbeizuführen. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-16	2023-07-16
RHSA-2023:3954_Red Hat	This release of Red Hat Fuse 7.12 serves as a replacement for Red Hat Fuse 7.11 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * hazelcast: Hazelcast connection caching (CVE-2022-36437) * spring-security: Authorization rules can be bypassed via forward or include dispatcher types in Spring Security (CVE-2022-31692) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * Apache CXF: SSRF Vulnerability (CVE-2022-46364) * Undertow: Infinite loop in SslConduit during close (CVE-2023-1108) * json-smart: Uncontrolled Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * spring-boot: Spring Boot Welcome Page DoS Vulnerability (CVE-2023-20883) * jakarta-commons-httpclient: missing connection hostname check against X.509 certificate name (CVE-2012-5783) * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * Moment.js: Path traversal in moment.locale (CVE-2022-24785) * batik: Server-	2023-06-29	2023-06-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * engine.io: Specially crafted HTTP request can trigger an uncaught exception (CVE-2022-41940) * postgresql-jdbc: Information leak of prepared statement data due to insecure temporary file permissions (CVE-2022-41946) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * Apache CXF: directory listing / code exfiltration (CVE-2022-46363) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * bouncycastle: potential blind LDAP injection attack using a self-signed certificate (CVE-2023-33201) * tomcat: JsonErrorReportValve injection (CVE-2022-45143) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		

Assessment

High | Due | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Due

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **56.90 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **1.92 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2022-25869

Description

All versions of the package angular; all versions of the package angularjs.core; all versions of the package angularjs are vulnerable to Cross-site Scripting (XSS) due to insecure page caching in the Internet Explorer browser, which allows interpolation of <textarea> elements.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-25869	2022-07-15	2025-07-28
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-25869	2022-07-15	2025-07-28

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Target	Hyperlink	Create Date	Update Date
CVE Details	https://www.cvedetails.com/cve/CVE-2022-25869	2022-07-15	2025-07-28

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
@angular/common	@angular/common-10.0.14	10.0.14

Weakness
CWE-79

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:3.1	NVD-CNA-NVD	6.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-prc3-vjfx-vhm9	Angular (deprecated package) Cross-site Scripting	2022-07-16	2022-07-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0021	Multiples vulnérabilités dans les produits IBM	2025-01-10	2025-01-10

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-0967_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM MQ ist eine Message Oriented Middleware von IBM. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in IBM MQ ausnutzen, um einen Denial of Service Angriff durchzuführen oder Cross-Site Scripting (XSS)-Angriffe durchzuführen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-04-24	2024-04-24
WID-SEC-W-2022-0701_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Angular ist ein TypeScript-basiertes Front-End-	2022-07-17	2022-07-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Webapplikationsframework. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Angular ausnutzen, um einen Cross-Site Scripting Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - MacOS X - Sonstiges - UNIX - Windows		
CVE-2022-25869_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-07-15	2022-07-15

Assessment Medium None In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **1.86 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **17.55 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	angular (ver. 10) is still supported by it's vendor with extended support. Support End Date: 4 years and 11 months ago Extended Support End Date: no date provided
Assessment	The vulnerability status is **in review**.

CVE-2022-25844

Description

The package angular after 1.7.0 are vulnerable to Regular Expression Denial of Service (ReDoS) by providing a custom locale rule that makes it possible to assign the parameter in posPre: ' '.repeat() of NUMBER_FORMATS.PATTERNS[1].posPre with a very high value. **Note:** 1) This package has been deprecated and is no longer maintained. 2) The vulnerable versions are 1.7.0 and higher.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-25844	2022-05-01	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-25844	2022-05-01	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2022-25844	2022-05-01	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
@angular/common	`@angular/common-10.0.14`	`10.0.14`

Weakness
CWE-1333

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-m2h2-264f-f486	angular vulnerable to regular expression denial of service (ReDoS)	2022-05-03	2022-05-03

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-1057	Multiples vulnérabilités dans les produits HPE Aruba Networking	2024-12-11	2024-12-11
CERTFR-2023-AVI-0245	Multiples vulnérabilités dans les produits IBM	2023-03-20	2023-03-20

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2022-0507_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Angular ist ein TypeScript-basiertes Front-End-Webapplikationsframework. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Angular ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2022-05-02	2022-05-02
CVE-2022-25844_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-05-01	2022-05-01
WID-SEC-W-2024-0967_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM MQ ist eine Message Oriented Middleware von IBM. # Angriff Ein entfernter, anonymer Angreifer kann mehrere	2024-04-24	2024-04-24

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Schwachstellen in IBM MQ ausnutzen, um einen Denial of Service Angriff durchzuführen oder Cross-Site Scripting (XSS)-Angriffe durchzuführen. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		

Assessment High Elevated In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.49 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **35.22 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	angular (ver. 10) is still supported by it's vendor with extended support. Support End Date: 4 years and 11 months ago Extended Support End Date: no date provided
Assessment	The vulnerability status is **in review**.

CVE-2022-22971

Description

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, application with a STOMP over WebSocket endpoint is vulnerable to a denial of service attack by an authenticated user.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-22971	2022-05-12	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-22971	2022-05-12	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2022-22971	2022-05-12	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Component	Artifact Id	Version
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	4.0	`AV:N/AC:L/Au:S/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	6.5	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-rqph-vqwm-22vc	Allocation of Resources Without Limits or Throttling in Spring Framework	2022-05-13	2022-05-13

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0034	Multiples vulnérabilités dans les produits Oracle	2023-01-18	2023-01-18
CERTFR-2022-AVI-454	Multiples vulnérabilités dans VMware Spring	2022-05-12	2022-05-12
CERTFR-2022-AVI-935	Multiples vulnérabilités dans Oracle WebLogic Server	2022-10-19	2022-10-19
CERTFR-2024-AVI-0240	Multiples vulnérabilités dans les produits IBM	2024-03-22	2024-03-22
CERTFR-2023-AVI-0276	Multiples vulnérabilités dans les produits IBM	2023-03-31	2023-03-31

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2023-1031_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-04-18	2023-04-18
WID-SEC-W-2023-0809_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. #	2023-03-30	2023-03-30

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um beliebigen Programmcode auszuführen, Informationen offenzulegen, Informationen falsch darzustellen, einen Denial of Service Zustand herbeizuführen, Sicherheitsvorkehrungen zu umgehen, einen Cross-Site-Scripting-Angriff durchzuführen oder unbekannte Auswirkungen zu verursachen. # Betroffene Betriebssysteme - Linux		
WID-SEC-W-2023-0126_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - MacOS X - UNIX - Windows	2023-01-17	2023-01-17
RHSA-2023:1661_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.11.0 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * WildFly: possible information disclosure (CVE-2022-1278) * jetty-http: improver hostname input handling (CVE-2022-2047) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-04-05	2023-04-05
WID-SEC-W-2022-0361_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, authentisierter Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2022-05-10	2022-05-10
RHSA-2023:3185_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.10.3 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * RESTEasy: creation of insecure temp files (CVE-2023-0482) For more details about the security issue(s), including the impact, a CVSS score,	2023-05-17	2023-05-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
CVE-2022-22971_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-05-11	2022-05-11
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-07-07	2022-07-07
WID-SEC-W-2023-0864_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung JBoss A-MQ ist eine Messaging-Plattform. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Red Hat JBoss A-MQ ausnutzen, um Informationen offenzulegen, Sicherheitsmaßnahmen zu umgehen und einen Denial-of-Service-Zustand zu verursachen. # Betroffene Betriebssysteme - UNIX - Linux	2023-04-05	2023-04-05
WID-SEC-W-2023-0138_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle	2023-01-17	2023-01-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows		
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-02-29	2024-02-29
WID-SEC-W-2023-1017_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-04-18	2023-04-18
WID-SEC-W-2023-0137_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2023-01-17	2023-01-17
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07
WID-SEC-W-2023-1809_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Enterprise Manager (OEM) ist ein Set von System Management Werkzeugen von Oracle für Oracle Umgebungen.	2023-07-18	2023-07-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Es beinhaltet Werkzeuge zum Monitoring von Oracle Umgebung und zur Automatisierung von Datenbank- und Applikations Administration. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Enterprise Manager ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows		

Assessment

Medium | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.38 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **41.39 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2022-22970

Description

In spring framework versions prior to 5.3.20+ , 5.2.22+ and old unsupported versions, applications that handle file uploads are vulnerable to DoS attack if they rely on data binding to set a MultipartFile or javax.servlet.Part to a field in a model object.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-22970	2022-05-12	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-22970	2022-05-12	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2022-22970	2022-05-12	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Component	Artifact Id	Version
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	3.5	AV:N/AC:M/Au:S/C:N/I:N/A:P	Low
CVSS:3.1	NVD-CNA-NVD	5.3	CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-hh26-6xwr-ggv7	Denial of service in Spring Framework	2022-05-13	2022-05-13

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-454	Multiples vulnérabilités dans VMware Spring	2022-05-12	2022-05-12
CERTFR-2022-AVI-626	Multiples vulnérabilités dans IBM i Modernization	2022-07-12	2022-07-12
CERTFR-2023-AVI-0418	Multiples vulnérabilités dans Zimbra	2023-05-30	2023-05-30
CERTFR-2024-AVI-0240	Multiples vulnérabilités dans les produits IBM	2024-03-22	2024-03-22
CERTFR-2023-AVI-0276	Multiples vulnérabilités dans les produits IBM	2023-03-31	2023-03-31
CERTFR-2023-AVI-0116	Multiples vulnérabilités dans les produits IBM	2023-02-13	2023-02-13

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2023-0809_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um beliebigen Programmcode auszuführen, Informationen offenzulegen, Informationen falsch darzustellen, einen Denial of Service Zustand herbeizuführen, Sicherheitsvorkehrungen	2023-03-30	2023-03-30

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	zu umgehen, einen Cross-Site-Scripting-Angriff durchzuführen oder unbekannte Auswirkungen zu verursachen. # Betroffene Betriebssysteme - Linux		
RHSA-2023:1661_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.11.0 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * WildFly: possible information disclosure (CVE-2022-1278) * jetty-http: improver hostname input handling (CVE-2022-2047) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-04-05	2023-04-05
WID-SEC-W-2022-0361_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, authentisierter Angreifer kann mehrere Schwachstellen in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2022-05-10	2022-05-10
RHSA-2023:3185_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.10.3 includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * keycloak: path traversal via double URL encoding (CVE-2022-3782) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * springframework: DoS via data binding to multipartFile or servlet part (CVE-2022-22970) * springframework: DoS with STOMP over WebSocket (CVE-2022-22971) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * RESTEasy: creation of insecure temp files (CVE-2023-0482) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2023-05-17	2023-05-17
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) *	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-0864_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung JBoss A-MQ ist eine Messaging-Plattform. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Red Hat JBoss A-MQ ausnutzen, um Informationen offenzulegen, Sicherheitsmaßnahmen zu umgehen und einen Denial-of-Service-Zustand zu verursachen. # Betroffene Betriebssysteme - UNIX - Linux	2023-04-05	2023-04-05
CVE-2022-22970_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-05-11	2022-05-11
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-02-29	2024-02-29
WID-SEC-W-2023-0137_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Communications umfasst branchenspezifische Lösungen für die Telekommunikationsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows	2023-01-17	2023-01-17
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX		

Assessment Medium None In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:N/A:H`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.18 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **59.53 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2022-22968

Description

In Spring Framework versions 5.3.0 - 5.3.18, 5.2.0 - 5.2.20, and older unsupported versions, the patterns for disallowedFields on a DataBinder are case sensitive which means a field is not effectively protected unless it is listed with both upper and lower case for the first character of the field, including upper and lower case for the first character of all nested fields within the property path.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-22968	2022-04-14	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-22968	2022-04-14	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2022-22968	2022-04-14	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-178

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	AV:N/AC:L/Au:N/C:N/I:P/A:N	Medium
CVSS:3.1	NVD-CNA-NVD	5.3	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-g5mm-vmx4-3rg7	Improper handling of case sensitivity in Spring Framework	2022-04-15	2022-04-15

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-655	Multiples vulnérabilités dans Oracle MySQL	2022-07-20	2022-07-20
CERTFR-2022-AVI-344	Vulnérabilité dans VMware Spring	2022-04-14	2022-04-14
CERTFR-2022-AVI-626	Multiples vulnérabilités dans IBM i Modernization	2022-07-12	2022-07-12
CERTFR-2022-AVI-935	Multiples vulnérabilités dans Oracle WebLogic Server	2022-10-19	2022-10-19
CERTFR-2022-AVI-539	Multiples vulnérabilités dans IBM DB2	2022-06-13	2022-06-13
CERTFR-2022-AVI-952	Multiples vulnérabilités dans IBM QRadar	2022-10-26	2022-10-26

Other

Id	Summary	Create Date	Update Date
RHSA-2022:5101_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.10.0 serves as a replacement for Red Hat AMQ Broker 7.9.4, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * nodejs-lodash: prototype pollution in defaultsDeep function leading to modifying properties (CVE-2019-10744) * amq: AMQ Broker Operator ClusterWide Edit	2022-06-16	2022-06-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Permissions Due Token Exposure (CVE-2022-1833) * jackson-databind: denial of service via a large depth of nested objects (CVE-2020-36518) * AMQ Broker: Malformed message can result in partial DoS (OOM) (CVE-2021-4040) * netty: control chars in header names may lead to HTTP request smuggling (CVE-2021-43797) * artemis-commons: Apache ActiveMQ Artemis DoS (CVE-2022-23913) * springframework: Spring Framework: Data Binding Rules Vulnerability (CVE-2022-22968) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2022-0735_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2022-07-19	2022-07-19
CVE-2022-22968_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-04-13	2022-04-13
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-02-29	2024-02-29
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07

Assessment

Medium **Elevated** **In Review**

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **22.75 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **4.30 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2022-22965

Description

A Spring MVC or Spring WebFlux application running on JDK 9+ may be vulnerable to remote code execution (RCE) via data binding. The specific exploit requires the application to run on Tomcat as a WAR deployment. If the application is deployed as a Spring Boot executable jar, i.e. the default, it is not vulnerable to the exploit. However, the nature of the vulnerability is more general, and there may be other ways to exploit it.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-22965	2022-04-01	2025-04-10
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-22965	2022-04-01	2025-04-10
CVE Details	https://www.cvedetails.com/cve/CVE-2022-22965	2022-04-01	2025-04-10

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Spring Framework	`spring-expression-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-context-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-aop-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-beans-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-jcl-5.3.14.jar`	`5.3.14`
Spring Framework	`spring-core-5.3.14.jar`	`5.3.14`

Weakness
CWE-94

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	7.5	`AV:N/AC:L/Au:N/C:P/I:P/A:P`	High
CVSS:3.1	NVD-CNA-NVD	9.8	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`	Critical

Advisories

Alerts

Id	Summary	Create Date	Update Date
CERT-EU-2022-023	UPDATE: Critical RCE Vulnerability in Spring Core	2022-03-31	2022-03-31
GHSA-36p3-wjmg-h94x	Remote Code Execution in Spring Framework	2022-03-31	2022-03-31
VU#970766	Spring Framework insecurely handles PropertyDescriptor objects with data binding	2022-03-31	2022-03-31

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07
CERTFR-2022-AVI-371	Multiples vulnérabilités dans les produits Cisco	2022-04-21	2022-04-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-472	Multiples vulnérabilités dans les produits IBM	2022-05-18	2022-05-18
CERTFR-2022-AVI-481	Multiples vulnérabilités dans les produits IBM	2022-05-20	2022-05-20
CERTFR-2022-AVI-716	Multiples vulnérabilités dans IBM Cloud Pak System	2022-08-09	2022-08-09
CERTFR-2022-AVI-307	Vulnérabilité dans VMware Tanzu	2022-04-04	2022-04-04
CERTFR-2022-AVI-456	Multiples vulnérabilités dans les produits SAP	2022-05-12	2022-05-12
CERTFR-2022-AVI-626	Multiples vulnérabilités dans IBM i Modernization	2022-07-12	2022-07-12
CERTFR-2022-AVI-572	Vulnérabilité dans les produits IBM	2022-06-21	2022-06-21
CERTFR-2022-AVI-568	Multiples vulnérabilités dans les produits IBM	2022-06-17	2022-06-17
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2022-AVI-376	Multiples vulnérabilités dans Fortinet FortiSOAR	2022-04-21	2022-04-21
CERTFR-2022-AVI-360	Vulnérabilité dans les produits Siemens	2022-04-20	2022-04-20
CERTFR-2022-AVI-928	Multiples vulnérabilités dans les produits IBM	2022-10-19	2022-10-19
CERTFR-2022-AVI-326	Multiples vulnérabilités dans les produits SolarWinds	2022-04-11	2022-04-11
CERTFR-2022-AVI-487	Multiples vulnérabilités dans les produits IBM	2022-05-23	2022-05-23
CERTFR-2022-AVI-494	Multiples vulnérabilités dans les produits IBM	2022-05-25	2022-05-25
CERTFR-2022-AVI-659	Multiples vulnérabilités dans Oracle WebLogic	2022-07-20	2022-07-20
CERTFR-2022-AVI-539	Multiples vulnérabilités dans IBM DB2	2022-06-13	2022-06-13
CERTFR-2022-AVI-345	Multiples vulnérabilités dans les produits SAP	2022-04-14	2022-04-14
CERTFR-2022-AVI-297	Vulnérabilité dans VMware Spring	2022-03-31	2022-03-31

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2023-0139_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2023-01-17	2023-01-17
WID-SEC-W-2023-1012_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Insurance Applications ist eine Produktfamilie mit Lösungen für die Versicherungsbranche. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Insurance Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-04-18	2023-04-18
RHSA-2022:1627_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms.	2022-04-27	2022-04-27

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	This release of Red Hat AMQ Broker 7.9.4 serves as a replacement for Red Hat AMQ Broker 7.9.3, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * spring-webmvc: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:1378_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This asynchronous security patch is an update to Red Hat Process Automation Manager 7. Security Fix(es): * spring-webmvc: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-14	2022-04-14
WID-SEC-W-2023-0016_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Tivoli Monitoring ist eine Systemüberwachungs-Software zum Managen von Betriebssystemen, Datenbanken und Servern in verteilten und Host-Umgebungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in IBM Tivoli Monitoring ausnutzen, um die Kontrolle über das System zu erlangen, vertrauliche Informationen offenzulegen, einen Denial of Service Zustand herbeizuführen, sowie weitere nicht spezifizierte Auswirkungen zu ereichen. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-03	2023-01-03
RHSA-2022:1360_Red Hat	This release of Red Hat Fuse 7.10.2 serves as a replacement for Red Hat Fuse 7.10.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * spring-webmvc: spring-framework: RCE via Data Binding on JDK 9+ [fuse-7] (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-13	2022-04-13
WID-SEC-W-2022-0033_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um beliebigen Programmcode mit den Rechten des Dienstes auszuführen. # Betroffene Betriebssysteme - CISCO Appliance - Linux - Sonstiges - UNIX - Windows	2022-03-30	2022-03-30
WID-SEC-W-2023-1016_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten	2023-04-18	2023-04-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Business Anwendungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows		
RHSA-2022:1333_Red Hat	A micro version update (from 1.6.4 to 1.6.5) is now available for Red Hat Camel K that includes CVE fixes in the base images, which are documented in the Release Notes document linked in the References section. Security Fix(es): * spring-beans: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-12	2022-04-12
RHSA-2022:1626_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.8.6 serves as a replacement for Red Hat AMQ Broker 7.8.5, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * spring-webmvc: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-27	2022-04-27
CVE-2022-22965_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-03-30	2022-03-30
WID-SEC-W-2022-0169_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - MacOS X - NetApp Appliance - UNIX - Windows	2022-04-19	2022-04-19
SSA-254054_Siemens	# Summary A vulnerability in Spring Framework was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2022-22965 and is also known as "Spring4Shell" or "SpringShell". Siemens has released updates for the affected products and recommends to update to the latest versions. # General Recommendations As a general security measure, Siemens strongly recommends to protect network access to devices with appropriate mechanisms. In order to operate the devices in a protected IT environment, Siemens recommends to configure the environment according to Siemens' operational guidelines for Industrial Security (Download: https://www.siemens.com/cert/operational-guidelines-industrial-security), and to follow the recommendations in the product manuals. Additional information on Industrial Security by Siemens can be found at: https://www.siemens.com/industrialsecurity # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To	2022-04-19	2022-04-19

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2022:1306_Red Hat	Red Hat Integration - Camel Extensions for Quarkus 2.2.1-1 serves as a replacement for 2.2.1 and includes the following security Fix(es): Security Fix(es): * spring-beans: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-02-29	2024-02-29
RHSA-2022:1379_Red Hat	Red Hat Decision Manager is an open source decision management platform that combines business rules management, complex event processing, Decision Model & Notation (DMN) execution, and business optimization for solving planning problems. It automates business decisions and makes that logic available to the entire business. This asynchronous security patch is an update to Red Hat Decision Manager 7. Security Fix(es): * spring-webmvc: spring-framework: RCE via Data Binding on JDK 9+ (CVE-2022-22965) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-14	2022-04-14
ICSA-22-286-05_CISA	# CISA Disclaimer This CSAF advisory was extracted from unstructured data and may contain inaccuracies. If you notice any errors, please reach out to the designated contact at CISA CSAF: central@cisa.dhs.gov # Legal Notice All information products included in https://us-cert.cisa.gov/ics are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see https://us-cert.cisa.gov/tlp/. # Risk evaluation Successful exploitation of these vulnerabilities could crash the Prognostic Model Executor and could allow remote code execution. # Critical infrastructure sectors Energy # Countries/areas deployed Worldwide # Company headquarters location Switzerland # Recommended Practices CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability these vulnerabilities. Specifically, users should: # Recommended Practices CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures. # Recommended Practices CISA also provides a section for control systems security recommended practices on the ICS webpage at cisa.gov/ics. Several CISA products detailing cyber defense best practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-	2022-10-13	2022-10-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Depth Strategies. # Recommended Practices Organizations observing suspected malicious activity should follow established internal procedures and report findings to CISA for tracking and correlation against other incidents. # Recommended Practices Additional mitigation guidance and recommended practices are publicly available on the ICS webpage at cisa.gov/ics in the technical information paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies. # Exploitability These vulnerabilities have a high attack complexity.		

Assessment Critical Escalate In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority Escalate

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
Keywords	**external attacker**
EPSS	This vulnerability has a **94.44 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **0.01 %** of all scored vulnerabilities.
KEV	This vulnerability, affecting **VMware Spring Framework**, has been **confirmed to have been exploited in the wild**. **Summary** **:** Spring Framework JDK 9+ Remote Code Execution Vulnerability . Apply updates per vendor instructions. **Notes** **:** https://nvd.nist.gov/vuln/detail/CVE-2022-22965 **Due Date** **:** 2022-04-25 **Publish Date** **:** 2022-04-04
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2022-22950

Description

n Spring Framework versions 5.3.0 - 5.3.16 and older unsupported versions, it is possible for a user to provide a specially crafted SpEL expression that may cause a denial of service condition.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2022-22950	2022-04-01	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2022-22950	2022-04-01	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2022-22950	2022-04-01	2024-11-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	4.0	AV:N/AC:L/Au:S/C:N/I:N/A:P	Medium
CVSS:3.1	NVD-CNA-NVD	6.5	CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-558x-2xjg-6232	Allocation of Resources Without Limits or Throttling in Spring Framework	2022-04-03	2022-04-03

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07
CERTFR-2022-AVI-626	Multiples vulnérabilités dans IBM i Modernization	2022-07-12	2022-07-12
CERTFR-2022-AVI-279	Vulnérabilité dans VMware Spring	2022-03-29	2022-03-29
CERTFR-2024-AVI-0240	Multiples vulnérabilités dans les produits IBM	2024-03-22	2024-03-22
CERTFR-2022-AVI-539	Multiples vulnérabilités dans IBM DB2	2022-06-13	2022-06-13

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2022-1035_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit	2022-03-28	2022-03-28

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Das Spring Framework bietet ein Entwicklungsmodell für Java mit Infrastrukturunterstützung auf Anwendungsebene. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in VMware Tanzu Spring Framework ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Linux - Sonstiges - UNIX - Windows		
RHSA-2022:5555_Red Hat	The ovirt-engine package provides the Red Hat Virtualization Manager, a centralized management platform that allows system administrators to view and manage virtual machines. The Manager provides a comprehensive range of features including search capabilities, resource management, live migrations, and virtual infrastructure provisioning. Security Fix(es): * nodejs-trim-newlines: ReDoS in .end() method (CVE-2021-33623) * apache-commons-compress: infinite loop when reading a specially crafted 7Z archive (CVE-2021-35515) * apache-commons-compress: excessive memory allocation when reading a specially crafted 7Z archive (CVE-2021-35516) * apache-commons-compress: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-35517) * apache-commons-compress: excessive memory allocation when reading a specially crafted ZIP archive (CVE-2021-36090) * nodejs-ansi-regex: Regular expression denial of service (ReDoS) matching ANSI escape codes (CVE-2021-3807) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * semantic-release: Masked secrets can be disclosed if they contain characters that are excluded from uri encoding (CVE-2022-31051) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. A list of bugs fixed in this update is available in the Technical Notes book: https://access.redhat.com/documentation/en-us/red_hat_virtualization/4.4/html-single/technical_notes	2022-07-14	2022-07-14
RHSA-2022:5903_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This asynchronous security patch is an update to Red Hat Process Automation Manager 7. Security Fix(es): * com.google.code.gson-gson: Deserialization of Untrusted Data in com.google.code.gson-gson (CVE-2022-25647) * jsoup: Crafted input may cause the jsoup HTML and XML parser to get stuck (CVE-2021-37714) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) * protobuf-java: potential DoS in the parsing procedure for binary data (CVE-2021-22569) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * wildfly-elytron: possible timing attack in ScramServer (CVE-2021-3642) * wildfly: incorrect JBOSS_LOCAL_USER challenge location may lead to giving access to all the local users (CVE-2021-3717) * ant: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-36373) * mysql-connector-java: unauthorized access to critical (CVE-2021-2471) * netty: control chars in header names may lead to HTTP request smuggling (CVE-2021-43797) * wildfly-core: Invalid Sensitivity Classification of Vault Expression (CVE-2021-3644) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-08-04	2022-08-04

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2022:8761_Red Hat	Red Hat support for Spring Boot provides an application platform that reduces the complexity of developing and operating applications (monoliths and microservices) for OpenShift as a containerized platform. This release of Red Hat support for Spring Boot 2.7.2 serves as a replacement for Red Hat support for Spring Boot 2.5.12, and includes security, bug fixes and enhancements. For more information, see the release notes listed in the References section. Security Fix(es): * reactor-netty: specific redirect configuration allows for a credentials leak (CVE-2020-5404) * kubernetes-client: Insecure deserialization in unmarshalYaml method (CVE-2021-4178) * protobuf-java: potential DoS in the parsing procedure for binary data (CVE-2021-22569) * undertow: potential security issue in flow control over HTTP/2 may lead to DOS(incomplete fix for CVE-2021-3629) (CVE-2022-1259) * undertow: Double AJP response for 400 from EAP 7 results in CPING failures (CVE-2022-1319) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-12-14	2022-12-14
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-07-07	2022-07-07
CVE-2022-22950_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2022-03-28	2022-03-28
WID-SEC-W-2024-0528_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich,	2024-02-29	2024-02-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Data Protection Advisor ist eine Monitoring Lösung. Der Collector ist der lokale Agent. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell Data Protection Advisor ausnutzen, um beliebigen Code auszuführen, einen Denial-of-Service-Zustand herbeizuführen, Dateien zu manipulieren, vertrauliche Informationen offenzulegen, seine Berechtigungen zu erweitern oder einen nicht spezifizierten Angriff durchzuführen. # Betroffene Betriebssysteme - Windows		
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07
WID-SEC-W-2023-1809_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Enterprise Manager (OEM) ist ein Set von System Management Werkzeugen von Oracle für Oracle Umgebungen. Es beinhaltet Werkzeuge zum Monitoring von Oracle Umgebung und zur Automatisierung von Datenbank- und Applikations Administration. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Enterprise Manager ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
ICSA-22-286-05_CISA	# CISA Disclaimer This CSAF advisory was extracted from unstructured data and may contain inaccuracies. If you notice any errors, please reach out to the designated contact at CISA CSAF: central@cisa.dhs.gov # Legal Notice All information products included in https://us-cert.cisa.gov/ics are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see https://us-cert.cisa.gov/tlp/. # Risk evaluation Successful exploitation of these vulnerabilities could crash the Prognostic Model Executor and could allow remote code execution. # Critical infrastructure sectors Energy # Countries/areas deployed Worldwide # Company headquarters location Switzerland # Recommended Practices CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability these vulnerabilities. Specifically, users should: # Recommended Practices CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures. # Recommended Practices CISA also provides a section for control systems security recommended practices on the ICS webpage at cisa.gov/ics. Several CISA products detailing cyber defense best practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-	2022-10-13	2022-10-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Depth Strategies. # Recommended Practices Organizations observing suspected malicious activity should follow established internal procedures and report findings to CISA for tracking and correlation against other incidents. # Recommended Practices Additional mitigation guidance and recommended practices are publicly available on the ICS webpage at cisa.gov/ics in the technical information paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies. # Exploitability These vulnerabilities have a high attack complexity.		

Assessment Medium Elevated In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **4.12 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **11.80 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

CVE-2021-45105

Description

Apache Log4j2 versions 2.0-alpha1 through 2.16.0 (excluding 2.12.3 and 2.3.1) did not protect from uncontrolled recursion from self-referential lookups. This allows an attacker with control over Thread Context Map data to cause a denial of service when a crafted string is interpreted. This issue was fixed in Log4j 2.17.0, 2.12.3, and 2.3.1.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-45105	2021-12-18	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-45105	2021-12-18	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-45105	2021-12-18	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Apache Log4j	`log4j-core-2.14.0.jar`	`2.14.0`

Weakness
CWE-20

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	4.3	`AV:N/AC:M/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	5.9	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H`	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
CERT-EU-2021-067	UPDATE: Java Logging Package RCE Vulnerability	2021-12-10	2021-12-10
GHSA-p6xc-xr62-6r2g	Apache Log4j2 vulnerable to Improper Input Validation and Uncontrolled Recursion	2021-12-18	2021-12-18
CERTFR-2021-ALE-022	[MaJ] Vulnérabilité dans Apache Log4j	2021-12-10	2021-12-10

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-1027	Multiples vulnérabilités dans IBM Db2	2022-11-14	2022-11-14
CERTFR-2022-AVI-526	Multiples vulnérabilités dans les produits IBM	2022-06-08	2022-06-08
CERTFR-2022-AVI-568	Multiples vulnérabilités dans les produits IBM	2022-06-17	2022-06-17
CERTFR-2022-AVI-717	Multiples vulnérabilités dans les produits Schneider	2022-08-09	2022-08-09
CERTFR-2022-AVI-125	Multiples vulnérabilités dans les produits SAP	2022-02-09	2022-02-09
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2022-AVI-570	Multiples vulnérabilités dans les produits IBM	2022-06-20	2022-06-20

Other

Id	Summary	Create Date	Update Date
SSA-479842_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging tool used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service	2021-12-21	2021-12-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	- also information disclosure and local (and potential remote) code execution. Furthermore, one additional denial of service vulnerability, CVE-2021-45105, was disclosed. The Siemens Energy Sensformer / Sensgear cloud service was affected by these vulnerabilities and has remediated them. No user actions are necessary. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2022:0205_Red Hat	Red Hat Data Grid is an in-memory, distributed, NoSQL datastore solution. It increases application response times and allows for dramatically improving performance while providing availability, reliability, and elastic scale. Data Grid 8.2.3 replaces Data Grid 8.2.2 and includes bug fixes and enhancements. Find out more about Data Grid 8.2.3 in the Release Notes [3]. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
CVE-2021-45105_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-12-18	2021-12-18
RHSA-2022:0083_Red Hat	This release of Red Hat build of Eclipse Vert.x 4.1.8 GA includes security updates. For more information, see the release notes listed in the References section. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0216_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This asynchronous patch is a security update for Red Hat JBoss Enterprise Application Platform 7.4. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2022:0043_Red Hat	Openshift Logging Bug Fix Release (5.2.5) Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-10	2022-01-10
RHSA-2022:0222_Red Hat	This update of Red Hat Integration - Camel Extensions for Quarkus serves as a replacement for 2.2 GA and includes the following security Fix(es): Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
WID-SEC-W-2022-0811_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache log4j ist ein Framework zum Loggen von Anwendungsmeldungen in Java. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache log4j ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - UNIX - Linux - MacOS X - Windows - CISCO Appliance - NetApp Appliance - Native Hypervisor - Applicance - Sonstiges - Hardware Appliance	2021-12-19	2021-12-19
RHSA-2022:0203_Red Hat	The releases of Red Hat Fuse 7.8.2, 7.9.1 and 7.10.1 serve as a patch to Red Hat Fuse on Karaf and Red Hat Fuse on Spring Boot and includes security fixes, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments,	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:1462_Red Hat	Red Hat Single Sign-On 7.5 is a standalone server, based on the Keycloak project, that provides authentication and standards-based single sign-on capabilities for web and mobile applications. This release of Red Hat Single Sign-On 7.5.2 on RHEL 7 serves as a replacement for Red Hat Single Sign-On 7.5.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-20	2022-04-20
RHSA-2022:1463_Red Hat	Red Hat Single Sign-On 7.5 is a standalone server, based on the Keycloak project, that provides authentication and standards-based single sign-on capabilities for web and mobile applications. This release of Red Hat Single Sign-On 7.5.2 on RHEL 8 serves as a replacement for Red Hat Single Sign-On 7.5.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-20	2022-04-20
SSA-501673_Siemens	# Summary Apache Log4j2 versions 2.0-alpha1 through 2.16.0 contain a vulnerability (CVE-2021-45105) that could allow attackers to cause a denial of service condition in affected applications [1]. This advisory informs about the impact of CVE-2021-45105 to Siemens products and the corresponding remediation and mitigation measures. The vulnerability is different from the JNDI lookup vulnerabilities, the impact of which is documented in SSA-661247 [2]. Currently, no products vulnerable to CVE-2021-45105 have been identified. Siemens is investigating to determine which products are affected and is continuously updating this advisory as more information becomes available. See section Additional Information for more details regarding the investigation status. [1] https://logging.apache.org/log4j/2.x/security.html [2] https://cert-portal.siemens.com/productcert/pdf/ssa-661247.pdf # General Recommendations As a general security measure, Siemens strongly recommends to protect network access to devices with appropriate mechanisms. In order to operate the devices in a protected IT environment, Siemens recommends to configure the environment according to Siemens' operational guidelines for Industrial Security (Download: https://www.siemens.com/cert/operational-guidelines-industrial-security), and to follow the recommendations in the product manuals. Additional information on Industrial Security by Siemens can be found at: https://www.siemens.com/industrialsecurity # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.	2021-12-19	2021-12-19

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2022:1297_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
RHSA-2022:0026_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. This advisory contains the RPM packages for Red Hat OpenShift Container Platform 4.6.53. See the following advisory for the container images for this release: https://access.redhat.com/errata/RHBA-2022:0025 Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-12	2022-01-12
RHSA-2022:1469_Red Hat	Red Hat Single Sign-On 7.5 is a standalone server, based on the Keycloak project, that provides authentication and standards-based single sign-on capabilities for web and mobile applications. This release of Red Hat Single Sign-On 7.5.2 serves as a replacement for Red Hat Single Sign-On 7.5.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-20	2022-04-20
WID-SEC-W-2023-0119_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Utilities Applications ist eine Produktfamilie mit branchenspezifischen Lösungen für Ver- und Entsorger. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Utilities Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-17	2023-01-17
RHSA-2022:0047_Red Hat	Openshift Logging Bug Fix Release (5.0.11) Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score,	2022-01-10	2022-01-10

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0223_Red Hat	A minor version update (from 1.6.2 to 1.6.3) is now available for Red Hat Camel K that includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2022:1299_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
RHSA-2022:0042_Red Hat	Openshift Logging Bug Fix Release (5.1.6) Security Fix(es): * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-10	2022-01-10
RHSA-2022:0219_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 1.6.6 serves as a replacement for Red Hat AMQ Streams 1.6.5, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * Kafka: Timing Attack Vulnerability for Apache Kafka Connect and Clients (CVE-2021-38153) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2022:1296_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3	2022-04-11	2022-04-11

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0044_Red Hat	OpenShift Logging Bug Fix Release (5.3.2) Security Fix(es): * rubygem-bundler: Dependencies of gems with explicit source may be installed from a different source (CVE-2020-36327) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-10	2022-01-10

Assessment

Medium **Elevated** **In Review**

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **65.10 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **1.57 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	log4j (ver. 2) is still supported by it's vendor. Support End Date: no date provided Vendor does not provide extended support for this product.
Assessment	The vulnerability status is **in review**.

CVE-2021-45046

Description

It was found that the fix to address CVE-2021-44228 in Apache Log4j 2.15.0 was incomplete in certain non-default configurations. This could allows attackers with control over Thread Context Map (MDC) input data when the logging configuration uses a non-default Pattern Layout with either a Context Lookup (for example, $${ctx:loginId}) or a Thread Context Map pattern (%X, %mdc, or %MDC) to craft malicious input data using a JNDI Lookup pattern resulting in an information leak and remote code execution in some environments and local code execution in all environments. Log4j

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

2.16.0 (Java 8) and 2.12.2 (Java 7) fix this issue by removing support for message lookup patterns and disabling JNDI functionality by default.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-45046	2021-12-14	2025-03-12
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-45046	2021-12-14	2025-03-12
CVE Details	https://www.cvedetails.com/cve/CVE-2021-45046	2021-12-14	2025-03-12

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Log4j	`log4j-core-2.14.0.jar`	`2.14.0`

Weakness

CWE-917

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.1	`AV:N/AC:H/Au:N/C:P/I:P/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	9.0	`CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H`	Critical

Advisories

Alerts

Id	Summary	Create Date	Update Date
VU#930724	Apache Log4j allows insecure JNDI lookups	2021-12-15	2021-12-15
CERT-EU-2021-076	Fortinet Critical Vulnerability	2021-12-18	2021-12-18
GHSA-7rjr-3q55-vv33	Incomplete fix for Apache Log4j vulnerability	2021-12-14	2021-12-14
CERT-EU-2021-075	VMWare Critical Vulnerability	2021-12-18	2021-12-18
CERT-EU-2021-067	UPDATE: Java Logging Package RCE Vulnerability	2021-12-10	2021-12-10
CERTFR-2021-ALE-022	[MaJ] Vulnérabilité dans Apache Log4j	2021-12-10	2021-12-10

Notices

Id	Summary	Create Date	Update Date
CERTFR-2021-AVI-951	Multiples vulnérabilités dans le noyau Linux de RedHat	2021-12-15	2021-12-15
CERTFR-2022-AVI-1027	Multiples vulnérabilités dans IBM Db2	2022-11-14	2022-11-14
CERTFR-2022-AVI-526	Multiples vulnérabilités dans les produits IBM	2022-06-08	2022-06-08

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-568	Multiples vulnérabilités dans les produits IBM	2022-06-17	2022-06-17
CERTFR-2022-AVI-717	Multiples vulnérabilités dans les produits Schneider	2022-08-09	2022-08-09
CERTFR-2022-AVI-124	Multiples vulnérabilités dans les produits Siemens	2022-02-09	2022-02-09
CERTFR-2022-AVI-125	Multiples vulnérabilités dans les produits SAP	2022-02-09	2022-02-09
CERTFR-2022-AVI-570	Multiples vulnérabilités dans les produits IBM	2022-06-20	2022-06-20

Other

Id	Summary	Create Date	Update Date
RHSA-2021:5127_Red Hat	Openshift Logging Security and Bug Fix Release (5.2.4) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
SSA-479842_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging tool used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Furthermore, one additional denial of service vulnerability, CVE-2021-45105, was disclosed. The Siemens Energy Sensformer / Sensgear cloud service was affected by these vulnerabilities and has remediated them. No user actions are necessary. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license	2021-12-21	2021-12-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2025:1747_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.12 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.3.11, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.12 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * velocity: arbitrary code execution when attacker is able to modify templates [eap-7.3.z] (CVE-2020-13936) * CXF: Apache CXF: directory listing / code exfiltration [eap-7.3.z] (CVE-2022-46363) * sshd-common: mina-sshd: Java unsafe deserialization vulnerability [eap-7.3.z] (CVE-2022-45047) * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value [eap-7.3.z] (CVE-2021-44228) * commons-text: apache-commons-text: variable interpolation RCE [eap-7.3.z] (CVE-2022-42889) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) [eap-7.3.z] (CVE-2021-45046) * org.jboss.hal-hal-parent: minimist: prototype pollution [eap-7.3.z] (CVE-2021-44906) * jackson-databind: use of deeply nested arrays [eap-7.3.z] (CVE-2022-42004) * snakeyaml: Constructor Deserialization Remote Code Execution [eap-7.3.z] (CVE-2022-1471) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS [eap-7.3.z] (CVE-2022-41881) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS [eap-7.3.z] (CVE-2022-42003) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos [eap-7.3.z] (CVE-2022-45693) * h2: Remote Code Execution in Console [eap-7.3.z] (CVE-2021-42392) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2025-02-24	2025-02-24
RHSA-2021:5137_Red Hat	Openshift Logging Bug Fix Release (5.0.10) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2022:0205_Red Hat	Red Hat Data Grid is an in-memory, distributed, NoSQL datastore solution. It increases application response times and allows for dramatically improving performance while providing availability, reliability, and elastic scale. Data Grid 8.2.3 replaces Data Grid 8.2.2 and includes bug fixes and enhancements. Find out more about Data Grid 8.2.3 in the Release Notes [3]. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2022:0083_Red Hat	This release of Red Hat build of Eclipse Vert.x 4.1.8 GA includes security updates. For more information, see the release notes listed in the References section. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
SSA-714170_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging library used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens Energy is preparing updates and recommends specific countermeasures for SPPA-T3000. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.	2021-12-16	2021-12-16
WID-SEC-W-2022-0352_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache log4j ist ein Framework zum Loggen von	2021-12-14	2021-12-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Anwendungsmeldungen in Java. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache log4j ausnutzen, um beliebigen Code auszuführen. # Betroffene Betriebssysteme - Appliance - CISCO Appliance - Hardware Appliance - Juniper Appliance - Linux - Native Hypervisor - NetApp Appliance - Sonstiges - UNIX - Windows		
RHSA-2022:0216_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This asynchronous patch is a security update for Red Hat JBoss Enterprise Application Platform 7.4. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2021:5094_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2025:1746_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.1.9 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.1.8, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.1.9 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS [eap-7.1.z] (CVE-2022-41881) * velocity: arbitrary code execution when attacker is able to modify templates [eap-7.1.z] (CVE-2020-13936) * jackson-databind: mishandles the interaction between serialization gadgets and typing which could result in remote command execution [eap-7.1.z] (CVE-2020-10673) * jackson-databind: Serialization gadgets in anteros-core [eap-7.1.z] (CVE-2020-9548) * jackson-databind: mishandles the interaction between serialization gadgets and typing which could result in remote command execution [eap-7.1.z] (CVE-2020-10672) * wildfly: incorrect JBOSS_LOCAL_USER challenge location may lead to giving access to all the local users [eap-7.1.z] (CVE-2021-3717) * jackson-databind: Serialization gadgets in ibatis-sqlmap [eap-7.1.z] (CVE-2020-9547) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) [eap-7.1.z] (CVE-2021-45046) * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value [eap-7.1.z] (CVE-2021-44228) * jackson-databind: Serialization gadgets in shaded-hikari-config [eap-7.1.z] (CVE-2020-9546) * CXF: Apache CXF: directory listing / code exfiltration [eap-7.1.z] (CVE-2022-46363) * sshd-common: mina-sshd: Java unsafe deserialization vulnerability [eap-7.1.z] (CVE-2022-45047) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos [eap-7.1.z] (CVE-2022-45693) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS [eap-7.1.z] (CVE-2022-42003) * jackson-databind: use of deeply nested arrays [eap-7.1.z] (CVE-2022-42004) * jackson-databind: Lacks certain xbean-reflect/JNDI blocking [eap-7.1.z] (CVE-2020-8840)	2025-02-24	2025-02-24

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* snakeyaml: Constructor Deserialization Remote Code Execution [eap-7.1.z] (CVE-2022-1471) * commons-text: apache-commons-text: variable interpolation RCE [eap-7.1.z] (CVE-2022-42889) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:5128_Red Hat	Openshift Logging Security and Bug Fix Release (5.1.5) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2022:0222_Red Hat	This update of Red Hat Integration - Camel Extensions for Quarkus serves as a replacement for 2.2 GA and includes the following security Fix(es): Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
CVE-2021-45046_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-12-14	2021-12-14
RHSA-2022:0203_Red Hat	The releases of Red Hat Fuse 7.8.2, 7.9.1 and 7.10.1 serve as a patch to Red Hat Fuse on Karaf and Red Hat Fuse on Spring Boot and includes security fixes, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2021:5141_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-16	2021-12-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2021:5129_Red Hat	Openshift Logging Security and Bug Fix Release (5.3.1) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2022:1297_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
RHSA-2021:5108_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5106_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-16	2021-12-16
WID-SEC-W-2023-0063_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Junos Space ist eine Software-Plattform, die eine Reihe von Applikationen für das Netzwerkmanagement beinhaltet. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Juniper Junos Space ausnutzen, um Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen	2022-01-12	2022-01-12

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	offenzulegen, einen Denial-of-Service-Zustand auszulösen, beliebigen Code auszuführen und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Juniper Appliance		
SSA-661247_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging tool used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens is currently investigating to determine which products are affected and is continuously updating this advisory as more information becomes available. See section Additional Information for more details regarding the investigation status. Note: two additional vulnerabilities were published for Apache Log4j, the impact of which are documented in SSA-501673: https://cert- portal.siemens.com/productcert/pdf/ssa-501673.pdf (CVE-2021-45105) and SSA-784507: https://cert-portal.siemens.com/productcert/pdf/ssa-784507.pdf (CVE-2021-44832). # General Recommendations As a general security measure, Siemens strongly recommends to protect network access to devices with appropriate mechanisms. In order to operate the devices in a protected IT environment, Siemens recommends to configure the environment according to Siemens' operational guidelines for Industrial Security (Download: https://www.siemens.com/cert/operational-guidelines-industrial- security), and to follow the recommendations in the product manuals. Additional information on Industrial Security by Siemens can be found at: https://www.siemens.com/industrialsecurity # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.	2021-12-13	2021-12-13
RHSA-2021:5148_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-15	2021-12-15
RHSA-2022:0223_Red Hat	A minor version update (from 1.6.2 to 1.6.3) is now available for Red Hat Camel K that includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: remote code execution via JDBC	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0138_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 2.0.0 serves as a replacement for Red Hat AMQ Streams 1.8.4, and includes security and bug fixes, and enhancements. Security Fix(es): * jetty: crafted URIs allow bypassing security constraints (CVE-2021-34429) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) * Kafka: Timing Attack Vulnerability for Apache Kafka Connect and Clients (CVE-2021-38153) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-13	2022-01-13
RHSA-2022:1299_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
SSA-397453_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging library used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens Energy is preparing updates and recommends specific countermeasures for TraceAlertServerPLUS.	2021-12-20	2021-12-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	# General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2022:1296_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
RHSA-2021:5107_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including	2021-12-16	2021-12-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		

Assessment Critical None Not Applicable

Rationale
Vulnerable configuration (context lookup or MDC) not used in application context.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:H`
Keywords	**external attacker**
EPSS	This vulnerability has a **94.34 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **0.05 %** of all scored vulnerabilities.
KEV	This vulnerability, affecting **Apache Log4j2**, has been **confirmed to have been exploited in the wild**. Furthermore, it has been **identified in ransomware campaigns**. **Summary** **:** Apache Log4j2 Deserialization of Untrusted Data Vulnerability . Apply updates per vendor instructions. **Notes** **:** https://logging.apache.org/log4j/2.x/security.html; https://nvd.nist.gov/vuln/detail/CVE-2021-45046 **Due Date** **:** 2023-05-22 **Publish Date** **:** 2023-05-01
EOL	log4j (ver. 2) is still supported by it's vendor. Support End Date: no date provided Vendor does not provide extended support for this product.
Assessment	The vulnerability status is **not applicable**.

CVE-2021-44832

Description

Apache Log4j2 versions 2.0-beta7 through 2.17.0 (excluding security fix releases 2.3.2 and 2.12.4) are vulnerable to a remote code execution (RCE) attack when a configuration uses a JDBC Appender with a JNDI LDAP data source URI when an attacker has control of the target LDAP server. This issue is fixed by limiting JNDI data source names to the java protocol in Log4j2 versions 2.17.1, 2.12.4, and 2.3.2.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-44832	2021-12-28	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-44832	2021-12-28	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-44832	2021-12-28	2024-11-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Apache Log4j	log4j-core-2.14.0.jar	2.14.0

Weakness
CWE-20

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	8.5	AV:N/AC:M/Au:S/C:C/I:C/A:C	High
CVSS:3.1	NVD-CNA-NVD	6.6	CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-8489-44mv-ggj8	Improper Input Validation and Injection in Apache Log4j2	2022-01-04	2022-01-04
CERT-EU-2021-067	UPDATE: Java Logging Package RCE Vulnerability	2021-12-10	2021-12-10
CERTFR-2021-ALE-022	[MaJ] Vulnérabilité dans Apache Log4j	2021-12-10	2021-12-10

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-933	Multiples vulnérabilités dans Oracle Systems	2022-10-19	2022-10-19
CERTFR-2022-AVI-1027	Multiples vulnérabilités dans IBM Db2	2022-11-14	2022-11-14
CERTFR-2022-AVI-526	Multiples vulnérabilités dans les produits IBM	2022-06-08	2022-06-08
CERTFR-2022-AVI-960	Multiples vulnérabilités dans les produits IBM	2022-10-27	2022-10-27
CERTFR-2022-AVI-056	Multiples vulnérabilités dans Oracle WebLogic Server	2022-01-19	2022-01-19
CERTFR-2022-AVI-717	Multiples vulnérabilités dans les produits Schneider	2022-08-09	2022-08-09
CERTFR-2024-AVI-0027	Multiples vulnérabilités dans les produits Juniper Networks	2024-01-11	2024-01-11
CERTFR-2022-AVI-125	Multiples vulnérabilités dans les produits SAP	2022-02-09	2022-02-09
CERTFR-2022-AVI-366	Multiples vulnérabilités dans Oracle PeopleSoft	2022-04-20	2022-04-20
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2022-AVI-345	Multiples vulnérabilités dans les produits SAP	2022-04-14	2022-04-14
CERTFR-2022-AVI-205	Multiples vulnérabilités dans les produits IBM	2022-03-04	2022-03-04

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2023-1031_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Retail Applications ist eine Sammlung von Produkten zur Unterstützung u. a. von Handelsfirmen und der Gastronomie. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Retail Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows - Sonstiges	2023-04-18	2023-04-18
RHSA-2022:0205_Red Hat	Red Hat Data Grid is an in-memory, distributed, NoSQL datastore solution. It increases application response times and allows for dramatically improving performance while providing availability, reliability, and elastic scale. Data Grid 8.2.3 replaces Data Grid 8.2.2 and includes bug fixes and enhancements. Find out more about Data Grid 8.2.3 in the Release Notes [3]. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2022:0230_Red Hat	OpenShift Logging Bug Fix Release (5.2.6) Security Fix(es): * nodejs-ua-parser-js: ReDoS via malicious User-Agent header (CVE-2021-27292) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832)	2022-01-21	2022-01-21
WID-SEC-W-2024-0064_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung JUNOS ist das "Juniper Network Operating System", das in Juniper Appliances verwendet wird. SRX Series Services Gateways ist ein Next-Generation Anti-Threat Firewall von Juniper. Bei den Switches der Juniper EX-Serie handelt es sich um Access- und Aggregations-/Core-Layer-Switches. Die Switches der QFX-Serie von Juniper sichern und automatisieren Netzwerke in Rechenzentren. Die Juniper MX-Serie ist eine Produktfamilie von Routern. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter, anonymer, authentisierter, lokaler oder physischer Angreifer kann mehrere Schwachstellen in Juniper JUNOS, Juniper JUNOS Evolved, Juniper SRX Series, Juniper EX Series, Juniper QFX Series, Juniper ACX Series, Juniper PTX Series und Juniper MX Series ausnutzen, um beliebigen Code auszuführen, Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen, einen Denial-of-Service-Zustand herbeizuführen und seine Berechtigungen zu erweitern. # Betroffene Betriebssysteme - Appliance - BIOS/Firmware	2024-01-10	2024-01-10
RHSA-2022:0083_Red Hat	This release of Red Hat build of Eclipse Vert.x 4.1.8 GA includes security updates. For more information, see the release notes listed in the References section. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0493_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. This advisory contains the RPM packages for Red Hat OpenShift Container Platform 4.7.43. See the following advisory for the container images for this release: https://access.redhat.com/errata/RHSA-2022:0492 Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. All OpenShift Container Platform 4.7 users are advised to upgrade to these updated packages and images when they are available in the appropriate release channel. To check for available updates, use the OpenShift Console or the CLI oc command. Instructions for upgrading a cluster are available at https://docs.openshift.com/container-platform/4.7/updating/updating-cluster-cli.html	2022-02-16	2022-02-16
WID-SEC-W-2023-0123_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Siebel CRM ist eine CRM-Lösung von Oracle. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Siebel CRM ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-17	2023-01-17
SSA-784507_Siemens	# Summary Apache Log4j2 versions 2.0-beta7 through 2.17.0 (excluding security fix releases 2.3.2 and 2.12.4) contain a vulnerability (CVE-2021-44832) that could allow an attacker with permission to modify the logging configuration file to execute arbitrary code, when the JDBC Appender is used [1]. This advisory informs about the impact of CVE-2021-44832 to Siemens products and the corresponding remediation and mitigation measures. The vulnerability is different from other JNDI lookup vulnerabilities, the impact of which is documented in SSA-661247 [2]. Currently, no products vulnerable to CVE-2021-44832 have been identified. Siemens is investigating to determine which products are affected and is continuously updating this advisory as more information becomes available. See section Additional Information for more details regarding the investigation status. [1] https://logging.apache.org/log4j/2.x/security.html [2] https://cert-portal.siemens.com/productcert/pdf/ssa-661247.pdf # General Recommendations As a general security measure, Siemens strongly recommends to protect network access to devices with appropriate mechanisms. In order to operate the devices in a protected IT environment, Siemens recommends to configure the environment according to Siemens' operational guidelines for Industrial Security (Download: https://www.siemens.com/cert/operational-guidelines-industrial-security), and to follow the recommendations in the product manuals. Additional information on Industrial Security by Siemens can be found at: https://www.siemens.com/industrialsecurity # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements	2021-12-28	2021-12-28

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2022:0226_Red Hat	OpenShift Logging Bug Fix Release (5.1.7) Security Fix(es): * nodejs-ua-parser-js: ReDoS via malicious User-Agent header (CVE-2021-27292) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832)	2022-01-20	2022-01-20
RHSA-2022:0227_Red Hat	Openshift Logging Bug Fix Release (5.3.3) Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * nodejs-ua-parser-js: ReDoS via malicious User-Agent header (CVE-2021-27292)	2022-01-20	2022-01-20
RHSA-2022:0216_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This asynchronous patch is a security update for Red Hat JBoss Enterprise Application Platform 7.4. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
WID-SEC-W-2023-0122_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Oracle Supply Chain ist eine Sammlung von Applikationen für verschiedene Zwecke. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Supply Chain ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-17	2023-01-17
WID-SEC-W-2022-0197_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache log4j ist ein Framework zum Loggen von Anwendungsmeldungen in Java. # Angriff Ein entfernter, authentisierter Angreifer kann eine Schwachstelle in Apache log4j ausnutzen, um beliebigen Programmcode auszuführen. # Betroffene Betriebssysteme - UNIX - Linux - Windows - CISCO Appliance - Sonstiges	2021-12-28	2021-12-28
RHSA-2022:0222_Red Hat	This update of Red Hat Integration - Camel Extensions for Quarkus serves as a replacement for 2.2 GA and includes the following security Fix(es): Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-2180_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2022-04-19	2022-04-19
RHSA-2022:0467_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 1.6.7 serves as a replacement for Red Hat AMQ Streams 1.6.6, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * kubernetes-client: Insecure deserialization in unmarshalYaml method (CVE-2021-4178) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-02-08	2022-02-08
RHSA-2022:0181_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. This advisory contains the RPM packages for Red Hat OpenShift Container Platform 4.6.54. See the following advisory for the container images for this release: https://access.redhat.com/errata/RHBA-2022:0180 Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. All OpenShift Container Platform 4.6 users are advised to upgrade to these updated packages and images when they are available in the appropriate release channel. To check for available updates, use the OpenShift Console or the CLI oc command. Instructions for upgrading a cluster are available at https://docs.openshift.com/container-platform/4.6/updating/updating-cluster-between-minor.html#understanding-upgrade-channels_updating-cluster-between-minor	2022-01-27	2022-01-27
RHSA-2022:0203_Red Hat	The releases of Red Hat Fuse 7.8.2, 7.9.1 and 7.10.1 serve as a patch to Red Hat Fuse on Karaf and Red Hat Fuse on Spring Boot and includes security fixes, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
RHSA-2022:0236_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-25	2022-01-25
RHSA-2022:1297_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
WID-SEC-W-2022-0169_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung MySQL ist ein Open Source Datenbankserver von Oracle. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle MySQL ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - MacOS X - NetApp Appliance - UNIX - Windows	2022-04-19	2022-04-19
RHSA-2022:0485_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. This advisory contains the RPM packages for Red Hat OpenShift Container Platform 4.8.31. See the following advisory for the container images for this release: https://access.redhat.com/errata/RHBA-2022:0484 Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. All OpenShift Container Platform 4.8 users are advised to upgrade to these updated packages and images when they are available in the appropriate release channel. To check for available updates, use the OpenShift Console or the CLI oc command. Instructions for upgrading a cluster are available at https://docs.openshift.com/container-platform/4.8/updating/updating-cluster-cli.html	2022-02-16	2022-02-16
RHSA-2022:0223_Red Hat	A minor version update (from 1.6.2 to 1.6.3) is now available for Red Hat Camel K that includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for	2022-01-20	2022-01-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2022:0138_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 2.0.0 serves as a replacement for Red Hat AMQ Streams 1.8.4, and includes security and bug fixes, and enhancements. Security Fix(es): * jetty: crafted URIs allow bypassing security constraints (CVE-2021-34429) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) * Kafka: Timing Attack Vulnerability for Apache Kafka Connect and Clients (CVE-2021-38153) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-13	2022-01-13
RHSA-2022:0225_Red Hat	Openshift Logging Bug Fix Release (5.0.12) Security Fix(es): * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832)	2022-01-20	2022-01-20
RHSA-2022:1299_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-04-11	2022-04-11
RHSA-2022:1296_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.4.4 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.4.3 and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.4.4 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * log4j: SQL injection in Log4j 1.x when application is configured to use JDBCAppender (CVE-2022-23305) * log4j: Unsafe deserialization flaw in Chainsaw log viewer (CVE-2022-23307) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern	2022-04-11	2022-04-11

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	(incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSSink (CVE-2022-23302) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-1524_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM Spectrum Protect ist eine zentralisierte Backuplösung für Systeme im Netzwerk. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in IBM Spectrum Protect Plus ausnutzen, um einen Denial-of-Service-Zustand zu verursachen, seine Privilegien zu erweitern, Sicherheitsmaßnahmen zu umgehen und beliebigen Code auszuführen. # Betroffene Betriebssysteme - Linux	2022-01-31	2022-01-31
CVE-2021-44832_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-12-28	2021-12-28

Assessment Medium Due In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority Due

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:H`
Keywords	**external attacker**
EPSS	This vulnerability has a **35.23 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **3.07 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	log4j (ver. 2) is still supported by it's vendor. Support End Date: no date provided Vendor does not provide extended support for this product.
Assessment	The vulnerability status is **in review**.

CVE-2021-44228

Description

Apache Log4j2 2.0-beta9 through 2.15.0 (excluding security releases 2.12.2, 2.12.3, and 2.3.1) JNDI features used in configuration, log messages, and parameters do not protect against attacker controlled LDAP and other JNDI related endpoints. An attacker who can control log messages or log message parameters can execute arbitrary code loaded from LDAP servers when message lookup substitution is enabled. From log4j 2.15.0, this behavior has been disabled by default.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

From version 2.16.0 (along with 2.12.2, 2.12.3, and 2.3.1), this functionality has been completely removed. Note that this vulnerability is specific to log4j-core and does not affect log4net, log4cxx, or other Apache Logging Services projects.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-44228	2021-12-10	2025-08-08
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-44228	2021-12-10	2025-08-08
CVE Details	https://www.cvedetails.com/cve/CVE-2021-44228	2021-12-10	2025-08-08

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Log4j	`log4j-core-2.14.0.jar`	`2.14.0`

Weakness

CWE-20, CWE-917

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	9.3	`AV:N/AC:M/Au:N/C:C/I:C/A:C`	Critical
CVSS:3.1	NVD-CNA-NVD	10.0	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H`	Critical

Advisories

Alerts

Id	Summary	Create Date	Update Date
VU#930724	Apache Log4j allows insecure JNDI lookups	2021-12-15	2021-12-15
CERT-EU-2021-076	Fortinet Critical Vulnerability	2021-12-18	2021-12-18
CERT-EU-2021-075	VMWare Critical Vulnerability	2021-12-18	2021-12-18
CERT-EU-2021-073	Adobe ColdFusion Critical Vulnerability	2021-12-17	2021-12-17
CERT-EU-2021-072	ArcGIS Critical Vulnerability	2021-12-16	2021-12-16
CERT-EU-2022-005	Critical Vulnerability in Ivanti Products	2022-01-19	2022-01-19
CERT-EU-2021-067	UPDATE: Java Logging Package RCE Vulnerability	2021-12-10	2021-12-10
GHSA-jfh8-c2jp-5v3q	Remote code injection in Log4j	2021-12-10	2021-12-10
CERT-EU-2021-071	UPDATE: Palo Alto Critical Vulnerability	2021-12-16	2021-12-16
CERT-EU-2021-074	CISCO Critical Vulnerability	2021-12-18	2021-12-18
CERTFR-2021-ALE-022	[MaJ] Vulnérabilité dans Apache Log4j	2021-12-10	2021-12-10

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERT-EU-2021-070	MobileIron Critical Vulnerability	2021-12-16	2021-12-16

Notices

Id	Summary	Create Date	Update Date
CERTFR-2021-AVI-951	Multiples vulnérabilités dans le noyau Linux de RedHat	2021-12-15	2021-12-15
CERTFR-2021-AVI-953	Multiples vulnérabilités dans les produits Schneider	2021-12-15	2021-12-15
CERTFR-2022-AVI-016	Multiples vulnérabilités dans les produits SAP	2022-01-11	2022-01-11
CERTFR-2022-AVI-568	Multiples vulnérabilités dans les produits IBM	2022-06-17	2022-06-17
CERTFR-2024-AVI-0027	Multiples vulnérabilités dans les produits Juniper Networks	2024-01-11	2024-01-11
CERTFR-2022-AVI-125	Multiples vulnérabilités dans les produits SAP	2022-02-09	2022-02-09
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2022-AVI-570	Multiples vulnérabilités dans les produits IBM	2022-06-20	2022-06-20
CERTFR-2022-AVI-1027	Multiples vulnérabilités dans IBM Db2	2022-11-14	2022-11-14
CERTFR-2022-AVI-526	Multiples vulnérabilités dans les produits IBM	2022-06-08	2022-06-08
CERTFR-2022-AVI-243	Multiples vulnérabilités dans les produits Apple	2022-03-15	2022-03-15
CERTFR-2022-AVI-717	Multiples vulnérabilités dans les produits Schneider	2022-08-09	2022-08-09
CERTFR-2022-AVI-124	Multiples vulnérabilités dans les produits Siemens	2022-02-09	2022-02-09

Other

Id	Summary	Create Date	Update Date
RHSA-2021:5133_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 1.6.5 serves as a replacement for Red Hat AMQ Streams 1.6.4, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5137_Red Hat	Openshift Logging Bug Fix Release (5.0.10) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5094_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5126_Red Hat	This update of Red Hat Integration - Camel Extensions for Quarkus serves as a replacement for 2.2 GA and includes the following security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs	2021-12-14	2021-12-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:5138_Red Hat	Red Hat AMQ Streams, based on the Apache Kafka project, offers a distributed backbone that allows microservices and other applications to share data with extremely high throughput and extremely low latency. This release of Red Hat AMQ Streams 1.8.4 serves as a replacement for Red Hat AMQ Streams 1.8.0, and includes security and bug fixes, and enhancements. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5129_Red Hat	Openshift Logging Security and Bug Fix Release (5.3.1) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5108_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5106_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-16	2021-12-16
RHSA-2021:5148_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-15	2021-12-15
RHSA-2022:0296_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This release of Red Hat Process Automation Manager 7.12.0 serves as an update to Red Hat Process Automation	2022-01-26	2022-01-26

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Manager 7.11.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * jackson-dataformat-cbor: Unchecked allocation of byte buffer can cause a java.lang.OutOfMemoryError exception (CVE-2020-28491) * kubernetes-client: fabric8-kubernetes-client: vulnerable to a path traversal leading to integrity and availability compromise (CVE-2021-20218) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.corba.* (CVE-2021-39149) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.jndi.ldap.LdapBindingEnumeration (CVE-2021-39145) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.jndi.ldap.LdapBindingEnumeration (CVE-2021-39151) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.jndi.ldap.LdapSearchEnumeration (CVE-2021-39147) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.jndi.toolkit.dir.ContextEnumerator (CVE-2021-39148) * xstream: Arbitrary code execution via unsafe deserialization of com.sun.xml.internal.ws.client.sei.* (CVE-2021-39141) * xstream: Arbitrary code execution via unsafe deserialization of javax.swing.UIDefaults$ProxyLazyValue (CVE-2021-39146) * xstream: Arbitrary code execution via unsafe deserialization of javax.swing.UIDefaults$ProxyLazyValue (CVE-2021-39154) * xstream: Arbitrary code execution via unsafe deserialization of sun.tracing.* (CVE-2021-39144) * xstream: Arbitrary code execution via unsafe deserialization of Xalan xsltc.trax.TemplatesImpl (CVE-2021-39139) * xstream: Arbitrary code execution via unsafe deserialization of Xalan xsltc.trax.TemplatesImpl (CVE-2021-39153) * xstream: Infinite loop DoS via unsafe deserialization of sun.reflect.annotation.AnnotationInvocationHandler (CVE-2021-39140) * xstream: remote command execution attack by manipulating the processed input stream (CVE-2021-29505) * xstream: Server-side request forgery (SSRF) via unsafe deserialization of com.sun.xml.internal.ws.client.sei.* (CVE-2021-39150) * xstream: Server-side request forgery (SSRF) via unsafe deserialization of jdk.nashorn.internal.runtime.Source$URLData (CVE-2021-39152) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:5140_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This asynchronous patch is a security update for Red Hat JBoss Enterprise Application Platform 7.4. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, and other related information, see the CVE page(s) listed in the References section.	2021-12-15	2021-12-15
RHSA-2021:5127_Red Hat	Openshift Logging Security and Bug Fix Release (5.2.4) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
SSA-479842_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging tool used in many Java-based applications) was disclosed, that could	2021-12-21	2021-12-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Furthermore, one additional denial of service vulnerability, CVE-2021-45105, was disclosed. The Siemens Energy Sensformer / Sensgear cloud service was affected by these vulnerabilities and has remediated them. No user actions are necessary. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2025:1747_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.12 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.3.11, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.12 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * velocity: arbitrary code execution when attacker is able to modify templates [eap-7.3.z] (CVE-2020-13936) * CXF: Apache CXF: directory listing / code exfiltration [eap-7.3.z] (CVE-2022-46363) * sshd-common: mina-sshd: Java unsafe deserialization vulnerability [eap-7.3.z] (CVE-2022-45047) * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value [eap-7.3.z] (CVE-2021-44228) * commons-text: apache-commons-text: variable interpolation RCE [eap-7.3.z] (CVE-2022-42889) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) [eap-7.3.z]	2025-02-24	2025-02-24

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	(CVE-2021-45046) * org.jboss.hal-hal-parent: minimist: prototype pollution [eap-7.3.z] (CVE-2021-44906) * jackson-databind: use of deeply nested arrays [eap-7.3.z] (CVE-2022-42004) * snakeyaml: Constructor Deserialization Remote Code Execution [eap-7.3.z] (CVE-2022-1471) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS [eap-7.3.z] (CVE-2022-41881) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS [eap-7.3.z] (CVE-2022-42003) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos [eap-7.3.z] (CVE-2022-45693) * h2: Remote Code Execution in Console [eap-7.3.z] (CVE-2021-42392) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:5093_Red Hat	This release of Red Hat build of Eclipse Vert.x 4.1.5 SP1 includes security updates. For more information, see the release notes listed in the References section. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issues and their impact, the CVSS score, acknowledgements, and other related information, see the CVE pages listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5130_Red Hat	A minor version update (from 1.6.1 to 1.6.2) is now available for Red Hat Camel K that includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
WID-SEC-W-2024-0064_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung JUNOS ist das "Juniper Network Operating System", das in Juniper Appliances verwendet wird. SRX Series Services Gateways ist ein Next-Generation Anti-Threat Firewall von Juniper. Bei den Switches der Juniper EX-Serie handelt es sich um Access- und Aggregations-/Core-Layer-Switches. Die Switches der QFX-Serie von Juniper sichern und automatisieren Netzwerke in Rechenzentren. Die Juniper MX-Serie ist eine Produktfamilie von Routern. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter, anonymer, authentisierter, lokaler oder physischer Angreifer kann mehrere Schwachstellen in Juniper JUNOS, Juniper JUNOS Evolved, Juniper SRX Series, Juniper EX Series, Juniper QFX Series, Juniper ACX Series, Juniper PTX Series und Juniper MX Series ausnutzen, um beliebigen Code auszuführen, Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen, einen Denial-of-Service-Zustand herbeizuführen und seine Berechtigungen zu erweitern. # Betroffene Betriebssysteme - Appliance - BIOS/Firmware	2024-01-10	2024-01-10
SSA-714170_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging library used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified	2021-12-16	2021-12-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens Energy is preparing updates and recommends specific countermeasures for SPPA-T3000. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
SCA-2021-0003_sick	# General Security Measures As general security measures, SICK recommends to minimize network exposure of the devices, restrict network access and follow recommended security practices in order to run the devices in a protected IT environment. # Vulnerability Classification SICK performs vulnerability classification by using the CVSS scoring system (*CVSS v3.1*). The environmental score is dependent on the customer’s environment and can affect the overall CVSS score. SICK recommends that customers individually evaluate the environmental score to achieve final scoring.	2021-12-14	2021-12-14
RHSA-2022:0082_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This release of Red Hat Process Automation Manager 7.11.1 serves as an update to Red Hat Process Automation Manager 7.11.0, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228)	2022-01-11	2022-01-11
RHSA-2025:1746_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.1.9 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.1.8, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.1.9 Release Notes for information	2025-02-24	2025-02-24

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	about the most significant bug fixes and enhancements included in this release. Security Fix(es): * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS [eap-7.1.z] (CVE-2022-41881) * velocity: arbitrary code execution when attacker is able to modify templates [eap-7.1.z] (CVE-2020-13936) * jackson-databind: mishandles the interaction between serialization gadgets and typing which could result in remote command execution [eap-7.1.z] (CVE-2020-10673) * jackson-databind: Serialization gadgets in anteros-core [eap-7.1.z] (CVE-2020-9548) * jackson-databind: mishandles the interaction between serialization gadgets and typing which could result in remote command execution [eap-7.1.z] (CVE-2020-10672) * wildfly: incorrect JBOSS_LOCAL_USER challenge location may lead to giving access to all the local users [eap-7.1.z] (CVE-2021-3717) * jackson-databind: Serialization gadgets in ibatis-sqlmap [eap-7.1.z] (CVE-2020-9547) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) [eap-7.1.z] (CVE-2021-45046) * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value [eap-7.1.z] (CVE-2021-44228) * jackson-databind: Serialization gadgets in shaded-hikari-config [eap-7.1.z] (CVE-2020-9546) * CXF: Apache CXF: directory listing / code exfiltration [eap-7.1.z] (CVE-2022-46363) * sshd-common: mina-sshd: Java unsafe deserialization vulnerability [eap-7.1.z] (CVE-2022-45047) * jettison: If the value in map is the map's self, the new new JSONObject(map) cause StackOverflowError which may lead to dos [eap-7.1.z] (CVE-2022-45693) * jackson-databind: deep wrapper array nesting wrt UNWRAP_SINGLE_VALUE_ARRAYS [eap-7.1.z] (CVE-2022-42003) * jackson-databind: use of deeply nested arrays [eap-7.1.z] (CVE-2022-42004) * jackson-databind: Lacks certain xbean-reflect/JNDI blocking [eap-7.1.z] (CVE-2020-8840) * snakeyaml: Constructor Deserialization Remote Code Execution [eap-7.1.z] (CVE-2022-1471) * commons-text: apache-commons-text: variable interpolation RCE [eap-7.1.z] (CVE-2022-42889) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:5128_Red Hat	Openshift Logging Security and Bug Fix Release (5.1.5) Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * netty: Request smuggling via content-length header (CVE-2021-21409) * netty-codec: Bzip2Decoder doesn't allow setting size restrictions for decompressed data (CVE-2021-37136) * netty-codec: SnappyFrameDecoder doesn't restrict chunk length and may buffer skippable chunks in an unnecessary way (CVE-2021-37137) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
RHSA-2021:5134_Red Hat	This release of Red Hat Fuse 7.10.0 serves as a replacement for Red Hat Fuse 7.9, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core (CVE-2020-9488, CVE-2021-44228) * nodejs-lodash (CVE-2019-10744) * libthrift (CVE-2020-13949) * xstream (CVE-2020-26217, CVE-2020-26259, CVE-2021-21341, CVE-2021-21342, CVE-2021-21343, CVE-2021-21344, CVE-2021-21345, CVE-2021-21346, CVE-2021-21347, CVE-2021-21348, CVE-2021-21349, CVE-2021-21350, CVE-2021-21351) * undertow (CVE-2020-27782, CVE-2021-3597, CVE-2021-3629, CVE-2021-3690) * xmlbeans (CVE-2021-23926) * batik (CVE-2020-11987) * xmlgraphics-commons (CVE-2020-11988) * tomcat (CVE-2020-13943) * bouncycastle (CVE-2020-15522, CVE-2020-15522) * groovy (CVE-2020-17521) * tomcat (CVE-2020-17527) * jetty (CVE-2020-27218, CVE-2020-27223, CVE-2021-28163,	2021-12-14	2021-12-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	CVE-2021-28164, CVE-2021-28169, CVE-2021-34428) * jackson-dataformat-cbor (CVE-2020-28491) * jboss-remoting (CVE-2020-35510) * kubernetes-client (CVE-2021-20218) * netty (CVE-2021-21290, CVE-2021-21295, CVE-2021-21409) * spring-web (CVE-2021-22118) * cxf-core (CVE-2021-22696) * json-smart (CVE-2021-27568) * jakarta.el (CVE-2021-28170) * commons-io (CVE-2021-29425) * sshd-core (CVE-2021-30129) * cxf-rt-rs-json-basic (CVE-2021-30468) * netty-codec (CVE-2021-37136, CVE-2021-37137) * jsoup (CVE-2021-37714) * poi (CVE-2019-12415) * mysql-connector-java (CVE-2020-2875, CVE-2020-2934) * wildfly (CVE-2021-3536) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
ICSA-22-034-01_CISA	# CISA Disclaimer This CSAF advisory was extracted from unstructured data and may contain inaccuracies. If you notice any errors, please reach out to the designated contact at CISA CSAF: central@cisa.dhs.gov # Legal Notice All information products included in https://us-cert.cisa.gov/ics are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see https://us-cert.cisa.gov/tlp/. # Risk evaluation Successful exploitation of this vulnerability could allow an attacker to gain remote code execution. # Critical infrastructure sectors Critical Manufacturing # Countries/areas deployed Worldwide # Company headquarters location Ireland # Recommended Practices CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability. Specifically, users should: # Recommended Practices CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures. CISA also provides a section for control systems security recommended practices on the ICS webpage on cisa.gov. Several recommended practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies. # Recommended Practices Additional mitigation guidance and recommended practices are publicly available on the ICS webpage on cisa.gov in the Technical Information Paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies. Organizations observing any suspected malicious activity should follow their established internal procedures and report their findings to CISA for tracking and correlation against other incidents. # Exploitability No known public exploits specifically target this vulnerability.	2022-02-03	2022-02-03
RHSA-2022:0203_Red Hat	The releases of Red Hat Fuse 7.8.2, 7.9.1 and 7.10.1 serve as a patch to Red Hat Fuse on Karaf and Red Hat Fuse on Spring Boot and includes security fixes, which are documented in the Release Notes document linked to in the References. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j-core: remote code execution via JDBC Appender (CVE-2021-44832) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) * log4j-core: DoS in log4j 2.x with Thread Context Map (MDC) input data contains a recursive lookup and context lookup pattern (CVE-2021-45105) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-01-20	2022-01-20
RHSA-2021:5141_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or	2021-12-16	2021-12-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-0063_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Junos Space ist eine Software-Plattform, die eine Reihe von Applikationen für das Netzwerkmanagement beinhaltet. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Juniper Junos Space ausnutzen, um Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen, einen Denial-of-Service-Zustand auszulösen, beliebigen Code auszuführen und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Juniper Appliance	2022-01-12	2022-01-12
WID-SEC-W-2022-0351_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache log4j ist ein Framework zum Loggen von Anwendungsmeldungen in Java. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache log4j ausnutzen, um beliebigen Programmcode auszuführen. # Betroffene Betriebssysteme - Appliance - CISCO Appliance - Hardware Appliance - Juniper Appliance - Linux - Native Hypervisor - NetApp Appliance - Sonstiges - UNIX - Windows	2021-12-09	2021-12-09
SSA-661247_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging tool used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens is currently investigating to determine which products are affected and is continuously updating this advisory as more information becomes available. See section Additional Information for more details regarding the investigation status. Note: two additional vulnerabilities were published for Apache Log4j, the impact of which are documented in SSA-501673: https://cert- portal.siemens.com/productcert/pdf/ssa-501673.pdf (CVE-2021-45105) and SSA-784507: https://cert-portal.siemens.com/productcert/pdf/ssa-784507.pdf (CVE-2021-44832). # General Recommendations As a general security measure, Siemens strongly recommends to protect network access to devices with appropriate mechanisms. In order to operate the devices in a protected IT environment, Siemens recommends to configure the environment	2021-12-13	2021-12-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	according to Siemens' operational guidelines for Industrial Security (Download: https://www.siemens.com/cert/operational-guidelines-industrial- security), and to follow the recommendations in the product manuals. Additional information on Industrial Security by Siemens can be found at: https://www.siemens.com/industrialsecurity # Additional Resources For further inquiries on security vulnerabilities in Siemens products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2021:5132_Red Hat	Red Hat Data Grid is an in-memory, distributed, NoSQL datastore solution. It increases application response times and allows for dramatically improving performance while providing availability, reliability, and elastic scale. Data Grid 8.2.2 replaces Data Grid 8.2.1 and includes bug fixes and enhancements. Find out more about Data Grid 8.2.2 in the Release Notes [3]. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-14	2021-12-14
SSA-397453_Siemens	# Summary On 2021-12-09, a vulnerability in Apache Log4j (a logging library used in many Java-based applications) was disclosed, that could allow remote unauthenticated attackers to execute code on vulnerable systems. The vulnerability is tracked as CVE-2021-44228 and is also known as "Log4Shell". On 2021-12-14 an additional denial of service vulnerability (CVE-2021-45046) was published rendering the initial mitigations and fix in version 2.15.0 as incomplete under certain non-default configurations. Log4j versions 2.16.0 and 2.12.2 are supposed to fix both vulnerabilities. On 2021-12-17, CVE-2021-45046 was reclassified with an increased CVSS base score (from 3.7 to 9.0). The potential impact of CVE-2021-45046 now includes - besides denial of service - also information disclosure and local (and potential remote) code execution. Siemens Energy is preparing updates and recommends specific countermeasures for TraceAlertServerPLUS. # General Recommendations Operators of critical power systems (e.g. TSOs or DSOs) worldwide are usually required by regulations to build resilience into the power grids by applying multi-level redundant secondary protection schemes. It is therefore recommended that the operators check whether appropriate resilient protection measures are in place. The risk of cyber incidents impacting the grid's reliability can thus be minimized by virtue of the grid design. Siemens Energy strongly recommends applying the provided security updates using the corresponding tooling and documented procedures made available with the product. If supported by the product, an automated means to apply the security updates across multiple product instances may be used. Siemens Energy strongly recommends prior validation of any security update before being applied, and supervision by trained staff of the update process in the target environment. As a general security measure Siemens Energy strongly recommends to protect network access with appropriate mechanisms (e.g. firewalls, segmentation, VPN). It is advised to configure the environment according to our operational guidelines in order to run the devices in a protected IT environment. # Additional Resources For further inquiries on security vulnerabilities in Siemens	2021-12-20	2021-12-20

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	products and solutions, please contact the Siemens ProductCERT: https://www.siemens.com/cert/advisories # Terms of Use Siemens Security Advisories are subject to the terms and conditions contained in Siemens' underlying license terms or other applicable agreements previously agreed to with Siemens (hereinafter "License Terms"). To the extent applicable to information, software or documentation made available in or through a Siemens Security Advisory, the Terms of Use of Siemens' Global Website (https://www.siemens.com/terms_of_use, hereinafter "Terms of Use"), in particular Sections 8-10 of the Terms of Use, shall apply additionally. In case of conflicts, the License Terms shall prevail over the Terms of Use.		
RHSA-2021:5107_Red Hat	Red Hat OpenShift Container Platform is Red Hat's cloud computing Kubernetes application platform solution designed for on-premise or private cloud deployments. Security Fix(es): * log4j-core: Remote code execution in Log4j 2.x when logs contain an attacker-controlled string value (CVE-2021-44228) * log4j: Remote code execution in Log4j 1.x when application is configured to use JMSAppender (CVE-2021-4104) * log4j-core: DoS in log4j 2.x with thread context message pattern and context lookup pattern (incomplete fix for CVE-2021-44228) (CVE-2021-45046) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-12-16	2021-12-16
CVE-2021-44228_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-12-10	2021-12-10
ICSA-21-357-02_CISA	# CISA Disclaimer This CSAF advisory was extracted from unstructured data and may contain inaccuracies. If you notice any errors, please reach out to the designated contact at CISA CSAF: central@cisa.dhs.gov # Legal Notice All information products included in https://us-cert.cisa.gov/ics are provided "as is" for informational purposes only. The Department of Homeland Security (DHS) does not provide any warranties of any kind regarding any information contained within. DHS does not endorse any commercial product or service, referenced in this product or otherwise. Further dissemination of this product is governed by the Traffic Light Protocol (TLP) marking in the header. For more information about TLP, see https://us-cert.cisa.gov/tlp/. # Risk evaluation Successful exploitation of this vulnerability could allow an attacker to enter malicious input resulting in remote code execution. # Critical infrastructure sectors Critical Manufacturing # Countries/areas deployed Worldwide # Company headquarters location Ireland # Recommended Practices CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability. Specifically, users should: # Recommended Practices CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures. CISA also provides a section for control systems security recommended practices on the ICS webpage on cisa.gov. Several recommended practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies. # Recommended Practices Additional mitigation guidance and recommended practices are publicly available on the ICS webpage on cisa.gov in the Technical Information Paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies. Organizations observing any suspected malicious activity should follow their established internal procedures and report their findings to CISA for tracking and correlation against other incidents. # Exploitability No known public exploits specifically target this vulnerability.	2021-12-23	2021-12-23

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Assessment Critical Escalate Applicable

Context Severity

Scheme	Source	Overall	CVSS Vector	$Severity_{ctx}$
CVSS:2.0	NVD-CNA-NVD + Assessment	7.0	AV:N/AC:M/Au:N/C:C/I:C/A:C/TD:M	High
CVSS:3.1	NVD-CNA-NVD + Assessment	9.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/MAC:H	Critical

Rationale

Vulnerability applicable. Upgrade to latest version on Log4j (2.17.2) pending.

The modified CVSS vectors anticipate that - in the given context - currently no possibility was identified to inject a log message with malicious content and the complexity for an attacker is high (TD:M; MAC:H). The modification is however not sufficient to reduce the severity. Therefore, the upgrade to a newer version or removal of Log4j is imperative to address the vulnerability.

Risk

Direct or indirect injection of messages may result in execution of arbitrary code.

Measures

Fix: Upgrade to latest version of Log4j mandatory.

Mitigation: Eliminate all external options to inject foreign log messages.

Priority Escalate

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD + Assessment-all* provides the vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H/MAC:H
Keywords	**external attacker**
EPSS	This vulnerability has a **94.36 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **0.04 %** of all scored vulnerabilities.
KEV	This vulnerability, affecting **Apache Log4j2**, has been **confirmed to have been exploited in the wild**. Furthermore, it has been **identified in ransomware campaigns**. **Summary** **:** Apache Log4j2 Remote Code Execution Vulnerability . For all affected software assets for which updates exist, the only acceptable remediation actions are: 1) Apply updates; OR 2) remove affected assets from agency networks. Temporary mitigations using one of the measures provided at https://www.cisa.gov/uscert/ed-22-02-apache-log4j-recommended-mitigation-measures are only acceptable until updates are available. **Notes** **:** https://nvd.nist.gov/vuln/detail/CVE-2021-44228 **Due Date** **:** 2021-12-24 **Publish Date** **:** 2021-12-10
EOL	log4j (ver. 2) is still supported by it's vendor. Support End Date: no date provided Vendor does not provide extended support for this product.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Criteria	Explanation
Assessment	The vulnerability status is **applicable**.

CVE-2021-36090

Description

When reading a specially crafted ZIP archive, Compress can be made to allocate large amounts of memory that finally leads to an out of memory error even for very small inputs. This could be used to mount a denial of service attack against services that use Compress' zip package.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-36090	2021-07-13	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-36090	2021-07-13	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-36090	2021-07-13	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`

Weakness

CWE-130

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-mc84-pj99-q6hh	Improper Handling of Length Parameter Inconsistency in Compress	2021-08-02	2021-08-02

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0073	Multiples vulnérabilités dans les produits IBM	2023-01-31	2023-01-31
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2021-AVI-671	Multiples vulnérabilités dans IBM Spectrum Protect Plus	2021-09-03	2021-09-03
CERTFR-2024-AVI-0590	Multiples vulnérabilités dans les produits Atlassian	2024-07-17	2024-07-17
CERTFR-2023-AVI-0325	Multiples vulnérabilités dans les produits Oracle	2023-04-19	2023-04-19
CERTFR-2021-AVI-804	Multiples vulnérabilités dans Oracle PeopleSoft	2021-10-20	2021-10-20
CERTFR-2022-AVI-239	Multiples vulnérabilités dans les produits IBM	2022-03-14	2022-03-14
CERTFR-2021-AVI-932	Multiples vulnérabilités dans les produits IBM	2021-12-10	2021-12-10
CERTFR-2021-AVI-943	Multiples vulnérabilités dans les produits IBM	2021-12-13	2021-12-13

Other

Id	Summary	Create Date	Update Date
RHSA-2022:5555_Red Hat	The ovirt-engine package provides the Red Hat Virtualization Manager, a centralized management platform that allows system administrators to view and manage virtual machines. The Manager provides a comprehensive range of features including search capabilities, resource management, live migrations, and virtual infrastructure provisioning. Security Fix(es): * nodejs-trim-newlines: ReDoS in .end() method (CVE-2021-33623) * apache-commons-compress: infinite loop when reading a specially crafted 7Z archive (CVE-2021-35515) * apache-commons-compress: excessive memory allocation when reading a specially crafted 7Z archive (CVE-2021-35516) * apache-commons-compress: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-35517) * apache-commons-compress: excessive memory allocation when reading a specially crafted ZIP archive (CVE-2021-36090) * nodejs-ansi-regex: Regular expression denial of service (ReDoS) matching ANSI escape codes (CVE-2021-3807) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * semantic-release: Masked secrets can be disclosed if they contain characters that are excluded from uri encoding (CVE-2022-31051) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. A list of bugs fixed in this update is available in the Technical Notes book: https://access.redhat.com/documentation/en-us/red_hat_virtualization/4.4/html-single/technical_notes	2022-07-14	2022-07-14
WID-SEC-W-2023-0426_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM Spectrum Protect ist eine zentralisierte Backuplösung für Systeme im Netzwerk. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM Spectrum Protect ausnutzen, um einen 'Denial of Service'-Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, einen 'Cross-Site-Scripting'-Angriff durchzuführen, beliebigen Code auszuführen, sensible Informationen offenzulegen und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - Sonstiges - Windows	2022-03-13	2022-03-13
CVE-2021-36090_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-07-13	2021-07-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
WID-SEC-W-2024-1627_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, einen Cross-Stite-Scripting-Angriff oder einen unspezifischen Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-07-16	2024-07-16
WID-SEC-W-2023-0132_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-17	2023-01-17
WID-SEC-W-2024-2180_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2022-04-19	2022-04-19
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07
WID-SEC-W-2024-1653_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Siebel CRM ist eine CRM-Lösung von Oracle. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Siebel CRM ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - Windows	2024-07-16	2024-07-16
WID-SEC-W-2023-1016_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen	2023-04-18	2023-04-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows		
WID-SEC-W-2024-0123_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-01-16	2024-01-16
WID-SEC-W-2023-1807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-07-18	2023-07-18
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932)	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2023-1017_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Financial Services ist eine Zusammenstellung von Anwendungen für den Finanzsektor und eine Technologiebasis zur Erfüllung von IT- und Geschäftsanforderungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Financial Services Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-04-18	2023-04-18

Assessment

High | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.28 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **48.85 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2021-35517

Description

When reading a specially crafted TAR archive, Compress can be made to allocate large amounts of memory that finally leads to an out of memory error even for very small inputs. This could be used to mount a denial of service attack against services that use Compress' tar package.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-35517	2021-07-13	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-35517	2021-07-13	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-35517	2021-07-13	2024-11-21

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Assets

Asset Name	Asset Type	Asset Version
A		1.0

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	commons-compress-1.18.jar	1.18

Weakness

CWE-130, CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	AV:N/AC:L/Au:N/C:N/I:N/A:P	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-xqfj-vm6h-2x34	Improper Handling of Length Parameter Inconsistency in Compress	2021-08-02	2021-08-02

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0073	Multiples vulnérabilités dans les produits IBM	2023-01-31	2023-01-31
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2021-AVI-671	Multiples vulnérabilités dans IBM Spectrum Protect Plus	2021-09-03	2021-09-03
CERTFR-2024-AVI-0590	Multiples vulnérabilités dans les produits Atlassian	2024-07-17	2024-07-17
CERTFR-2022-AVI-239	Multiples vulnérabilités dans les produits IBM	2022-03-14	2022-03-14
CERTFR-2021-AVI-932	Multiples vulnérabilités dans les produits IBM	2021-12-10	2021-12-10
CERTFR-2021-AVI-943	Multiples vulnérabilités dans les produits IBM	2021-12-13	2021-12-13

Other

Id	Summary	Create Date	Update Date
RHSA-2022:5555_Red Hat	The ovirt-engine package provides the Red Hat Virtualization Manager, a centralized management platform that allows system administrators to view and manage virtual machines. The Manager provides a comprehensive range of features including search capabilities, resource management, live migrations, and virtual infrastructure provisioning. Security Fix(es): * nodejs-trim-newlines: ReDoS in .end() method (CVE-2021-33623) * apache-commons-compress: infinite loop when reading a specially crafted 7Z archive (CVE-2021-35515) * apache-	2022-07-14	2022-07-14

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	commons-compress: excessive memory allocation when reading a specially crafted 7Z archive (CVE-2021-35516) * apache-commons-compress: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-35517) * apache-commons-compress: excessive memory allocation when reading a specially crafted ZIP archive (CVE-2021-36090) * nodejs-ansi-regex: Regular expression denial of service (ReDoS) matching ANSI escape codes (CVE-2021-3807) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * semantic-release: Masked secrets can be disclosed if they contain characters that are excluded from uri encoding (CVE-2022-31051) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. A list of bugs fixed in this update is available in the Technical Notes book: https://access.redhat.com/documentation/en-us/red_hat_virtualization/4.4/html-single/technical_notes		
WID-SEC-W-2023-0426_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM Spectrum Protect ist eine zentralisierte Backuplösung für Systeme im Netzwerk. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM Spectrum Protect ausnutzen, um einen 'Denial of Service'-Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, einen 'Cross-Site-Scripting'-Angriff durchzuführen, beliebigen Code auszuführen, sensible Informationen offenzulegen und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - Sonstiges - Windows	2022-03-13	2022-03-13
WID-SEC-W-2024-1627_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, einen Cross-Stite-Scripting-Angriff oder einen unspezifischen Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-07-16	2024-07-16
CVE-2021-35517_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-07-13	2021-07-13
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153)	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	* xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07

Assessment

High | Elevated | In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.28 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **48.80 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

CVE-2021-35516

Description

When reading a specially crafted 7Z archive, Compress can be made to allocate large amounts of memory that finally leads to an out of memory error even for very small inputs. This could be used to mount a denial of service attack against services that use Compress' sevenz package.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-35516	2021-07-13	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-35516	2021-07-13	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-35516	2021-07-13	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`

Weakness

CWE-130, CWE-770

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-crv7-7245-f45f	Improper Handling of Length Parameter Inconsistency in Compress	2021-08-02	2021-08-02

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2021-AVI-671	Multiples vulnérabilités dans IBM Spectrum Protect Plus	2021-09-03	2021-09-03
CERTFR-2024-AVI-0590	Multiples vulnérabilités dans les produits Atlassian	2024-07-17	2024-07-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
CERTFR-2021-AVI-943	Multiples vulnérabilités dans les produits IBM	2021-12-13	2021-12-13

Other

Id	Summary	Create Date	Update Date
CVE-2021-35516_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2021-07-13	2021-07-13
RHSA-2022:5555_Red Hat	The ovirt-engine package provides the Red Hat Virtualization Manager, a centralized management platform that allows system administrators to view and manage virtual machines. The Manager provides a comprehensive range of features including search capabilities, resource management, live migrations, and virtual infrastructure provisioning. Security Fix(es): * nodejs-trim-newlines: ReDoS in .end() method (CVE-2021-33623) * apache-commons-compress: infinite loop when reading a specially crafted 7Z archive (CVE-2021-35515) * apache-commons-compress: excessive memory allocation when reading a specially crafted 7Z archive (CVE-2021-35516) * apache-commons-compress: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-35517) * apache-commons-compress: excessive memory allocation when reading a specially crafted ZIP archive (CVE-2021-36090) * nodejs-ansi-regex: Regular expression denial of service (ReDoS) matching ANSI escape codes (CVE-2021-3807) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * semantic-release: Masked secrets can be disclosed if they contain characters that are excluded from uri encoding (CVE-2022-31051) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. A list of bugs fixed in this update is available in the Technical Notes book: https://access.redhat.com/documentation/en-us/red_hat_virtualization/4.4/html-single/technical_notes	2022-07-14	2022-07-14
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) *	2022-07-07	2022-07-07

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07
WID-SEC-W-2024-1627_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, einen Cross-Stite-Scripting-Angriff oder einen unspezifischen Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-07-16	2024-07-16

Assessment

High Elevated In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.28 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **49.00 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

CVE-2021-35515

Description

When reading a specially crafted 7Z archive, the construction of the list of codecs that decompress an entry can result in an infinite loop. This could be used to mount a denial of service attack against services that use Compress' sevenz package.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2021-35515	2021-07-13	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2021-35515	2021-07-13	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2021-35515	2021-07-13	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`

Weakness

CWE-834, CWE-835

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-7hfm-57qf-j43q	Excessive Iteration in Compress	2021-08-02	2021-08-02

Notices

Id	Summary	Create Date	Update Date
CERTFR-2022-AVI-523	Multiples vulnérabilités dans les produits IBM	2022-06-07	2022-06-07
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2021-AVI-671	Multiples vulnérabilités dans IBM Spectrum Protect Plus	2021-09-03	2021-09-03
CERTFR-2024-AVI-0590	Multiples vulnérabilités dans les produits Atlassian	2024-07-17	2024-07-17
CERTFR-2021-AVI-943	Multiples vulnérabilités dans les produits IBM	2021-12-13	2021-12-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Other

Id	Summary	Create Date	Update Date
RHSA-2022:5555_Red Hat	The ovirt-engine package provides the Red Hat Virtualization Manager, a centralized management platform that allows system administrators to view and manage virtual machines. The Manager provides a comprehensive range of features including search capabilities, resource management, live migrations, and virtual infrastructure provisioning. Security Fix(es): * nodejs-trim-newlines: ReDoS in .end() method (CVE-2021-33623) * apache-commons-compress: infinite loop when reading a specially crafted 7Z archive (CVE-2021-35515) * apache-commons-compress: excessive memory allocation when reading a specially crafted 7Z archive (CVE-2021-35516) * apache-commons-compress: excessive memory allocation when reading a specially crafted TAR archive (CVE-2021-35517) * apache-commons-compress: excessive memory allocation when reading a specially crafted ZIP archive (CVE-2021-36090) * nodejs-ansi-regex: Regular expression denial of service (ReDoS) matching ANSI escape codes (CVE-2021-3807) * spring-expression: Denial of service via specially crafted SpEL expression (CVE-2022-22950) * semantic-release: Masked secrets can be disclosed if they contain characters that are excluded from uri encoding (CVE-2022-31051) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. A list of bugs fixed in this update is available in the Technical Notes book: https://access.redhat.com/documentation/en-us/red_hat_virtualization/4.4/html-single/technical_notes	2022-07-14	2022-07-14
RHSA-2022:5532_Red Hat	This release of Red Hat Fuse 7.11.0 serves as a replacement for Red Hat Fuse 7.10 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * fastjson (CVE-2022-25845) * jackson-databind (CVE-2020-36518) * mysql-connector-java (CVE-2021-2471, CVE-2022-21363) * undertow (CVE-2022-1259, CVE-2021-3629, CVE-2022-1319) * wildfly-elytron (CVE-2021-3642) * nodejs-ansi-regex (CVE-2021-3807, CVE-2021-3807) * 3 qt (CVE-2021-3859) * kubernetes-client (CVE-2021-4178) * spring-security (CVE-2021-22119) * protobuf-java (CVE-2021-22569) * google-oauth-client (CVE-2021-22573) * XStream (CVE-2021-29505, CVE-2021-43859) * jdom (CVE-2021-33813, CVE-2021-33813) * apache-commons-compress (CVE-2021-35515, CVE-2021-35516, CVE-2021-35517, CVE-2021-36090) * Kafka (CVE-2021-38153) * xml-security (CVE-2021-40690) * logback (CVE-2021-42550) * netty (CVE-2021-43797) * xnio (CVE-2022-0084) * jdbc-postgresql (CVE-2022-21724) * spring-expression (CVE-2022-22950) * springframework (CVE-2021-22096, CVE-2021-22060, CVE-2021-22096, CVE-2022-22976, CVE-2022-22970, CVE-2022-22971, CVE-2022-22978) * h2 (CVE-2022-23221) * junrar (CVE-2022-23596) * artemis-commons (CVE-2022-23913) * elasticsearch (CVE-2020-7020) * tomcat (CVE-2021-24122, CVE-2021-25329, CVE-2020-9484, CVE-2021-25122, CVE-2021-33037, CVE-2021-30640, CVE-2021-41079, CVE-2021-42340, CVE-2022-23181) * junit4 (CVE-2020-15250) * wildfly-core (CVE-2020-25689, CVE-2021-3644) * kotlin (CVE-2020-29582) * karaf (CVE-2021-41766, CVE-2022-22932) * Spring Framework (CVE-2022-22968) * metadata-extractor (CVE-2022-24614) * poi-scratchpad (CVE-2022-26336) * postgresql-jdbc (CVE-2022-26520) * tika-core (CVE-2022-30126) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-07-07	2022-07-07
CVE-2021-35515_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/	2021-07-13	2021-07-13

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.		
WID-SEC-W-2022-0607_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Red Hat Fuse ist eine Open-Source-Integrationsplattform, die auf Apache Camel basiert. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Red Hat FUSE ausnutzen, um vertrauliche Informationen offenzulegen, beliebigen Code auszuführen, einen Denial of Service Zustand herbeizuführen, Sicherheitsmaßnahmen zu umgehen, Daten und Informationen zu manipulieren und seine Privilegien zu erweitern. # Betroffene Betriebssysteme - Linux - UNIX	2022-07-07	2022-07-07
WID-SEC-W-2024-1627_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, einen Cross-Stite-Scripting-Angriff oder einen unspezifischen Angriff durchzuführen. # Betroffene Betriebssysteme - Windows	2024-07-16	2024-07-16

Assessment

High Elevated In Review

Rationale

The vulnerability has automatically been marked as in review.

Priority

Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.11 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **70.40 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2020-13956

Description

Apache HttpClient versions prior to version 4.5.13 and 5.0.3 can misinterpret malformed authority component in request URIs passed to the library as java.net.URI object and pick the wrong target host for request execution.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2020-13956	2020-12-02	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2020-13956	2020-12-02	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2020-13956	2020-12-02	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
B		`2.0`

Affected Components

Component	Artifact Id	Version
Apache HTTP Components	`httpcore-4.4.13.jar`	`4.4.13`

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:P/A:N`	Medium
CVSS:3.1	NVD-CNA-NVD	5.3	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N`	Medium

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-7r82-7xv7-xcpj	Cross-site scripting in Apache HttpClient	2021-06-03	2021-06-03

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0839	Multiples vulnérabilités dans les produits IBM	2023-10-13	2023-10-13
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2022-AVI-056	Multiples vulnérabilités dans Oracle WebLogic Server	2022-01-19	2022-01-19
CERTFR-2021-AVI-804	Multiples vulnérabilités dans Oracle PeopleSoft	2021-10-20	2021-10-20
CERTFR-2024-AVI-0459	Multiples vulnérabilités dans les produits IBM	2024-05-31	2024-05-31
CERTFR-2021-AVI-559	Multiples vulnérabilités dans Oracle PeopleSoft	2021-07-21	2021-07-21
CERTFR-2021-AVI-556	Multiples vulnérabilités dans Oracle Database Server	2021-07-21	2021-07-21
CERTFR-2023-AVI-0110	Multiples vulnérabilités dans les produits IBM	2023-02-09	2023-02-09
CERTFR-2021-AVI-943	Multiples vulnérabilités dans les produits IBM	2021-12-13	2021-12-13
CERTFR-2023-AVI-0861	Multiples vulnérabilités dans Oracle WebLogic	2023-10-18	2023-10-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Other

Id	Summary	Create Date	Update Date
RHSA-2022:0722_Red Hat	HttpClient is a HTTP/1.1 compliant HTTP agent implementation based on httpcomponents HttpCore. It also provides reusable components for client-side authentication, HTTP state management, and HTTP connection management. Security Fix(es): * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2022-03-01	2022-03-01
WID-SEC-W-2023-2625_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um beliebigen Code auszuführen, Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen, einen Denial-of-Service-Zustand herbeizuführen und einen Cross-Site-Scripting-Angriff durchzuführen. # Betroffene Betriebssysteme - Linux	2023-10-10	2023-10-10
RHSA-2022:1860_Red Hat	Maven is a software project management and comprehension tool. Based on the concept of a project object model (POM), Maven can manage a project's build, reporting and documentation from a central piece of information. Security Fix(es): * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Additional Changes: For detailed information on changes in this release, see the Red Hat Enterprise Linux 8.6 Release Notes linked from the References section.	2022-05-10	2022-05-10
WID-SEC-W-2022-0044_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache HttpComponents ist ein Toolset von HTTP Java Komponenten. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache HttpComponents ausnutzen, um den Nutzer zu täuschen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2020-10-07	2020-10-07
WID-SEC-W-2023-2691_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Die Komponenten der Oracle JDEdwards sind vollständig integrierte und komplette Lösungen geschäftlicher Anwendungen (ERP) für Unternehmen. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Oracle JD Edwards ausnutzen, um die Integrität zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-10-17	2023-10-17
RHSA-2021:0248_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.5 serves as a	2021-01-25	2021-01-25

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	replacement for Red Hat JBoss Enterprise Application Platform 7.3.4, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.5 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * wildfly: Potential Memory leak in Wildfly when using OpenTracing (CVE-2020-27822) * undertow: special character in query results in server errors (CVE-2020-27782) * wildfly-core: memory leak in WildFly host-controller in domain mode while not able to reconnect to domain-controller (CVE-2020-25689) * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * wildfly: resource adapter logs plaintext JMS password at warning level on connection error (CVE-2020-25640) * resteasy-client: potential sensitive information leakage in JAX-RS RESTEasy Client's WebApplicationException handling (CVE-2020-25633) For more details about the security issue(s), including the impact, a CVSS score, and other related information, see the CVE page(s) listed in the References section.		
WID-SEC-W-2024-0794_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Dell ECS ist ein Objektspeichersystem. # Angriff Ein Angreifer kann mehrere Schwachstellen in Dell ECS ausnutzen, um seine Privilegien zu erweitern, beliebigen Programmcode mit Administratorrechten auszuführen, Informationen offenzulegen, Dateien zu manipulieren, einen Cross-Site-Scripting-Angriff durchzuführen, Sicherheitsvorkehrungen zu umgehen oder einen Denial of Service Zustand herbeizuführen. # Betroffene Betriebssysteme - Linux - UNIX - Windows	2024-04-04	2024-04-04
WID-SEC-W-2023-0132_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-01-17	2023-01-17
RHSA-2021:0603_Red Hat	Red Hat Decision Manager is an open source decision management platform that combines business rules management, complex event processing, Decision Model & Notation (DMN) execution, and Business Optimizer for solving planning problems. It automates business decisions and makes that logic available to the entire business. This release of Red Hat Decision Manager 7.10.0 serves as an update to Red Hat Decision Manager 7.9.1, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * hibernate-core-kie-server-ee8: hibernate-core: SQL injection vulnerability when both hibernate.use_sql_comments and JPQL String literals are used (CVE-2020-25638) * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * xercesimpl: wildfly: XML validation manipulation due to incomplete application of use-grammar-pool-only in xercesImpl (CVE-2020-14338) * log4j-core: log4j: improper validation of certificate with host mismatch in SMTP appender (CVE-2020-9488) For more details about the security issue(s), including the impact, a CVSS score,	2021-02-17	2021-02-17

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:4100_Red Hat	This release of Red Hat Integration - Service registry 2.0.2.GA serves as a replacement for 2.0.1.GA, and includes the below security fixes. Security Fix(es): * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * RESTEasy: PathParam in RESTEasy can lead to a reflected XSS attack (CVE-2021-20293) * resteasy: Error message exposes endpoint class information (CVE-2021-20289) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-11-02	2021-11-02
RHSA-2021:0246_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.5 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.3.4, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.5 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * wildfly: Potential Memory leak in Wildfly when using OpenTracing (CVE-2020-27822) * undertow: special character in query results in server errors (CVE-2020-27782) * wildfly-core: memory leak in WildFly host-controller in domain mode while not able to reconnect to domain-controller (CVE-2020-25689) * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * wildfly: resource adapter logs plaintext JMS password at warning level on connection error (CVE-2020-25640) * resteasy-client: potential sensitive information leakage in JAX-RS RESTEasy Client's WebApplicationException handling (CVE-2020-25633) For more details about the security issue(s), including the impact, a CVSS score, and other related information, see the CVE page(s) listed in the References section.	2021-01-25	2021-01-25
RHSA-2022:1861_Red Hat	Maven is a software project management and comprehension tool. Based on the concept of a project object model (POM), Maven can manage a project's build, reporting and documentation from a central piece of information. Security Fix(es): * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section. Additional Changes: For detailed information on changes in this release, see the Red Hat Enterprise Linux 8.6 Release Notes linked from the References section.	2022-05-10	2022-05-10
WID-SEC-W-2023-2674_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-10-17	2023-10-17
WID-SEC-W-2024-1659_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Insurance Applications ist eine Produktfamilie mit Lösungen für die Versicherungsbranche. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Insurance Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		
RHSA-2021:3140_Red Hat	This release of Red Hat Fuse 7.9.0 serves as a replacement for Red Hat Fuse 7.8, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * hawtio-osgi (CVE-2017-5645) * prometheus-jmx-exporter: snakeyaml (CVE-2017-18640) * apache-commons-compress (CVE-2019-12402) * karaf-transaction-manager-narayana: netty (CVE-2019-16869, CVE-2019-20445) * tomcat (CVE-2020-1935, CVE-2020-1938, CVE-2020-9484, CVE-2020-13934, CVE-2020-13935, CVE-2020-11996) * spring-cloud-config-server (CVE-2020-5410) * velocity (CVE-2020-13936) * httpclient: apache-httpclient (CVE-2020-13956) * shiro-core: shiro (CVE-2020-17510) * hibernate-core (CVE-2020-25638) * wildfly-openssl (CVE-2020-25644) * jetty (CVE-2020-27216, CVE-2021-28165) * bouncycastle (CVE-2020-28052) * wildfly (CVE-2019-14887, CVE-2020-25640) * resteasy-jaxrs: resteasy (CVE-2020-1695) * camel-olingo4 (CVE-2020-1925) * springframework (CVE-2020-5421) * jsf-impl: Mojarra (CVE-2020-6950) * resteasy (CVE-2020-10688) * hibernate-validator (CVE-2020-10693) * wildfly-elytron (CVE-2020-10714) * undertow (CVE-2020-10719) * activemq (CVE-2020-13920) * cxf-core: cxf (CVE-2020-13954) * fuse-apicurito-operator-container: golang.org/x/text (CVE-2020-14040) * jboss-ejb-client: wildfly (CVE-2020-14297) * xercesimpl: wildfly (CVE-2020-14338) * xnio (CVE-2020-14340) * flink: apache-flink (CVE-2020-17518) * resteasy-client (CVE-2020-25633) * xstream (CVE-2020-26258) * mybatis (CVE-2020-26945) * pdfbox (CVE-2021-27807, CVE-2021-27906) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-08-11	2021-08-11
RHSA-2021:3700_Red Hat	AMQ Broker is a high-performance messaging implementation based on ActiveMQ Artemis. It uses an asynchronous journal for fast message persistence, and supports multiple languages, protocols, and platforms. This release of Red Hat AMQ Broker 7.9.0 serves as a replacement for Red Hat AMQ Broker 7.8.2, and includes security and bug fixes, and enhancements. For further information, refer to the release notes linked to in the References section. Security Fix(es): * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * jetty: request containing multiple Accept headers with a large number of "quality" parameters may lead to DoS (CVE-2020-27223) * resteasy-jaxrs: resteasy: Error message exposes endpoint class information (CVE-2021-20289) * netty: Information disclosure via the local system temporary directory (CVE-2021-21290) * netty: possible request smuggling in HTTP/2 due missing validation (CVE-2021-21295) * netty: Request smuggling via content-length header (CVE-2021-21409) * jetty-server: jetty: Symlink directory exposes webapp directory contents (CVE-2021-28163) * jetty-server: jetty: Ambiguous paths can access WEB-INF (CVE-2021-28164) * jetty-server: jetty: Resource exhaustion when receiving an invalid large TLS frame (CVE-2021-28165) * jetty-server: jetty: requests to the ConcatServlet and WelcomeFilter are able to access protected resources within the WEB-INF directory (CVE-2021-28169) * commons-io: apache-commons-io: Limited path traversal in Apache Commons IO 2.2 to 2.6 (CVE-2021-29425) * broker: Red Hat AMQ Broker: discloses JDBC username and password in the application log file (CVE-2021-3425) * jetty-server: jetty: SessionListener can prevent a session from being	2021-09-30	2021-09-30

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	invalidated breaking logout (CVE-2021-34428) * jetty-server: jetty: crafted URIs allow bypassing security constraints (CVE-2021-34429) * broker: AMQ Broker 7: Incorrect privilege in Management Console (CVE-2021-3763) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		
RHSA-2021:0084_Red Hat	This release of Red Hat build of Quarkus 1.7.6 includes security updates, bug fixes, and enhancements. For more information, see the release notes page listed in the References section. Security Fix(es): * apache http client: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * vertx-web: Vert.x StaticHandler backslash issue on Windows (QUARKUS-458) For more details about the security issues and their impact, the CVSS score, acknowledgments, and other related information see the CVE pages listed in the References section.	2021-01-12	2021-01-12
RHSA-2021:0250_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.5 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.3.4, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.5 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * wildfly: Potential Memory leak in Wildfly when using OpenTracing (CVE-2020-27822) * undertow: special character in query results in server errors (CVE-2020-27782) * wildfly-core: memory leak in WildFly host-controller in domain mode while not able to reconnect to domain-controller (CVE-2020-25689) * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * wildfly: resource adapter logs plaintext JMS password at warning level on connection error (CVE-2020-25640) * resteasy-client: potential sensitive information leakage in JAX-RS RESTEasy Client's WebApplicationException handling (CVE-2020-25633) For more details about the security issue(s), including the impact, a CVSS score, and other related information, see the CVE page(s) listed in the References section.	2021-01-25	2021-01-25
RHSA-2021:0327_Red Hat	Red Hat Single Sign-On 7.4 is a standalone server, based on the Keycloak project, that provides authentication and standards-based single sign-on capabilities for web and mobile applications. This release of Red Hat Single Sign-On 7.4.5 serves as a replacement for Red Hat Single Sign-On 7.4.4, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * undertow: special character in query results in server errors (CVE-2020-27782) * keycloak: Default Client configuration is vulnerable to SSRF using "request_uri" parameter (CVE-2020-10770) * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * wildfly: resource adapter logs plaintext JMS password at warning level on connection error (CVE-2020-25640) * wildfly-core: memory leak in WildFly host-controller in domain mode while not able to reconnect to domain-controller (CVE-2020-25689) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-02-01	2021-02-01
WID-SEC-W-2023-1807_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten	2023-07-18	2023-07-18

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Business Anwendungen. # Angriff Ein Angreifer aus dem angrenzenden Netzwerk oder ein entfernter anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - UNIX - Linux - Windows		
WID-SEC-W-2024-3197_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Commerce ist eine elektronische Handelsplattform. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Commerce ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Windows	2024-10-15	2024-10-15
WID-SEC-W-2024-1637_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Oracle Fusion Middleware bündelt mehrere Produkte zur Erstellung, Betrieb und Management von intelligenten Business Anwendungen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Fusion Middleware ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows	2024-07-16	2024-07-16
RHSA-2021:0247_Red Hat	Red Hat JBoss Enterprise Application Platform 7 is a platform for Java applications based on the WildFly application runtime. This release of Red Hat JBoss Enterprise Application Platform 7.3.5 serves as a replacement for Red Hat JBoss Enterprise Application Platform 7.3.4, and includes bug fixes and enhancements. See the Red Hat JBoss Enterprise Application Platform 7.3.5 Release Notes for information about the most significant bug fixes and enhancements included in this release. Security Fix(es): * wildfly: Potential Memory leak in Wildfly when using OpenTracing (CVE-2020-27822) * undertow: special character in query results in server errors (CVE-2020-27782) * wildfly-core: memory leak in WildFly host-controller in domain mode while not able to reconnect to domain-controller (CVE-2020-25689) * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * wildfly: resource adapter logs plaintext JMS password at warning level on connection error (CVE-2020-25640) * resteasy-client: potential sensitive information leakage in JAX-RS RESTEasy Client's WebApplicationException handling (CVE-2020-25633) For more details about the security issue(s), including the impact, a CVSS score, and other related information, see the CVE page(s) listed in the References section.	2021-01-25	2021-01-25
CVE-2020-13956_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2020-10-08	2020-10-08
WID-SEC-W-2024-1643_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Communications Applications umfasst	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	eine Sammlung von Werkzeugen zur Verwaltung von Messaging-, Kommunikationsdiensten und -ressourcen. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in Oracle Communications Applications ausnutzen, um die Vertraulichkeit, Integrität und Verfügbarkeit zu gefährden. # Betroffene Betriebssysteme - Sonstiges - UNIX - Windows		
RHSA-2021:0811_Red Hat	This release of Red Hat Integration - Camel K - Tech-Preview 3 serves as a replacement for tech-preview 2, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * jackson-databind: FasterXML DOMDeserializer insecure entity expansion is vulnerable to XML external entity (XXE) (CVE-2020-25649) * cassandra: allows manipulation of the RMI registry to perform a MITM attack and capture user names and passwords used to access the JMX interface (CVE-2020-13946) * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-03-11	2021-03-11
WID-SEC-W-2024-1872_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein entfernter anonymer oder authentifizierter Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um vertrauliche Informationen offenzulegen, Sicherheitsmaßnahmen zu umgehen, Dateien zu manipulieren, einen Denial-of-Service-Zustand auszulösen und einen Cross-Site-Scripting-Angriff durchzuführen. # Betroffene Betriebssysteme - Linux	2021-07-25	2021-07-25
RHSA-2021:1044_Red Hat	Red Hat Process Automation Manager is an open source business process management suite that combines process management and decision service management, and enables business and IT users to create, manage, validate, and deploy process applications and decision services. This release of Red Hat Process Automation Manager 7.10.1 serves as an update to Red Hat Process Automation Manager 7.10.0, and includes bug fixes, which are documented in the Release Notes document linked to in the References. Security Fix(es): * httpclient: apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * log4j-core: log4j: improper validation of certificate with host mismatch in SMTP appender (CVE-2020-9488) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-03-30	2021-03-30
RHSA-2023:3954_Red Hat	This release of Red Hat Fuse 7.12 serves as a replacement for Red Hat Fuse 7.11 and includes bug fixes and enhancements, which are documented in the Release Notes document linked in the References. Security Fix(es): * hazelcast: Hazelcast connection caching (CVE-2022-36437) * spring-security: Authorization rules can be bypassed via forward or include dispatcher types in Spring Security (CVE-2022-31692) * xstream: Denial of Service by injecting recursive collections or maps based on element's hash values raising a stack overflow (CVE-2022-41966) * Apache-Commons-BCEL: arbitrary bytecode produced via out-of-bounds writing (CVE-2022-42920) * Apache CXF: SSRF Vulnerability (CVE-2022-46364) * Undertow: Infinite loop in SslConduit during close (CVE-2023-1108) * json-smart: Uncontrolled	2023-06-29	2023-06-29

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Resource Consumption vulnerability in json-smart (Resource Exhaustion) (CVE-2023-1370) * springframework: Security Bypass With Un-Prefixed Double Wildcard Pattern (CVE-2023-20860) * spring-boot: Spring Boot Welcome Page DoS Vulnerability (CVE-2023-20883) * jakarta-commons-httpclient: missing connection hostname check against X.509 certificate name (CVE-2012-5783) * apache-httpclient: incorrect handling of malformed authority component in request URIs (CVE-2020-13956) * undertow: Server identity in https connection is not checked by the undertow client (CVE-2022-4492) * Moment.js: Path traversal in moment.locale (CVE-2022-24785) * batik: Server-Side Request Forgery (CVE-2022-38398) * batik: Server-Side Request Forgery (CVE-2022-38648) * batik: Server-Side Request Forgery (SSRF) vulnerability (CVE-2022-40146) * batik: Apache XML Graphics Batik vulnerable to code execution via SVG (CVE-2022-41704) * dev-java/snakeyaml: DoS via stack overflow (CVE-2022-41854) * codec-haproxy: HAProxyMessageDecoder Stack Exhaustion DoS (CVE-2022-41881) * engine.io: Specially crafted HTTP request can trigger an uncaught exception (CVE-2022-41940) * postgresql-jdbc: Information leak of prepared statement data due to insecure temporary file permissions (CVE-2022-41946) * batik: Untrusted code execution in Apache XML Graphics Batik (CVE-2022-42890) * Apache CXF: directory listing / code exfiltration (CVE-2022-46363) * springframework: Spring Expression DoS Vulnerability (CVE-2023-20861) * shiro: Authentication bypass through a specially crafted HTTP request (CVE-2023-22602) * bouncycastle: potential blind LDAP injection attack using a self-signed certificate (CVE-2023-33201) * tomcat: JsonErrorReportValve injection (CVE-2022-45143) For more details about the security issues, including the impact, CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.		

Assessment Medium None In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority None

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N`
Keywords	No keyword sets matched.
EPSS	This vulnerability has a **0.49 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **35.40 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2019-12402

Description

The file name encoding algorithm used internally in Apache Commons Compress 1.15 to 1.18 can get into an infinite loop when faced with specially crafted inputs. This can lead to a denial of service attack if an attacker can choose the file names inside of an archive created by Compress.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2019-12402	2019-08-30	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2019-12402	2019-08-30	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2019-12402	2019-08-30	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

Affected Components

Component	Artifact Id	Version
Apache Commons Compress	`commons-compress-1.18.jar`	`1.18`

Weakness

CWE-835

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	5.0	`AV:N/AC:L/Au:N/C:N/I:N/A:P`	Medium
CVSS:3.1	NVD-CNA-NVD	7.5	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`	High

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-53x6-4x5p-rrvv	Denial of Service in Apache Commons Compress	2019-10-11	2019-10-11

Notices

Id	Summary	Create Date	Update Date
CERTFR-2024-AVI-0590	Multiples vulnérabilités dans les produits Atlassian	2024-07-17	2024-07-17

Other

Id	Summary	Create Date	Update Date
WID-SEC-W-2022-0770_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM DB2 ist ein relationales Datenbanksystem (RDBS) von IBM. # Angriff Ein entfernter, anonymer oder authentisierter Angreifer kann mehrere Schwachstellen in IBM DB2 ausnutzen, um seine	2020-04-23	2020-04-23

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	Privilegien zu erhöhen oder einen Denial of Service zu verursachen # Betroffene Betriebssysteme - Linux - UNIX - Windows		
CVE-2019-12402_Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2019-08-27	2019-08-27
WID-SEC-W-2024-1773_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Apache Commons ist ein Apache-Projekt, das alle Aspekte der wiederverwendbaren Java-Komponenten behandelt. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in Apache Commons Compress ausnutzen, um einen Denial of Service Angriff durchzuführen. # Betroffene Betriebssysteme - Sonstiges	2019-08-27	2019-08-27
RHSA-2021:3140_Red Hat	This release of Red Hat Fuse 7.9.0 serves as a replacement for Red Hat Fuse 7.8, and includes bug fixes and enhancements, which are documented in the Release Notes document linked to in the References. Security Fix(es): * hawtio-osgi (CVE-2017-5645) * prometheus-jmx-exporter: snakeyaml (CVE-2017-18640) * apache-commons-compress (CVE-2019-12402) * karaf-transaction-manager-narayana: netty (CVE-2019-16869, CVE-2019-20445) * tomcat (CVE-2020-1935, CVE-2020-1938, CVE-2020-9484, CVE-2020-13934, CVE-2020-13935, CVE-2020-11996) * spring-cloud-config-server (CVE-2020-5410) * velocity (CVE-2020-13936) * httpclient: apache-httpclient (CVE-2020-13956) * shiro-core: shiro (CVE-2020-17510) * hibernate-core (CVE-2020-25638) * wildfly-openssl (CVE-2020-25644) * jetty (CVE-2020-27216, CVE-2021-28165) * bouncycastle (CVE-2020-28052) * wildfly (CVE-2019-14887, CVE-2020-25640) * resteasy-jaxrs: resteasy (CVE-2020-1695) * camel-olingo4 (CVE-2020-1925) * springframework (CVE-2020-5421) * jsf-impl: Mojarra (CVE-2020-6950) * resteasy (CVE-2020-10688) * hibernate-validator (CVE-2020-10693) * wildfly-elytron (CVE-2020-10714) * undertow (CVE-2020-10719) * activemq (CVE-2020-13920) * cxf-core: cxf (CVE-2020-13954) * fuse-apicurito-operator-container: golang.org/x/text (CVE-2020-14040) * jboss-ejb-client: wildfly (CVE-2020-14297) * xercesimpl: wildfly (CVE-2020-14338) * xnio (CVE-2020-14340) * flink: apache-flink (CVE-2020-17518) * resteasy-client (CVE-2020-25633) * xstream (CVE-2020-26258) * mybatis (CVE-2020-26945) * pdfbox (CVE-2021-27807, CVE-2021-27906) For more details about the security issue(s), including the impact, a CVSS score, acknowledgments, and other related information, refer to the CVE page(s) listed in the References section.	2021-08-11	2021-08-11
WID-SEC-W-2022-1375_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung JFrog Artifactory ist eine universelle DevOps-Lösung. # Angriff Ein entfernter, anonymer Angreifer kann mehrere Schwachstellen in JFrog Artifactory ausnutzen, um seine Privilegien zu erweitern, beliebigen Code auszuführen, Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen und einen Denial-of-Service-Zustand auszulösen. # Betroffene Betriebssysteme - UNIX - Linux	2022-09-11	2022-09-11
WID-SEC-W-2024-1627_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen	2024-07-16	2024-07-16

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung Confluence ist eine kommerzielle Wiki-Software. # Angriff Ein entfernter anonymer Angreifer kann mehrere Schwachstellen in Atlassian Confluence ausnutzen, um einen Denial-of-Service-Zustand zu erzeugen, einen Cross-Stite-Scripting-Angriff oder einen unspezifischen Angriff durchzuführen. # Betroffene Betriebssysteme - Windows		

Assessment High Elevated In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority Elevated

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
Keywords	**resource exemption**
EPSS	This vulnerability has a **0.38 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **40.98 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	No end-of-life (EOL) information available.
Assessment	The vulnerability status is **in review**.

CVE-2016-1000027

Description

Pivotal Spring Framework through 5.3.16 suffers from a potential remote code execution (RCE) issue if used for Java deserialization of untrusted data. Depending on how the library is implemented within a product, this issue may or not occur, and authentication may be required. NOTE: the vendor's position is that untrusted data is not an intended use case. The product's behavior will not be changed because some users rely on deserialization of trusted data.

References

Target	Hyperlink	Create Date	Update Date
NVD	https://nvd.nist.gov/vuln/detail/CVE-2016-1000027	2020-01-02	2024-11-21
MITRE	https://www.cve.org/CVERecord?id=CVE-2016-1000027	2020-01-02	2024-11-21
CVE Details	https://www.cvedetails.com/cve/CVE-2016-1000027	2020-01-02	2024-11-21

Affected Assets

Asset Name	Asset Type	Asset Version
A		`1.0`

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Affected Components

Component	Artifact Id	Version
Spring Framework	spring-expression-5.3.14.jar	5.3.14
Spring Framework	spring-context-5.3.14.jar	5.3.14
Spring Framework	spring-aop-5.3.14.jar	5.3.14
Spring Framework	spring-beans-5.3.14.jar	5.3.14
Spring Framework	spring-jcl-5.3.14.jar	5.3.14
Spring Framework	spring-core-5.3.14.jar	5.3.14

Weakness
CWE-502

Initial Severity

Scheme	Source	Overall	CVSS Vector	Severity
CVSS:2.0	NVD-CNA-NVD	7.5	AV:N/AC:L/Au:N/C:P/I:P/A:P	High
CVSS:3.1	NVD-CNA-NVD	9.8	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H	Critical

Advisories

Alerts

Id	Summary	Create Date	Update Date
GHSA-4wrc-f8pq-fpqp	Pivotal Spring Framework contains unsafe Java deserialization methods	2022-05-24	2022-05-24

Notices

Id	Summary	Create Date	Update Date
CERTFR-2023-AVI-0839	Multiples vulnérabilités dans les produits IBM	2023-10-13	2023-10-13
CERTFR-2023-AVI-0908	Multiples vulnérabilités dans les produits NetApp	2023-11-03	2023-11-03
CERTFR-2025-AVI-0590	Multiples vulnérabilités dans les produits IBM	2025-07-11	2025-07-11
CERTFR-2024-AVI-0113	Multiples vulnérabilités dans les produits IBM	2024-02-09	2024-02-09
CERTFR-2025-AVI-0756	Multiples vulnérabilités dans les produits VMware	2025-09-05	2025-09-05
CERTFR-2025-AVI-0622	Multiples vulnérabilités dans les produits VMware	2025-07-25	2025-07-25

Other

Id	Summary	Create Date	Update Date
CVE-2016-1000027_ Red Hat	# Terms of Use This content is licensed under the Creative Commons Attribution 4.0 International License (https://creativecommons.org/licenses/by/4.0/). If you distribute this content, or a modified version of it, you must provide attribution to Red Hat Inc. and provide a link to the original.	2016-07-08	2016-07-08
WID-SEC-W-2023-2625_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich,	2023-10-10	2023-10-10

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Id	Summary	Create Date	Update Date
	die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung IBM QRadar Security Information and Event Management (SIEM) bietet Unterstützung bei der Erkennung und Priorisierung von Sicherheitsbedrohungen im Unternehmen. # Angriff Ein entfernter, anonymer, authentisierter oder lokaler Angreifer kann mehrere Schwachstellen in IBM QRadar SIEM ausnutzen, um beliebigen Code auszuführen, Sicherheitsmaßnahmen zu umgehen, vertrauliche Informationen offenzulegen, einen Denial-of-Service-Zustand herbeizuführen und einen Cross-Site-Scripting-Angriff durchzuführen. # Betroffene Betriebssysteme - Linux		
WID-SEC-W-2023-1060_BSI	# LEGAL_DISCLAIMER Das BSI ist als Anbieter für die eigenen, zur Nutzung bereitgestellten Inhalte nach den allgemeinen Gesetzen verantwortlich. Nutzerinnen und Nutzer sind jedoch dafür verantwortlich, die Verwendung und/oder die Umsetzung der mit den Inhalten bereitgestellten Informationen sorgfältig im Einzelfall zu prüfen. # Produktbeschreibung ActiveIQ Unified Manager ist eine Managementlösung für NetApp Storage Produkte. # Angriff Ein entfernter, anonymer Angreifer kann eine Schwachstelle in NetApp ActiveIQ Unified Manager ausnutzen, um einen Denial of Service Angriff durchzuführen, Informationen offenzulegen oder Dateien zu manipulieren. # Betroffene Betriebssysteme - UNIX - Linux - Windows	2023-04-20	2023-04-20

Assessment Critical Escalate In Review

Rationale
The vulnerability has automatically been marked as in review.

Priority Escalate

Criteria	Explanation
CVSS Overall	*CVSS:3.1 NVD-CNA-NVD* provides the vector: `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`
Keywords	**external attacker**
EPSS	This vulnerability has a **59.21 %** chance of being exploited in the next 30 days according to FIRST. It ranks in the top **1.81 %** of all scored vulnerabilities.
KEV	vulnerability has not been confirmed to have been exploited in the wild.
EOL	spring-framework (ver. 5.3) is still supported by it's vendor with extended support. Support End Date: 1 year and 2 months ago Extended Support End Date: in 3 years and 8 months
Assessment	The vulnerability status is **in review**.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Glossary

Common Product Enumeration
Common Product Enumeration (CPE) is a scheme used by the *NVD* to identify vulnerable products (software and hardware). A CPE has a defined structure consisting of several parts:

```
cpe:<cpe_version>:<part>:<vendor>:<product>:<version>:<update>:<edition>:
    <language>:<sw_edition>:<target_sw>:
        <target_hw>:<other>
```

With a CPE several vulnerabilities (*CVE*) can be associated.

Common Vulnerability Exposure
A Common Vulnerability Exposure (CVE) is a public representation of a vulnerability. Each CVE covers a description and machine-readable information for version matching.

Common Vulnerability Scoring System
The severity of security vulnerabilities is usually determined using the Common Vulnerability Scoring System (CVSS). This uses individual metrics to measure various factors of a vulnerability.

National Institute of Standards and Technology
The National Institute of Standards and Technology (NIST) is a science laboratory and agency of the United State Department of Commerce. Apart from many other activities the NIST publishes the Cybersecurity Framework guidance on information security and risk management.

National Vulnerability Database
The National Vulnerability Database (NVD) is a repository of vulnerability related data. The NVD hosts *CPE* and *CVE* details for retrieving and matching vulnerability information.

The NVD is managed by the *National Institute of Standards and Technology (NIST)*.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved

Log of Template Changes

Revision	Date	Author	Modification
01	27.08.2025	K. Klein	Initial structure for report generation.

written permission of metaeffekt GmbH.
© 2025 metaeffekt GmbH - All rights reserved